

Aula 05

*Prefeitura de Ponta Grossa-PR (Nível
Médio e Superior) Informática Básica -
2026 (Pós-Edital)*

Autor:

**Diego Carvalho, Renato da Costa,
Equipe Informática e TI**

07 de Agosto de 2026

Índice

1) Segurança da Informação - Teoria	3
2) Segurança da Informação - Mapa Mental	68
3) Segurança da Informação - Resumo	71
4) Segurança da Informação - Questões Comentadas - MULTIBANCAS	78
5) Segurança da Informação - Lista de Questões - MULTIBANCAS	103



TÓPICOS DA AULA

Tópicos da Aula	3
Segurança da Informação	6
Conceitos Básicos	6
Controles de Segurança	9
Terminologia	10
Princípios Fundamentais	12
Confidencialidade	12
Integridade	13
Disponibilidade	14
Princípios Adicionais	15
Autenticidade	15
Irretratabilidade	17
Desafio	19
Criptologia	20
Conceitos Básicos	20
Esteganografia	21
Criptografia e Criptoanálise	24
Conceitos Básicos	24
Técnicas de Criptografia	26
Principais Algoritmos	34
Autenticidade	35
Conceitos Básicos	35
Método de Autenticação: O que você sabe?	35
Método de Autenticação: O que você é?	38



Método de Autenticação: O que você tem?.....	38
Autenticação Forte	41
Assinatura Digital	44
Conceitos Básicos	44
Algoritmos de Hash	49
Controle de Acesso	52
Certificado Digital	56
Conceitos Básicos	56
Infraestrutura de Chave Pública (ICP-Brasil)	60
Tipos de Certificado	66

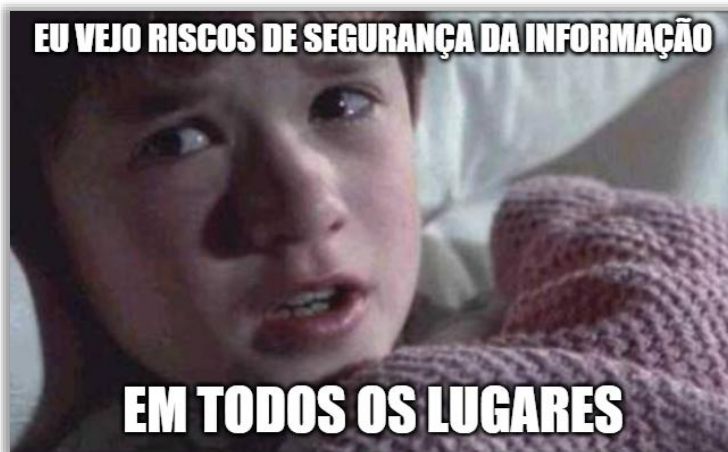
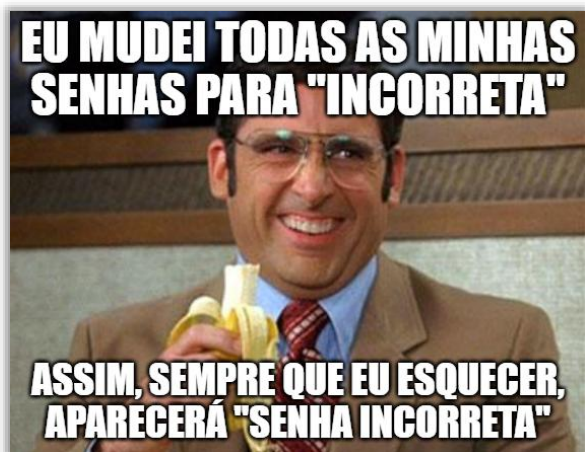


APRESENTAÇÃO DA AULA

Pessoal, o tema da nossa aula é: **Segurança da Informação**. Nós vamos ver os conceitos básicos, terminologias e princípios fundamentais. Depois vamos entender mais sobre criptografia, assinatura digital e certificação digital. Esses são assuntos que estão no dia-a-dia de vocês mesmo que vocês não percebam. *Quem aí não viu as tretas que rolaram com hackeamento de celulares recentemente na política brasileira?* Pois é, ninguém está imune...



PROFESSOR DIEGO CARVALHO - [WWW.INSTAGRAM.COM/PROFESSORDIEGOCARVALHO](https://www.instagram.com/professordiego-carvalho)



Galera, todos os tópicos da aula possuem Faixas de Incidência, que indicam se o assunto cai muito ou pouco em prova. Diego, se cai pouco para que colocar em aula? Cair pouco não significa que não cairá justamente na sua prova! A ideia aqui é: se você está com pouco tempo e precisa ver somente aquilo que cai mais, você pode filtrar pelas incidências média, alta e altíssima; se você tem tempo sobrando e quer ver tudo, vejam também as incidências baixas e baixíssimas. *Fechado?*

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

INCIDÊNCIA EM PROVA: BAIXA

INCIDÊNCIA EM PROVA: MÉDIA

INCIDÊNCIA EM PROVA: ALTA

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Além disso, essas faixas não são por banca – é baseado tanto na quantidade de vezes que caiu em prova independentemente da banca e também em minhas avaliações sobre cada assunto...



SEGURANÇA DA INFORMAÇÃO

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

Vamos conversar um pouco sobre segurança da informação? Tem um comportamento muito comum que acontece com quase todo mundo: acordar, tomar banho, escovar os dentes, tomar um café, ir trabalhar, guardar os pertences na gaveta, trabalhar o dia todo e, no fim do expediente, pegar suas coisas e ir embora para casa. Tudo certo até aqui, né? Mas deixa eu te perguntar: quando você sai de casa, deixa a porta destrancada? Deixa o carro aberto na rua, sem alarme? Seu cofre fica escancarado? Se sua resposta foi “não” para tudo isso – ótimo, é o que eu esperava!

Afinal, quando falamos de bens físicos, somos bem cuidadosos. A gente tranca, protege, investe em segurança. Por quê? Porque sabemos que esses bens têm valor – e ninguém quer ser roubado. Agora vem o ponto: por que, quando o assunto é informação, a maioria das pessoas relaxa tanto? Deem uma olhada nessa notícia que circulou na internet:

The top 10 most common passwords list in 2025

1. 123456
2. 123456789
3. qwerty
4. password
5. 12345
6. qwerty123
7. 1q2w3e
8. 12345678
9. 111111
10. 1234567890

Em pleno 2025, as senhas mais usadas no mundo ainda são "123456". Sério mesmo! Parece piada, mas é realidade. É como se alguém colocasse a chave de casa embaixo do tapete e ainda deixasse um bilhete avisando onde ela está.

É claro que nem toda informação exige um cofre digital com 12 camadas de proteção, assim como nem toda casa precisa de câmeras e cerca elétrica. Se você mora numa vila pacata na Suíça, provavelmente pode dormir com a janela aberta; mas se mora numa área de risco, é prudente reforçar a segurança. E na era digital, essa lógica vale para dados também. Estamos produzindo e acessando uma quantidade absurda de informação todos os dias – arquivos, fotos, mensagens, documentos – tudo isso via celular, computador, nuvem, entre outros.

Aliás, você sabia que a cada dois anos o volume de dados digitais no mundo dobra? Em 2025, a estimativa era de mais de 181 zettabytes de informação digital. E onde há muito dado circulando, há também muito



risco. É por isso que empresas gastam milhões em segurança da informação – elas sabem que informação é dinheiro. E não estamos falando só de grandes bancos ou governos. Uma simples padaria do bairro que usa um sistema de pedidos já tem dados importantes que merecem ser protegidos. Vejamos algumas notícias recentes:



Banco Central identifica vazamento de dados de usuários do Pix

Autoridade monetária informou que foram expostos dados de movimentação de recursos

De CPF a fotos: UFMS confirma que dados pessoais de alunos foram acessados por hackers em

Seus dados do Auxílio Brasil vazaram? Instituto abre consulta para checar; veja o passo a passo

Justiça determinou que Caixa Econômica Federal e União paguem R\$ 15 mil em indenização para cada um dos quase 4 milhões de beneficiários que podem ter sido atingidos. Decisão foi em 1ª instância, e cabe recurso.

pós-graduação receberam e-mails informando sobre o vazamento dos dados vazados foi divulgada pela Agência de Tecnologia da Informação (Agetic). Ao todo, a instituição tem mais de 26 mil acadêmicos

Ninguém está imune! E a verdade é que todos nós – pessoas, empresas e governos – precisamos repensar como lidamos com nossas informações no dia a dia. Então, vamos refletir: se você protege seu carro, sua casa e seu cofre... por que não proteger seus dados com a mesma seriedade? Dito isso, vamos ver na tabela seguinte também algumas definições de Segurança da Informação...

DEFINIÇÕES DE SEGURANÇA DA INFORMAÇÃO

Proteção de informações e de sistemas de informações contra acesso, uso, divulgação, interrupção, modificação ou destruição não autorizados.

Salvaguarda de dados organizacionais contra acesso não autorizado ou modificação para assegurar sua disponibilidade, confidencialidade e integridade.

Conjunto de estratégias para gerenciar processos, ferramentas e políticas necessárias para prevenir, detectar, documentar e combater ameaças às informações organizacionais.

O Decreto Nº 9.637 da Presidência da República, que institui a Política Nacional de Segurança da Informação (PNSI) nos órgãos e entidades da Administração Pública Federal busca:

“Assegurar a disponibilidade, integridade, a confidencialidade e a autenticidade da informação a nível nacional. Para os fins do disposto neste Decreto, a segurança da informação abrange: I – a segurança cibernética; II – a defesa cibernética; III – a segurança física e a proteção de dados organizacionais; e IV – as ações destinadas a assegurar a disponibilidade, a integridade, a confidencialidade e a autenticidade da informação”.

Já a literatura acadêmica afirma que existe uma trindade sagrada da segurança da informação. São três princípios (também chamados de propriedades ou atributos): **Confidencialidade**, **Integridade** e **Disponibilidade** – conhecidos pela sigla **CID**. Se um ou mais desses princípios forem desrespeitados em algum momento, significa que houve um incidente de segurança da informação (apesar de a figura ao lado apresentar uma pirâmide numerada, não existe hierarquia entre os princípios).





Vamos ver esses princípios em detalhes mais à frente, mas basicamente a **confidencialidade** é o princípio de que a informação não esteja disponível ou seja revelada a indivíduos, entidades ou processos não autorizados; a **integridade** é o princípio de salvaguarda da exatidão e completeza de ativos de informação; e a **disponibilidade** é o princípio da capacidade de estar acessível e utilizável quando demandada por uma entidade autorizada.



Controles de Segurança

INCIDÊNCIA EM PROVA: BAIXA

Quando o assunto é segurança da informação, um dos primeiros passos que qualquer organização deve dar é: avaliar seus riscos e, a partir daí, selecionar os controles mais adequados para proteger seus dados. Isso ajuda a reduzir os riscos a níveis aceitáveis, sem precisar investir à toa em ferramentas que talvez nem façam sentido para aquele contexto. Mas afinal, o que são esses controles de segurança?

São, basicamente, mecanismos que protegem as informações – e isso pode significar proteger sua confidencialidade, sua integridade ou sua disponibilidade (lembra da tríade da segurança?). Esses controles podem ser muito variados, mas costumam ser classificados em dois grandes tipos¹ apresentados na tabela seguinte:

TIPO DE CONTROLE	DESCRIÇÃO
CONTROLES FÍSICOS	São barreiras que impedem ou limitam o acesso físico direto às informações ou à infraestrutura que contém as informações. Ex: portas, trancas, paredes, blindagem, vigilantes, geradores, sistemas de câmeras, alarmes, catracas, cadeados, salas-cofre, alarmes de incêndio, crachás de identificação, entre outros.
CONTROLES LÓGICOS	Também chamados de controles técnicos, são barreiras que impedem ou limitam o acesso à informação por meio do monitoramento e controle de acesso a informações e a sistemas de computação. Ex: senhas, firewalls, listas de controle de acesso, criptografia, biometria ² , IDS, IPS, entre outros.

Um ponto muito importante (e que confunde muita gente): o tipo de controle depende do tipo de recurso que está sendo protegido e, não, do método de autenticação utilizado. Querem ver um exemplo? Se você usa biometria para entrar em uma sala, trata-se de um controle físico, porque o recurso é um espaço físico. Por outro lado, se você usa biometria para acessar um sistema, aí é um controle lógico, pois está acessando um ambiente digital. Em outras palavras, o mesmo método (biometria, por exemplo) pode atuar como controle físico ou lógico, dependendo do que está sendo protegido.

(CEBRASPE / TRT10 - 2013) Os mecanismos utilizados para a segurança da informação consistem em controles físicos e controles lógicos. Os controles físicos constituem barreiras de hardware, enquanto os lógicos são implementados por meio de softwares.

Comentários: o controle de acesso físico é uma barreira física, já o controle de acesso lógico é implementado por hardware ou software (Errado).

(CEBRASPE / TJDF - 2015) Na segurança da informação, controles físicos são soluções implementadas nos sistemas operacionais em uso nos computadores para garantir, além da disponibilidade das informações, a integridade e a confidencialidade destas.

Comentários: controles físicos referem-se a mecanismos como barreiras físicas, vigilância e controle de acesso ao ambiente. Já os controles implementados no sistema operacional são controles lógicos (Errado).

¹ Nunca vi em bibliografias consagradas, mas já encontrei em uma prova a cobrança de controles de segurança processuais, que tratam basicamente de... processos de segurança (Ex: troca de senha a cada 30 dias).

² A biometria é polêmica: há algumas classificações que a colocam como controle lógico e outras como físico ou lógico a depender do que ela se propõe a proteger.



Terminologia

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

Sabe-se que existe o **risco** de que um determinado **agente** se aproveite de **vulnerabilidades** para - por meio de **ataques** ou de **ameaças** - gerar um **incidente** que quebre a confidencialidade, integridade ou disponibilidade de um **ativo** de **informação** gerando graves **impactos** organizacionais. *Professor, não entendi nada!* Calma, galera! Vocês só não entenderam por que vocês ainda não sabem o significado da maioria dessas palavras.

Na Segurança da Informação, utiliza-se um jargão muito específico. Caso - no decorrer da aula - vocês tenham alguma dúvida, é só retornar aqui e descobrir o significado. Vejamos

TERMINOLOGIA	DESCRIÇÃO
ATIVO	Qualquer coisa que tenha valor para instituição, tais como: informações, pessoas, serviços, software, hardware, documentos físicos, entre outros.
INFORMAÇÃO	Ativo que, como qualquer outro ativo importante para os negócios, tem valor para a organização e, por isso, deve ser adequadamente protegido.
AGENTE	Fonte produtora de um evento que pode ter um efeito adverso sobre um ativo de informação, como um funcionário, meio ambiente, hacker, etc.
VULNERABILIDADE	Fragilidades presentes ou associadas a ativos que, quando exploradas por ameaças, levam à ocorrência de incidentes de segurança.
AMEAÇA	A ameaça é um agente externo que, se aproveitando das vulnerabilidades, poderá quebrar a confidencialidade, integridade ou disponibilidade da informação, causando um desastre ou perda significativa em um ambiente, sistema ou ativo de informação.
ATAQUE	Evento decorrente da exploração de uma vulnerabilidade por uma ameaça com o intuito de obter, alterar, destruir, remover, implantar ou revelar informações sem autorização de acesso.
EVENTO	Ocorrência identificada de um sistema, serviço ou rede, que indica uma possível violação da política de segurança da informação ou falha de controles, ou uma situação previamente desconhecida, que possa ser relevante para a Segurança da Informação.
INCIDENTE	Fato decorrente de um ataque bem-sucedido, com consequências negativas, uma ocorrência indicando uma violação, uma falha ou situação desconhecida, algo que possa ser relevante para a segurança da informação.
IMPACTO	Abrangência dos danos causados por um incidente de segurança sobre um ou mais processos de negócio.
RISCO	Probabilidade potencial da concretização de um evento que possa causar danos a um ou mais ativos da organização.

Eu percebo que é muito comum que os alunos tenham dúvidas sobre a diferença entre ameaça e risco. Vamos dirimi-las agora! A ameaça trata de um dano potencial, isto é, caso ocorra um incidente, poderá haver dano ou não. Já o risco trata de uma possibilidade de dano, isto é, avalia a probabilidade de um incidente ocorrer e o impacto potencial associado. Em geral, o risco está relacionado à probabilidade de uma ameaça se concretizar e explorar uma vulnerabilidade.

Agora vamos fazer uma analogia - grosso modo - para entender melhor como essa terminologia se aplicaria à vida cotidiana. Imagine que você passe no sonhado concurso público e compre um carro -



esse carro seria um ativo. Como o carro ainda está com o cheirinho de novo, você decide estacioná-lo mais longe a fim de evitar a ocorrência de qualquer acontecimento imprevisível – **isso seria um evento.**

Se esse acontecimento imprevisível fosse negativo, como alguém abrir a porta do carro ao lado com força e arranhar o seu carro, **isso seria incidente.** No entanto, esse lugar mais longe é mais perigoso e frequentemente carros são furtados por diversos assaltantes – **esses assaltantes seriam os agentes.** Como o carro foi comprado recentemente, você ainda não teve tempo de instalar um alarme – **isso seria uma vulnerabilidade.**

Dessa forma, você sabe que há chances de o carro ser furtado – isso seria um **risco.** Certo dia, quando você se aproxima do carro para voltar para casa, um meliante anuncia um assalto – **isso seria um risco,** visto que ele ainda não o assaltou efetivamente. Ele, então, rouba a sua chave e carteira, entra no veículo e sai cantando pneu – **isso seria um ataque.** O agressor some com o carro, leva para um desmanche e você fica sem o carro para todo sempre – **isso seria um impacto.**

(CEBRASPE / PEFUCE - 2012) As ameaças são fatores externos que podem gerar incidente de segurança da informação por intermédio da exploração das vulnerabilidades dos ativos de informação.

Comentários: ameaça é um agente externo que, se aproveitando das vulnerabilidades, poderá quebrar a confidencialidade, integridade ou disponibilidade da informação, causando um desastre ou perda significativa em um ambiente, sistema ou ativo de informação (Correto).



Princípios Fundamentais

Confidencialidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Confidencialidade é, basicamente, a capacidade de proteger uma informação contra acessos não autorizados. Em outras palavras, é garantir que apenas quem tem permissão possa ver ou acessar determinados dados – sejam eles pessoas, sistemas, dispositivos ou processos. Você pode pensar nela como uma espécie de privacidade controlada: quem tem permissão, acessa; quem não tem, não vê – e ponto final. E isso é algo muito mais presente no nosso cotidiano do que parece...

Imagina o seguinte: você escreve uma carta para alguém e a coloca num envelope selado. O carteiro pode até pegar a carta, levá-la para lá e para cá... mas ele não deve abrir o envelope. Se ele rompe o lacre e lê o conteúdo, pronto – a confidencialidade foi violada. Por quê? Porque alguém que não tinha autorização acabou acessando informações que deveriam ser privadas. E esse mesmo raciocínio vale para e-mails, arquivos, fotos, senhas, relatórios... qualquer tipo de dado sensível que precise de proteção.

Importante: a confidencialidade precisa ser garantida em toda a jornada da informação: quando ela é criada; enquanto está sendo transmitida (por rede, por exemplo); e quando está armazenada ou mesmo sendo descartada. Inclusive, quando uma informação for apagada, isso precisa ser feito de modo seguro – para que ninguém consiga recuperá-la depois.

Um alerta: confidencialidade não é a mesma coisa que confiabilidade! A Confiabilidade diz respeito à resistência do sistema a falhas e à sua capacidade de funcionar corretamente ao longo do tempo.

(FCC / TCE-RS - 2014) José utilizou uma ferramenta para criptografar uma informação a ser transmitida para Maria, com o objetivo de proteger a informação contra acesso não autorizado. O requisito básico de segurança da informação assegurado pela criptografia é a:

- a) irretratabilidade.
- b) autenticidade.
- c) confidencialidade.
- d) disponibilidade.
- e) confiabilidade.

Comentários: (a) Errado. Irretratabilidade (ou não repúdio) está relacionada à impossibilidade de negar a autoria de uma ação, geralmente assegurada por assinaturas digitais, não pela criptografia em si; (b) Errado. Autenticidade garante que a informação venha de uma fonte confiável, mas a criptografia por si só não assegura isso – são necessários mecanismos adicionais, como certificados digitais; (c) Correto. A criptografia protege os dados contra acesso não autorizado, assegurando que apenas partes autorizadas possam acessar o conteúdo, garantindo assim a confidencialidade; (d) Errado. Disponibilidade refere-se à garantia de que a informação estará acessível quando necessário, algo que não é assegurado diretamente pela criptografia; (e) Errado. Confiabilidade não é um dos requisitos clássicos da segurança da informação; os principais são confidencialidade, integridade, disponibilidade, autenticidade e não repúdio (Letra C).



Integridade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Integridade é a capacidade de garantir que a informação manipulada está correta, fidedigna e que não foi corrompida. Esse princípio geralmente trata da salvaguarda da exatidão e completeza da informação, com o intuito de aferir que a informação não tenha sido alterada sem autorização durante seu percurso, de sua origem ao seu destino, mantendo todas as características originais estabelecidas pelo proprietário da informação.

Em outras palavras, esse princípio sinaliza a conformidade dos dados armazenados com relação às inserções, alterações e processamentos autorizados efetuados. Sinaliza, ainda, a conformidade dos dados transmitidos pelo emissor com os recebidos pelo destinatário, garantindo a não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital.

No exemplo anterior, se a carta que eu enviei chegou ao destinatário exatamente da forma que eu a enviei, ou seja, lacrada, correta, fidedigna, precisa, original, impecável, sem nenhuma manipulação, então mantivemos o princípio da integridade da informação. É por essa razão que empresas de e-commerce pedem que os clientes não aceitem produtos que estejam com a embalagem danificada ou sem lacre – porque ela pode ter sido manipulada por terceiros.

Percebam também que confidencialidade e integridade são princípios independentes, isto é, a quebra de um princípio não implica a quebra do outro. Por exemplo: o carteiro pode interceptar minha carta, colocá-la contra uma luz forte e eventualmente conseguir visualizar a minha mensagem sem a minha autorização – quebrando o princípio da confidencialidade. No entanto, ele não terá quebrado o princípio da integridade, visto que minha carta será entregue inalterada.

(VUNESP / TJ-SP - 2014) Assinale a alternativa que apresenta corretamente a característica do requisito básico de segurança, conhecido como integridade.

- a) Verificar se uma entidade é realmente quem ela diz ser.
- b) Determinar as ações que uma entidade pode executar.
- c) Proteger uma informação contra acesso não autorizado.
- d) Proteger a informação contra alteração não autorizada.

Comentários: (a) Errado. Verificar a identidade de uma entidade está relacionado ao requisito de autenticidade, e não à integridade; (b) Errado. Determinar as ações que uma entidade pode executar refere-se ao controle de acesso, que não é o foco a integridade; (c) Errado. Proteger uma informação contra acesso não autorizado é um exemplo clássico do requisito de confidencialidade; (d) Correto. A integridade assegura que a informação não seja alterada de forma não autorizada, garantindo que os dados permaneçam íntegros e confiáveis (Letra D).



Disponibilidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

A disponibilidade é um dos pilares da segurança da informação e trata de algo simples, mas essencial: garantir que a informação esteja acessível e utilizável sempre que for necessário – por quem tem permissão, é claro. Em outras palavras, não basta a informação existir; ela precisa estar funcionando e acessível na hora certa. Imagine que você tem todos os dados do mundo salvos em um servidor, mas o servidor está fora do ar. De que adianta?

Um exemplo bem cotidiano (e frustrante): você precisa fazer uma transferência urgente, entra no app do seu banco e... nada funciona. O sistema está fora do ar! Você tenta de novo, e de novo... e nada. Isso já aconteceu comigo uma vez (com um banco que prefiro nem comentar, mas vai aparecer um boleto dele mais à frente nessa aula), e a situação me irritou tanto que acabei mudando de banco no dia seguinte.

Agora imagina isso em escala: quando um sistema bancário fica indisponível, as perdas podem ser milionárias – ou até bilionárias, dependendo do tempo em que o sistema ficou fora do ar. Por isso, as instituições investem pesado para garantir continuidade, robustez e alta disponibilidade. E como se faz isso? Com uma série de recursos e práticas, como: backups atualizados, redundância de servidores, fontes de energia ininterrupta, firewalls e sistemas de proteção para evitar que ataques causem interrupções e monitoramento constante para detectar e reagir a falhas antes que virem crises.

Saiba mais:

Há uma pegadinha clássica que trata da diferença entre Confidencialidade e Disponibilidade. A Confidencialidade garante que a informação somente esteja acessível para usuários autorizados. Já a Disponibilidade garante que a informação esteja disponível aos usuários autorizados sempre que necessário (notem que existem dois requisitos).

(CEBRASPE / CGM-PB - 2018) A disponibilidade pressupõe que uma informação deva estar disponível a qualquer pessoa de direito, sempre que necessário.

Comentários: essa é a premissa da disponibilidade, isto é, informação disponível sempre que necessário aos usuários autorizados (Correto).

(CEBRASPE / SERPRO - 2013) Um ataque à infraestrutura de conectividade de um banco à Internet, interrompendo o acesso a seus serviços de home banking, afeta a disponibilidade.

Comentários: ataques que interrompem o acesso aos serviços, como os de negação de serviço (DoS), comprometem a disponibilidade, impedindo que usuários autorizados acessem os sistemas (Correto).



Princípios Adicionais

Quando falamos sobre os princípios da segurança da informação, a maioria dos livros e especialistas se baseia naquela tríade clássica: Confidencialidade, Integridade e Disponibilidade (CID). Esses três pilares são, de fato, os mais recorrentes e considerados fundamentais para qualquer estratégia de proteção de dados. Mas... nem todo mundo para por aí. Alguns autores vão além e incluem outros dois princípios que também são extremamente relevantes: Autenticidade e Irretratabilidade (ou Não-Repúdio).

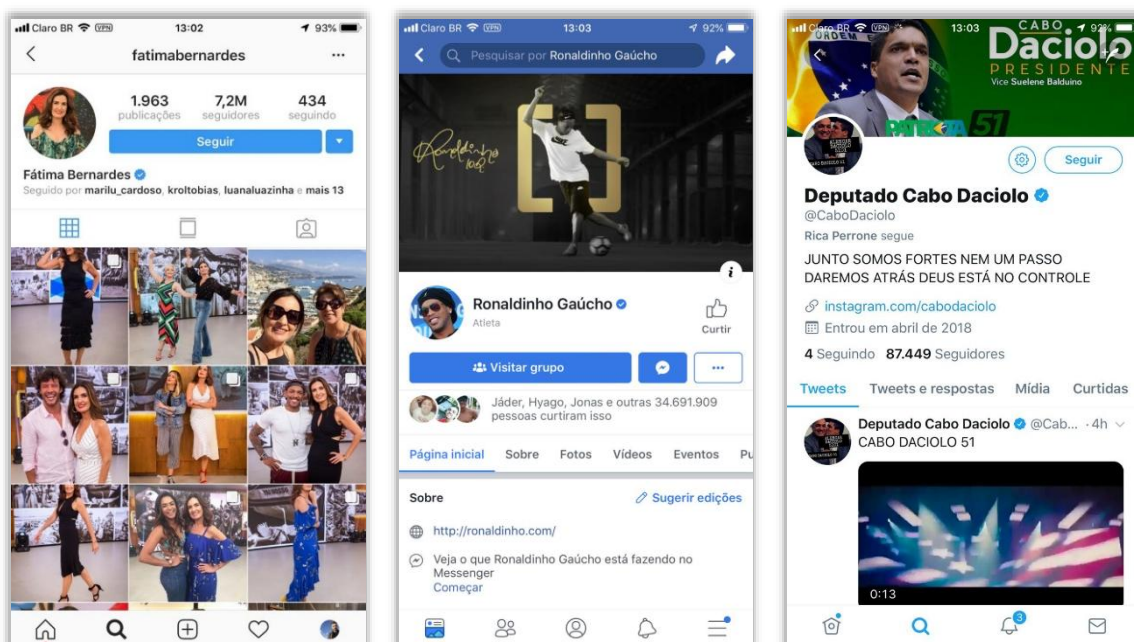
Esses dois princípios são cada vez mais valorizados, especialmente no contexto de assinaturas digitais, certificados eletrônicos e transações online – onde a identidade e a responsabilidade de quem envia a informação precisam estar muito bem amarradas. Existe ainda uma abordagem mais ampla – e bem menos conhecida – proposta por Donn B. Parker, um dos pioneiros no campo da segurança da informação. Ele sugeriu um modelo chamado Hexagrama Parkeriano, que amplia os princípios para seis atributos. Além da Confidencialidade, Integridade, Disponibilidade e Autenticidade, ele define:

- **Posse ou Controle:** refere-se a quem realmente detém a informação, independentemente de quem a criou. Por exemplo, um celular roubado com dados sigilosos: o dono perde o controle da informação, mesmo que ela continue intacta.
- **Utilidade:** refere-se à capacidade da informação de ser útil para quem a utiliza. Em outras palavras, de nada adianta a informação estar correta e protegida, se estiver em um formato ilegível ou inacessível.

Autenticidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

A autenticidade é a propriedade que trata da garantia de que o emissor de uma mensagem é de fato quem alega ser. Em outras palavras, ela garante a identidade de quem está enviando uma determinada informação. *Sabe quando você assina um contrato?* A sua assinatura é uma forma (frágil) de garantir que você é quem diz ser! O cartório tem a sua assinatura (chamada firma) e ele pode comparar com a assinatura que consta no contrato.



Eu sei replicar a assinatura do meu pai impecavelmente. Logo, eu poderia quebrar essa garantia da autenticidade porque se trata de um método frágil, mas existem outras maneiras de melhorar essa garantia de autenticidade. De toda forma, a autenticidade busca garantir que a pessoa que está requisitando acesso a alguma informação é realmente quem ela diz ser. Hoje em dia é muito fácil se passar por outro em redes sociais. Nada impediria que eu criasse um Instagram como **@fatima_bernardes**, um Facebook como **@ronaldinho_gaucho_10** ou um Twitter como **@cabo_daciolo_51**.

No entanto, as redes sociais criaram a verificação de conta (representado pelo ícone ). *O que é isso, professor?* Esse é um recurso criado inicialmente para figuras públicas, celebridades, cantores, artistas, entre outro para evitar que outras pessoas se passem por elas. Observem nas três redes sociais acima que existe o ícone que mostra que essa conta é autêntica, isto é, ela é realmente de quem diz ser.

Alguém sempre poderá dizer: *professor, não é possível garantir isso, porque o celular do dono da conta pode ter sido roubado, por exemplo*. É verdade, absolutamente nenhum sistema é totalmente seguro. No entanto, quando dissemos que isso garante autenticidade, nós assumimos que não ocorreu nenhum incidente e que o dono utiliza uma autenticação forte em suas redes. Em segurança da informação, é comum utilizar o verbo garantir sem problema. Caiu poucas vezes em prova, mas é bom enfatizar que existem dois tipos de autenticação:

- **Autenticação de Origem dos Dados:** pode ocorrer sem conexão e busca garantir que a origem dos dados recebidos é realmente de quem diz ser.
- **Autenticação de Entidade Par:** ocorre com conexão e busca garantir a confiabilidade da identidade das entidades conectadas.

(FCC / TRF4 - 2014) A segurança da informação objetiva a proteção de ativos da informação contra acessos não autorizados, alterações indevidas, sendo considerada uma prática de gestão de riscos incidentes que impliquem o comprometimento de seus requisitos e conceitos básicos. Dentro desta análise conceitual, a garantia de que as entidades identificadas em um processo de comunicação como remetentes ou autores sejam, exatamente, os mencionados nela, pode ser conceituada como:

- a) severidade.
- b) confidencialidade.
- c) disponibilidade.
- d) criticidade.
- e) autenticidade.

Comentários: (a) Errado. Severidade não é um requisito básico da segurança da informação, mas um termo usado na avaliação do impacto de incidentes; (b) Errado. Confidencialidade refere-se à proteção contra acesso não autorizado, não à verificação da identidade do remetente; (c) Errado. Disponibilidade está relacionada ao acesso contínuo e oportuno às informações, não à verificação de identidade; (d) Errado. Criticidade também não é um requisito básico, mas sim uma medida do quanto um ativo é essencial para o negócio; (e) Correto. Autenticidade assegura que a identidade do remetente ou autor da informação é verdadeira e corresponde à informada no processo de comunicação (Letra E).

(CEBRASPE / Prefeitura de Vitória - 2010) Autenticar é confirmar a identidade de uma entidade visando, por exemplo, garantir que a entidade é quem ela diz ser. As técnicas para autenticação podem basear-se na verificação de informações como, por exemplo, senhas.

Comentários: autenticar é realmente confirmar a identidade de uma entidade, isto é, garantir que ela é legítima – uma senha é realmente uma forma de verificação de autenticidade, visto que – em tese – apenas o proprietário conhece a senha (Correto).



Irretratabilidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Também chamada de Irrefutabilidade ou Não-repúdio, o princípio da irretratabilidade trata da capacidade de garantir que o emissor da mensagem ou participante de um processo não negue posteriormente a sua autoria. No Direito, o não-repúdio implica a intenção de cumprir as obrigações de um contrato. Implica também que uma parte de uma transação não possa negar ter recebido uma transação, nem a outra parte pode negar ter enviado uma transação.

É importante notar que, embora a tecnologia – como os sistemas criptográficos – possa ajudar nos esforços de não-repúdio, o conceito é, em sua essência, um conceito legal que transcende o domínio da tecnologia. *Como assim, professor?* Lembrem-se do exemplo anterior! Alguém sempre pode falar que teve o celular roubado ou que quem fez a postagem foi um estagiário ou que o algoritmo do sistema está com algum erro.



No entanto, é possível utilizar uma autenticação forte, o que aumenta consideravelmente a confiança de que quem enviou a mensagem foi realmente quem parece ser. Dessa forma, alguém dificilmente conseguiria negar sua autoria. Em 2015, o Twitter Oficial do STJ publicou o tweet ao lado e o apagou minutos depois. O órgão dificilmente conseguiria negar sua autoria, visto que – como possui uma conta verificada – necessita de autenticação forte.

Professor, autenticidade e irretratabilidade são a mesma coisa? Não, são conceitos distintos! Se você me envia uma carta com a sua assinatura no papel, eu sei que você é autor da carta (Autenticidade), mas você ainda pode negar que escreveu aquele conteúdo porque – apesar de ter a sua assinatura – alguém pode ter capturado a carta no meio do caminho e alterado o conteúdo mensagem deixando apenas a assinatura ao final.

Por meio da Irretratabilidade, inserimos um mecanismo de integridade que garante que a carta está íntegra, isto é, foi recebida exatamente da maneira que foi enviada. Nesse caso, quando garantimos a autenticidade (assinatura) e a integridade (mensagem sem modificações), nós garantimos automaticamente a irretratabilidade – também chamada de não repúdio, porque o autor não pode repudiar sua autoria, isto é, não pode se esquivar de ter enviado aquela mensagem.

AUTENTICIDADE + INTEGRIDADE = IRRETRATABILIDADE

(CEBRASPE / TCE-PA - 2016) O princípio de não repúdio impede que o autor de um documento negue a criação e a assinatura desse documento.

Comentários: o princípio de não repúdio garante que uma ação ou transação não possa ser negada por seu autor, sendo frequentemente implementado por meio de assinaturas digitais. (Correto).

Há uma propriedade/mecanismo de segurança chamada Rastreabilidade (ou Auditoria). Não se trata de um dos princípios clássicos de segurança, mas é importante entendê-lo. Trata-se da capacidade de um sistema de registrar, acompanhar e reconstruir todas as ações realizadas sobre dados e recursos, permitindo identificar quem fez o quê, quando, onde e como. Isso é feito por meio de logs de auditoria, que armazenam eventos como acessos, alterações, exclusões, tentativas de falha e operações administrativas.



Na prática, a rastreabilidade garante visibilidade e controle sobre o uso do sistema. Por exemplo, em um banco de dados, é possível verificar qual usuário consultou uma informação sensível, quem alterou um registro ou se houve tentativa de acesso indevido. Esses registros são fundamentais para investigações, conformidade legal, detecção de fraudes e análise de incidentes de segurança.

Para que a auditoria seja confiável, os logs devem possuir algumas características essenciais: integridade (não podem ser alterados sem detecção), imutabilidade (preferencialmente append-only), sincronização de tempo (para manter a ordem correta dos eventos) e armazenamento seguro, muitas vezes em ambiente separado do sistema principal. Técnicas como assinatura digital e controle rigoroso de acesso reforçam essa proteção.

A integridade dos logs de auditoria exige que os registros não possam ser alterados ou apagados sem deixar vestígios. Para isso, utiliza-se o conceito de trilhas de auditoria imutáveis (append-only), em que novos eventos são apenas adicionados, nunca modificados ou removidos. Além disso, técnicas como assinatura digital garantem que qualquer alteração posterior seja detectável, assegurando autenticidade e integridade. A sincronização de horário (por exemplo, via NTP confiável) também é essencial para manter a consistência temporal dos eventos.

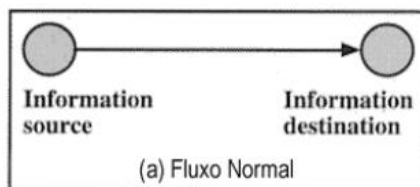
Outro ponto fundamental é a segregação de funções e de ambientes. Logs de auditoria não devem ficar na mesma estrutura de dados das tabelas de negócio, pois isso facilita adulterações e compromete a rastreabilidade. O ideal é armazená-los em um repositório separado, com controles de acesso mais restritivos, muitas vezes em sistemas especializados de auditoria ou SIEM. Isso impede que usuários com privilégios operacionais alterem ou excluam registros para encobrir ações indevidas.

A rastreabilidade forte também implica retenção adequada dos dados de auditoria. A exclusão de logs antigos para liberar espaço, embora comum em ambientes de baixa criticidade, compromete investigações e auditorias forenses. Em sistemas sensíveis, adota-se política de retenção segura, com arquivamento controlado, e não simples deleção. O foco é preservar a cadeia de evidências, mesmo que isso exija soluções de armazenamento escaláveis.

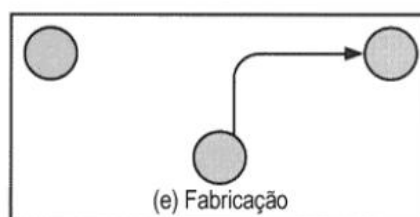
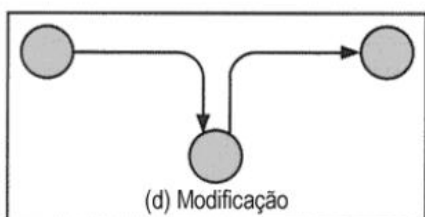
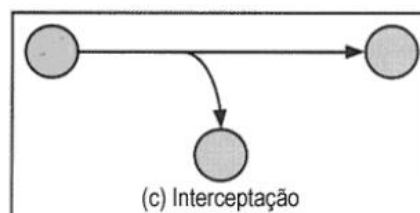
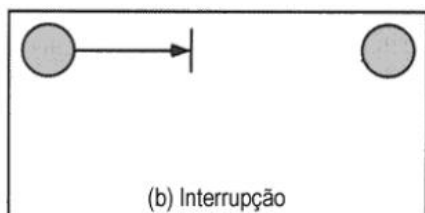


Desafio

Considerem o cenário normal de fluxo de informação abaixo em que uma fonte da informação envia dados para um destinatário da informação. Em seguida, vamos analisar os quatro cenários acima:



- **(b) Interrupção:** a informação que deveria sair da fonte e chegar ao destinatário foi interrompida no meio do caminho e não chegou ao seu destino final;
- **(c) Interceptação:** a informação que sai da fonte chegou ao destinatário, mas foi interceptada por alguém não autorizado no meio do caminho que teve acesso ao seu conteúdo;
- **(d) Modificação:** a informação que saiu da fonte foi recebida por um terceiro (que não necessariamente a leu) e posteriormente enviada ao destinatário com alterações;
- **(e) Fabricação:** a informação não foi enviada pela fonte e, sim, por um terceiro se fazendo parecer ter sido a fonte e enviada ao destinatário.



Quais serviços de segurança da informação foram violados por meio dos quatro ataques apresentados acima? A resposta eu vou deixar no rodapé³!

³ (b) Disponibilidade; (c) Confidencialidade; (d) Integridade; (e) Autenticidade.

CRIPTOLOGIA

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

A informação sempre foi objeto de poder, portanto é comum a criação de técnicas para obter informações de modo não autorizado e, ao contrário, acaba sendo necessário o surgimento de mecanismos de defesa visando proteger as informações. Basicamente a Criptologia se ocupa da ocultação de informações e da quebra dos segredos de ocultação. A primeira pode ser alcançada por Esteganografia ou Criptografia, e a segunda pode ser alcançada por Criptoanálise.

A criptografia possui dois grandes grupos: códigos e cifras. Os códigos são palavras, frases, letras, símbolos usados para substituir elementos do texto claro. As cifras, por sua vez, são algoritmos de criptografia e descryptografia de mensagens. Elas se caracterizam por dois tipos básicos de transformação: transposição e substituição. Vejam abaixo como esses conceitos são dispostos um em relação ao outro.

CRIPTOLOGIA



(CEBRASPE / STF - 2013) A criptologia incorpora estudos e conhecimentos das áreas de criptografia e criptoanálise.

Comentários: criptologia é o campo que abrange tanto a criptografia (proteção da informação) quanto a criptoanálise (estudo da quebra de sistemas criptográficos) (Correto).

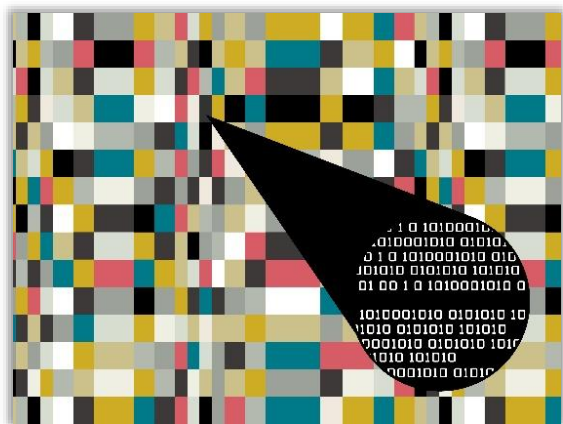


Esteganografia

INCIDÊNCIA EM PROVA: BAIXA

Trata-se de uma técnica utilizada para esconder informações. Seu objetivo é que as informações sejam transmitidas de forma invisível, sem que possam ser capturadas ou monitoradas. *Quem aí tem filhos?* Vocês podem fazer um experimento legal com eles: escrevam uma carta secreta com suco de limão! Vocês precisarão de uma folha de papel em branco, um cotonete, um ferro de passar roupa e um copinho com limão espremido.

Molhem a ponta do cotonete no suco de limão, escrevam alguma coisa no papel em branco e deixem secar naturalmente. Vocês perceberão que a folha continuará em branco e não será possível visualizar a mensagem escrita. Após um tempo, peguem o ferro de passar roupa e passem o papel. A mensagem escrita com o limão de forma invisível aparecerá no papel! Esse é um exemplo bem simples de esteganografia. Vou compartilhar uma experiência pessoal com vocês! Certa vez, em uma viagem ao Deserto do Saara, fui em um povoado berbere onde um artista fazia pinturas com pigmentos de água com açúcar. Inicialmente, não era possível ver nenhuma definição do que ele estava desenhando. Até que ele passou o papel em um maçarico de gás propano e de repente apareceu essa imagem ao lado! *Legal, né?* O guia nos contou que, há trezentos anos atrás, essa era uma forma de enviar mensagens de forma invisível entre as famílias. Depois de um tempo, tornou-se uma forma de arte chamada Piroaquarela ou Aquarela de Fogo. Já na era moderna, a esteganografia aparece como uma técnica para ocultar uma mensagem dentro de outra, de forma que não sejam percebidas por terceiros. Em geral, escondem-se mensagens dentro de imagens, sons, vídeos ou textos.



Professor, como é possível esconder uma mensagem em uma imagem? Não vamos entrar em muitos detalhes sobre o funcionamento, mas basicamente uma imagem é um conjunto pixels codificados em milhões e milhões de bits.

Por exemplo: 01101010000101110101011101101000) - como mostra a imagem ao lado.

Se eu modificar apenas alguns desses bits para guardar uma mensagem secreta, não vai fazer muita diferença para você porque a mudança será basicamente imperceptível para o olho humano.

Alguém consegue notar alguma diferença entre a imagem da esquerda e a imagem da direita abaixo? Pois é, a imagem da direita está esteganografada, isto é, há uma mensagem escondida dentro dela. Se a pessoa que vai receber a mensagem sabe disso e sabe como decifrá-la, ela conseguirá ver a mensagem escondida na imagem. Caso contrário, uma pessoa desavisada só vai achar que é uma foto de um panda. E isso pode ser feito com vários tipos de arquivos.





Saiba mais:

Curiosidade: transcrevo a seguir uma reportagem da Folha de São Paulo, de 10 de março de 2008. Vejam que legal :)



Você nunca mais verá a Hello Kitty com olhos inocentes. A culpa é do traficante colombiano Juan Carlos Ramírez Abadía. Quando foi preso em São Paulo, em agosto do ano passado, os delegados da Polícia Federal ficaram intrigados com a quantidade de imagens da gatinha japonesa que ele guardava nos computadores. Eram quase 200 imagens, quase todas enviadas por e-mail.

A surpresa maior foi a descoberta de que a Hello Kitty não era só uma Hello Kitty. Havia mensagens de voz e de texto escondidas nas imagens. Algumas delas podem mudar o destino de Abadía no Brasil: elas contêm ordens para movimentar cocaína entre países e para sumir com pessoas na Colômbia, segundo análise feita pelo DEA, a agência antidrogas dos EUA. Para os americanos, Abadía continuou a comandar o tráfico na Colômbia mesmo após se mudar para o Brasil.

A mulher de Abadía, Yessica, é fanática por Hello Kitty. Um dos quartos da casa em que ela vivia em Aldeia da Serra (Grande SP) tinha cadeiras, relógios e papel de parede da Hello Kitty. O DEA ajudou a PF porque o Brasil não teria toda a tecnologia necessária para fazer a investigação. A técnica de computação usada para esconder uma mensagem de voz em uma imagem é conhecida como esteganografia.

A Al Qaeda utilizou essa técnica para preparar os atentados de 2001. Hello Kitty não era o único disfarce para as ordens de Abadía. Algumas mensagens continham fotos de crianças (...)

<https://www1.folha.uol.com.br/fsp/cotidian/ff1003200801.htm>

(CCV-UFC / UFC - 2013) Sobre Esteganografia é correto afirmar que:

- a) É uma categoria de algoritmo criptográfico simétrico.
- b) É a análise de desempenho dos algoritmos criptográficos.
- c) É uma técnica para ocultar uma mensagem dentro de outra.
- d) É um algoritmo matemático capaz de obter a mensagem original a partir do seu código hash.
- e) É uma técnica para decifrar o texto cifrado sem qualquer conhecimento da mensagem original e do algoritmo criptográfico utilizado.

Comentários: (a) Errado. Esteganografia não é um algoritmo criptográfico simétrico; ela não criptografa, mas oculta informações; (b) Errado. A análise de desempenho de algoritmos criptográficos é mais associada à criptoanálise ou à engenharia de desempenho, não à esteganografia; (c) Correto. A esteganografia é a técnica de ocultar uma mensagem dentro de outra, como esconder texto em uma imagem ou áudio, de modo que a existência da mensagem passe despercebida; (d) Errado. Um código hash é irreversível; não é possível obter a mensagem original a partir dele. Esteganografia também não tem relação com hash; (e) Errado. Essa definição se refere à criptoanálise, não à esteganografia (Letra C).

(FUNIVERSA / PC-DF - 2012) Esteganografia é um termo pouco utilizado no âmbito da segurança da informação, mas que exige cuidados especiais de quem se preocupa com o tema. Assinale a alternativa que apresenta a definição de esteganografia.

- a) Técnica de esconder informações dentro de arquivos como imagens, sons, vídeos ou textos.
- b) Sinônimo de criptografia, é técnica de codificar a informação para que não seja entendida por terceiros.
- c) Algoritmo matemático que converte um texto claro em uma mensagem cifrada, e vice-versa.
- d) Estudo de técnicas de quebra de sigilo de mensagens eletrônicas criptografadas.
- e) Método para codificação de arquivos binários, transformando-os em texto ASCII.

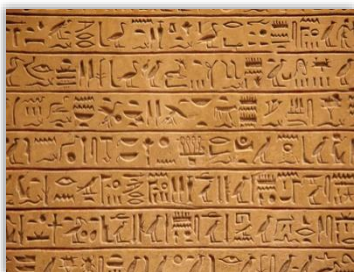
Comentários: (a) Correto. Esteganografia é a técnica de ocultar informações dentro de outros arquivos, como imagens, sons ou vídeos, de modo que a existência da mensagem passe despercebida; (b) Errado. Criptografia e esteganografia são distintas: a criptografia transforma o conteúdo para torná-lo ilegível, enquanto a esteganografia oculta sua existência; (c) Errado. Essa é a definição de um algoritmo criptográfico, não de esteganografia; (d) Errado. O estudo da quebra de sigilo de mensagens criptografadas é chamado de criptoanálise; (e) Errado. Transformar arquivos binários em texto ASCII é uma técnica como o Base64, que não se relaciona com esteganografia (Letra A).



Criptografia e Criptoanálise

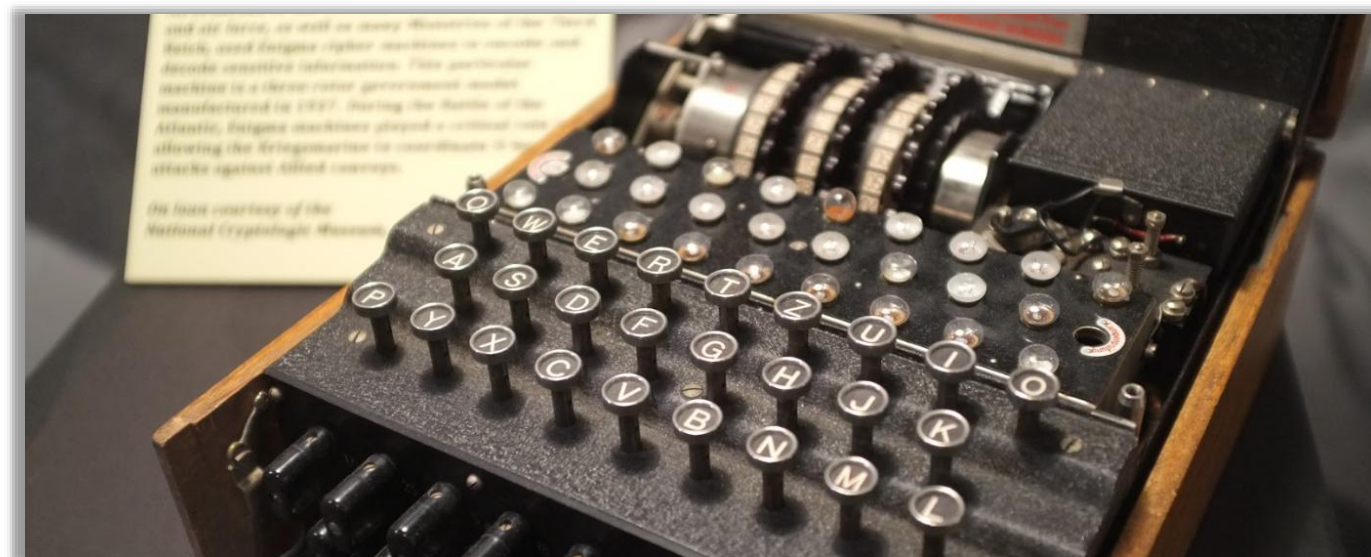
Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA



A Criptografia é a técnica de tornar uma mensagem ininteligível! Ela remonta ao Egito por volta de 1.900 A.C., quando um escriba esculpiu alguns símbolos hieroglíficos em uma rocha no túmulo do chefe egípcio Khnumhotep II. A criptografia não era tão difícil naquela época, já que a maioria das pessoas era analfabeta e só a elite podia ler qualquer linguagem escrita. Desde essa época, faraós, reis, imperadores, presidentes, ditadores e comandantes militares usaram a criptografia para esconder comunicações de seus inimigos.

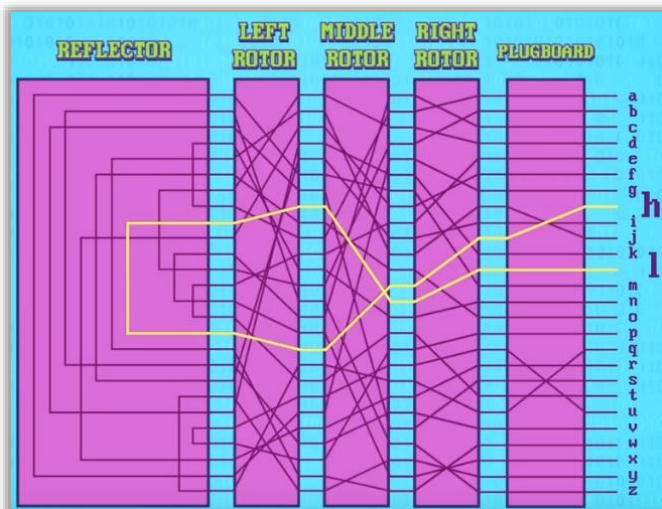
Um exemplo é Maria, Rainha dos Escoceses! Em 1577, ela queria assassinar a Rainha Elizabeth I e - para tal - começou a trocar mensagens com seus companheiros de conluio. Para que ninguém desconfiasse caso as mensagens acabassem em mãos erradas, eles as criptografavam! Eles utilizaram uma cifra de substituição, em que você substitui umas letras por outras ou palavras comuns por símbolos. As mensagens de Maria foram capturadas pelos espiões da Rainha Elizabeth I, decifradas e Maria foi imediatamente presa, julgada e condenada por traição. A pena foi morte por decapitação na guilhotina. Essa é apenas uma historinha para contextualizar sobre a importância da criptologia no decorrer da história da humanidade. *Bacana? :)*



Falando agora de tempos mais modernos, essa máquina acima é chamada Enigma II. Ela é uma máquina eletromecânica de criptografia utilizada pelos nazistas durante a Segunda Guerra Mundial. Quem assistiu ao filme O Jogo da Imitação (The Imitation Game), que conta a história de Allan Turing - o pai da computação -, deve conhecê-la. Se não assistiram ainda, assistam! É um filme! #ficadica :)



A Enigma era poderosa e complexa por possuir três rotores – como mostrado na imagem ao lado – para bagunçar as letras digitadas e dificultar a decifragem das mensagens. O **H** digitado se tornava um **J**, que se tornava um **M**, que se tornava um **Q**, que se tornava um **P**, que passava por um refletor e se tornava um **I**, que se tornava um **H**, que se tornava um **N**, que finalmente se tornava um **L** na mensagem criptografada. Além disso, você poderia configurar a máquina de diversas maneiras, dificultando a decifragem para quem interceptasse. Ela era utilizada para troca de mensagens entre os generais nazistas. Foi quando o matemático britânico Allan Turing criou uma máquina chamada *Bombe* capaz de traduzir textos encriptados pelos alemães e decifrando diversas mensagens que continham informações de planos e estratégias de guerra. Dessa forma, considera-se que a máquina de criptoanálise de Allan Turing ajudou a encerrar a guerra mais cedo, porque vários ataques alemães foram evitados.



Técnicas de Criptografia

Atualmente são empregadas técnicas de criptografias simétricas, assimétricas e híbridas. Essas técnicas empregam dois fundamentos principais: substituição, em que cada elemento no texto claro é mapeado para outro elemento; e transposição, em que os elementos no texto claro original são reorganizados. O requisito essencial de ambos é que nenhuma informação seja perdida! Vejamos em detalhes...

Criptografia Simétrica⁴

INCIDÊNCIA EM PROVA: ALTÍSSIMA



A Criptografia Simétrica implica o uso de uma chave secreta utilizada tanto para codificar quanto para decodificar informações. Um dos precursores da criptografia simétrica foi o imperador romano Júlio César, que implementou uma técnica que codificava a mensagem a ser enviada, substituindo cada caractere do texto por um caractere três posições à frente em relação ao alfabeto, conforme a imagem ao lado. Observem que A corresponde a D, D corresponde a G, G corresponde a J, e assim por diante.

D Culswrjudild Slphwulfd Ipsoldf r xvr gh xpd fkdylh vhfuhwd xwlolcdgd wdqwr sdud frglilfdu txdqwr sdud ghfrglilfdu lqirupdfrhv. Up grv suhfxuvruhv gd fulswrjudild vlphwulfd irl r lpshudgru urpdqr Jxolr Chvdu, txh Ipsohphqwr xpd whqlfdu txh frglilfdyd d phqvdihp d vhu hqylldgd, vxevwlwxlqgr fdgd fdudfwhuh gr whawr sru xp fdudfwhuh wuhv srlvrhv d iuhqwh hp uhodfdr dr doidehwr, frqiruph d lpdjhp dr odgr. Oevhuyhp txh A fruhvsrqgh d D, D fruhvsrqgh d G, G fruhvsrqgh d J, h dvlp sru gldqwh.



O segundo parágrafo é exatamente o primeiro parágrafo, porém cifrado com a técnica do Imperador Júlio César. *Bacana, né?* Quem quiser brincar, acesse o site abaixo:

[HTTPS://CRYPTII.COM/PIPES/CAESAR-CIPHER](https://cryptii.com/pipes/caesar-cipher)

Se uma pessoa interceptar a mensagem do segundo parágrafo, não conseguirá decifrar a mensagem. No entanto, se ela souber qual é a chave de encriptação, facilmente ela conseguirá decodificar a mensagem. *E o que seria essa chave de encriptação?* É uma informação que controla a operação de um algoritmo de criptografia – na criptografia simétrica, ela é utilizada tanto para codificar quanto para decodificar a mensagem. No caso acima, a chave de Júlio César é 3! *Por quê?* Porque o caractere verdadeiro e o caractere codificado diferem em três posições.

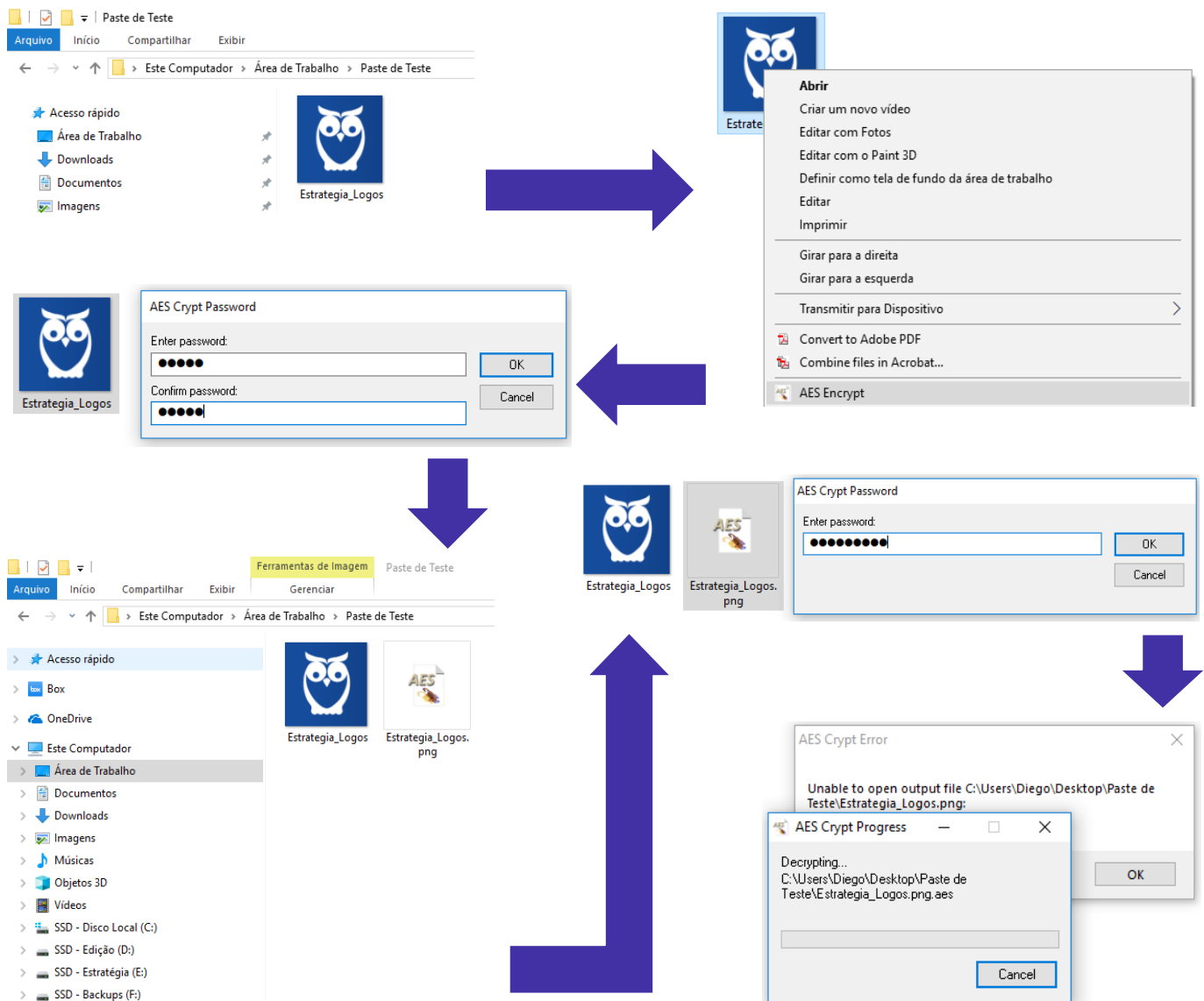
Bacana! Nós entendemos a criptografia simétrica de uma maneira simplificada. Vamos ver agora como isso se aplicaria aos tempos atuais. Vamos supor que Maria precise enviar um documento sensível para João. Ela faz uso de um software de encriptação para proteger seu documento e, para tal, utiliza uma senha ou chave. Ela então envia o documento criptografado para João! *João vai conseguir abrir o documento?* Não, porque ele não sabe a senha! *E agora?*

Maria teria que entregar ou falar pessoalmente qual é a senha para João, mas isso poderia ser um grande inconveniente. Ela poderia enviá-la por e-mail, mas seria arriscado, visto que alguém poderia interceptá-la e utilizá-la para descriptografar o documento sensível. Percebam, então, que essa é uma boa solução para casos mais simples, mas há riscos e inconvenientes. Quem quiser brincar com esse tipo de criptografia ou precisar esconder algum arquivo, eu recomendo:

⁴ Também chamado de Algoritmo de Chave Secreta, Chave Única, Chave Compartilhada, Chave Privada ou Criptografia Convencional.



[HTTPS://WWW.AESCRYPT.COM](https://www.aescrypt.com)



Na primeira figura, eu tenho uma imagem do logo do Estratégia. Na segunda figura, eu cliço com o botão direito para utilizar o programa AES Encrypt. Na terceira figura, o programa pede para que eu insira uma senha ou chave - eu utilizo '**12345**'. Na quarta figura, é criado o arquivo criptografado da imagem. Na quinta figura, eu tento abrir a foto e o programa pede a senha - eu insiro '**123456789**'. Na última figura, é negada a abertura da imagem por senha incorreta!

Voltando ao nosso contexto: se a pessoa que vai descriptografar o arquivo futuramente for a mesma pessoa que o criptografou, não há muito problema. No entanto, eu poderia enviar esse arquivo criptografado para o meu parceiro, Professor Renato da Costa. Nesse caso, ele só conseguiria abri-lo se possuísse a senha ou chave que eu escolhi. Dessa forma, eu teria que encontrá-lo pessoalmente para passar a senha ou chave - isso poderia ser um inconveniente.

Em um sistema de criptografia simétrica é primordial que a chave seja protegida. Como se trata da mesma chave, ela deve ser trocada antes da comunicação iniciar. O sistema fica vulnerável se a chave não for bem



protegida ou se a chave for interceptada por um atacante quando for enviada entre as partes que se comunicam. O risco de a chave ser comprometida fica maior com o aumento do número de partes envolvidas na troca de mensagens com a mesma chave.

Por fim, é importante ressaltar um rigor teórico: a criptografia – por si só – garante apenas o princípio da confidencialidade. No entanto, algoritmos criptográficos simétricos permitem garantir confidencialidade, integridade e autenticidade. *Como se garante a integridade?* Enviando o texto em claro junto do texto criptografado, o que permite verificar se a mensagem recebida é exatamente igual a mensagem enviada – concluindo que não foi alterada no meio do caminho.

Além disso, permite também garantir o princípio da autenticidade, caso se possa assegurar que apenas as duas entidades tenham conhecimento da chave secreta. *Diego, por que não garante o não-repúdio?* Porque um terceiro jamais poderá saber quem de fato enviou uma determinada mensagem. Como as duas entidades conhecem a chave secreta, uma das entidades pode sempre negar (repudiar) o envio da mensagem afirmando que quem a enviou foi a outra entidade.

- **Principais algoritmos:** DES, 3DES, AES, IDEA, RC4, Blowfish, Cifragem de Júlio César, etc.

(FCC / SEFAZ/PB - 2006) Criptografia simétrica é um método de codificação que utiliza:

- a) uma chave pública e uma chave privada para encriptar e decodificar a mesma mensagem.
- b) duas chaves públicas para encriptar e decodificar a mesma mensagem.
- c) uma só chave para encriptar e decodificar a mesma mensagem.
- d) duas chaves privadas para encriptar e decodificar a mesma mensagem.
- e) uma chave pública e duas chaves privadas para encriptar e decodificar a mesma mensagem.

Comentários: (a) Errado. O uso de uma chave pública e outra privada caracteriza a criptografia assimétrica, não a simétrica; (b) Errado. Duas chaves públicas não permitem a decodificação da mensagem, pois elas apenas criptografam; (c) Correto. A criptografia simétrica utiliza uma única chave, compartilhada entre remetente e destinatário, para cifrar e decifrar a mensagem; (d) Errado. Não se utiliza duas chaves privadas em nenhum dos modelos tradicionais de criptografia; (e) Errado. Essa combinação não é adotada em modelos de criptografia válidos (Letra C).

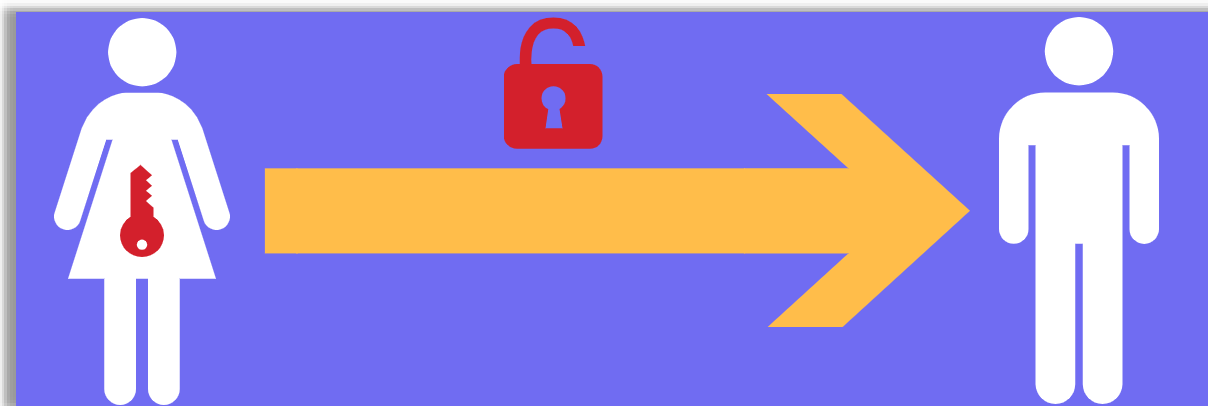
Criptografia Assimétrica

INCIDÊNCIA EM PROVA: ALTÍSSIMA

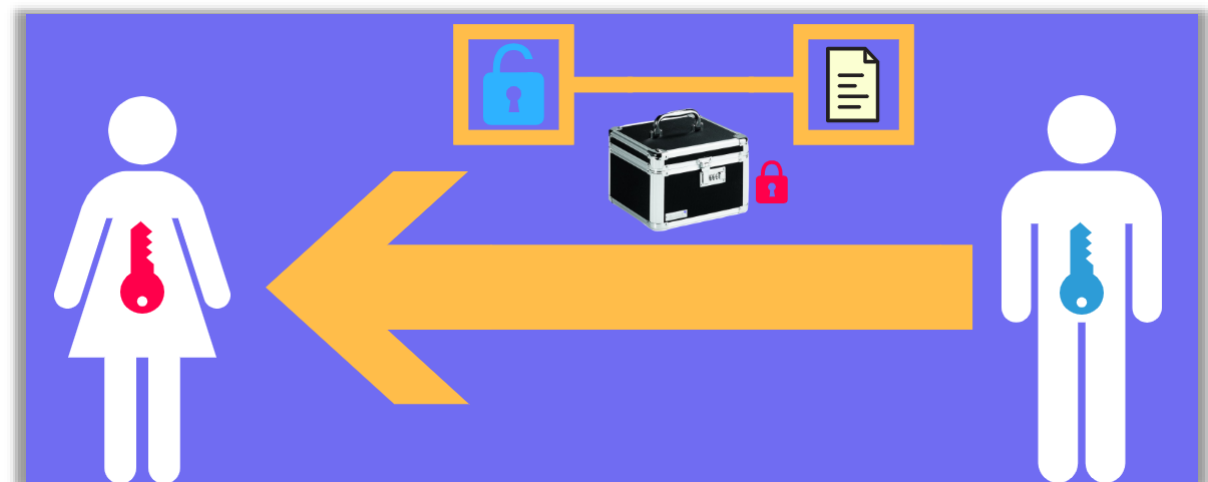
Nós vimos que a Criptografia Simétrica tinha uma falha: havia a necessidade de compartilhar a chave de cifragem/decifragem. A Criptografia Assimétrica (também chamada de Criptografia de Chave Pública) acabou com essa vulnerabilidade ao criar duas chaves distintas e assimétricas – sendo uma pública e uma privada. A chave pública é disponibilizada para qualquer um e a chave privada é de uso personalíssimo e restrito a um usuário, instituição ou equipamento.

Embora sejam chaves criptográficas diferentes, elas formam um par exclusivo em que necessariamente ao se criptografar informações com uma chave pública, somente a chave privada correspondente do par é capaz de descriptografar essas informações e vice-versa. Para entender isso melhor, eu preciso bastante da atenção de vocês agora – esse assunto é um pouquinho complexo e cai muito em prova. Vejam só...





Imaginem que agora é a Maria que precisa receber um documento sensível de João. No entanto, dessa vez, antes de receber qualquer documento, ela decide comprar um cadeado vermelho que vem acompanhado de uma chave vermelha. Dessa forma, ela vai aos correios e envia seu novo cadeado vermelho aberto para João, permanecendo com a chave vermelha sob sua posse. *Entenderam essa parte?*



João recebe o cadeado vermelho aberto e decide comprar um cadeado azul com uma única chave. Além disso, ele compra uma caixa. Então, ele insere seu cadeado azul aberto junto com o documento sensível que Maria precisa, coloca tudo dentro dessa caixa, permanece com a sua chave azul, mas tranca a caixa com o cadeado vermelho que foi enviado aberto por Maria e envia a caixa para ela por meio dos correios.

Maria recebe a caixa trancada com seu cadeado vermelho e - como somente ela possui a chave vermelha para o cadeado vermelho - destranca a caixa e encontra o cadeado azul aberto de João junto do documento sensível. Pronto! Agora toda vez que eles precisarem enviar documentos sensíveis um para o outro, eles podem inseri-los na caixa junto de seu cadeado aberto e trancá-la com o cadeado do outro. *Simples, né?*

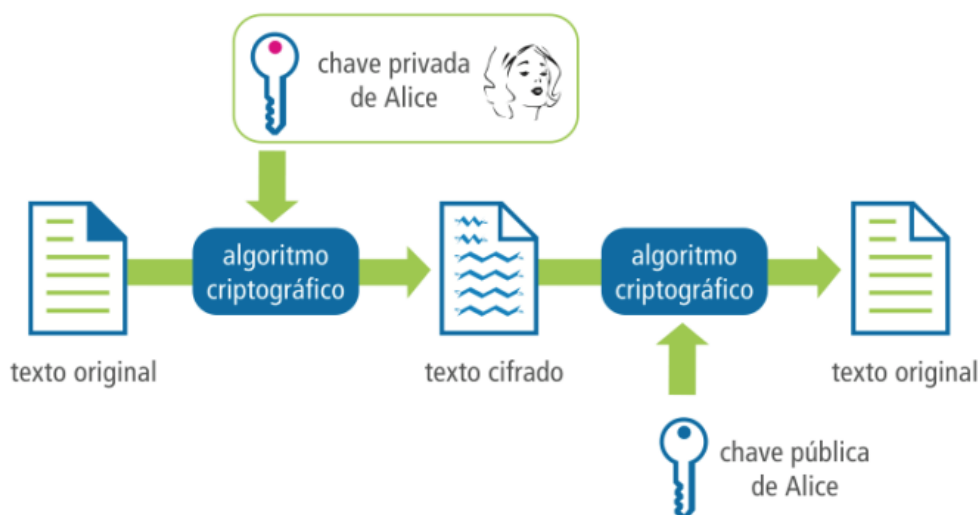
Esse método é interessante porque, caso o carteiro ou qualquer outra pessoa intercepte a caixa, ele não conseguirá abri-la. *Por que, professor?* Porque a chave nunca é enviada! O que é enviado é apenas o cadeado aberto - cada um permanece com sua chave. Em nossa analogia, o cadeado aberto representa a chave pública e a chave do cadeado representa a chave privada. No entanto, toda metáfora tem suas limitações. Logo, vamos retornar agora aos computadores!

Na Criptografia Assimétrica, nós possuímos duas chaves diferentes - uma chave pública e uma chave privada - por essa razão, é chamada de criptografia assimétrica. Esse par de chaves formam um par exclusivo, de modo que um texto criptografado pela chave pública só pode ser descriptografado pela chave privada e um texto criptografado pela chave privada só pode ser descriptografado pela chave pública. *Bacana?*

A chave pública é realmente pública - você pode contar qual é a sua chave pública para todo mundo. Evidentemente, a chave privada é exclusivamente sua! Similarmente, o número da sua conta corrente é público - ela seria sua chave pública. Já a senha de transação da sua conta corrente é privada - ela seria sua chave privada. *Professor, quando eu quiser criptografar uma mensagem, eu devo usar a minha chave pública ou minha chave privada?* Depende!



O emissor que deseja enviar uma informação sigilosa deverá utilizar a chave pública do destinatário para criptografar essa informação sigilosa. Para isto, é importante que o destinatário disponibilize sua chave pública. O Princípio da Confidencialidade é garantido, uma vez que somente o destinatário que possui a chave privada específica dessa chave pública conseguirá desfazer a operação de criptografia - como mostra a imagem anterior.



Professor, o que acontece se eu utilizar minha chave privada para criptografar uma informação? Nesse caso, qualquer um que possua sua chave pública conseguirá descriptografá-la e visualizá-la. E como sua chave pública é literalmente pública, você não garantirá o princípio da confidencialidade (todos terão

acesso à informação). Por outro lado, você garantirá o princípio da autenticidade. *Como assim, Diego?* Vejam só...

Nós sabemos que o princípio da autenticidade garante que determinada pessoa é realmente quem ela diz ser. Se alguém utilizar a minha chave pública para descriptografar uma informação e conseguir, ela terá certeza de que fui eu que realmente cryptografei aquela informação. *Por que?* Porque se a informação foi descriptografada com minha chave pública, ela só pode ter sido cryptografada com minha chave privada. E adivinhem: somente eu possuo minha chave privada!

Note que, diferentemente dos algoritmos de criptografia simétrica, os algoritmos de chave pública podem garantir também o não-repúdio porque, partindo do princípio de que a mensagem é íntegra, autêntica e que a chave privada é particular de cada entidade, somente a autora poderia tê-la enviado, logo não poderia negá-la. Percebam, portanto, que sempre que garantimos o não-repúdio garantimos a autenticidade, mas o contrário não é verdadeiro.

Em suma, algoritmos de criptografia simétrica podem garantir confidencialidade, integridade e autenticidade e algoritmos de chave pública garantem todos esses + não-repúdio.

- **Principais algoritmos:** RSA, DSA, ECDSA, ElGamal, Diffie-Hellman (para troca de chaves), etc.

(FUNIVERSA / PC/GO - 2015) Criptografia é a ciência de transformar mensagens para ocultar seu significado de intrusos. Considerando essa informação, assinale a alternativa que apresenta a técnica de criptografia que utiliza a chave pública para codificar as mensagens.

- a) cifração de chave simétrica
- b) hashing
- c) esteganografia
- d) cifração de chave assimétrica
- e) assinatura digital

Comentários: (a) Errado. A cifração de chave simétrica utiliza uma única chave secreta para codificar e decodificar a mensagem, não uma chave pública; (b) Errado. Hashing não é criptografia, mas uma função unidirecional que gera um resumo fixo da mensagem, sem possibilidade de reversão; (c) Errado. Esteganografia não transforma a mensagem, mas a oculta dentro de outro conteúdo; (d) Correto. A cifração de chave assimétrica utiliza um par de chaves: a chave pública para cifrar e a chave privada para decifrar; (e) Errado. Assinatura digital utiliza a chave privada para assinar e a pública para verificar, sendo usada para autenticidade e integridade, não para cifrar mensagens (Letra D).

Comparando os algoritmos de criptografia simétrica com algoritmos de criptografia assimétrica, podemos afirmar que os algoritmos de criptografia simétrica possuem menor custo computacional do que a criptografia assimétrica (isto é, possuem um maior desempenho ao cryptografar uma mesma quantidade de dados em menos tempo). Além disso, a criptografia simétrica utiliza, em geral, chaves menores do que a criptografia assimétrica.

Dito de outra forma, os algoritmos de criptografia assimétrica precisam - em geral - de chaves maiores para garantir o mesmo nível de segurança que algoritmos de criptografia simétrica (que utilizam chaves consideravelmente menores). Por fim, o gerenciamento de chaves para comunicação de um grupo de usuários é mais simples na criptografia assimétrica (utilizam $2n$ chaves, sendo n o número de pessoas), enquanto a criptografia simétrica utiliza $n(n-1)/2$ chaves.

Criptografia Híbrida

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



A Criptografia Assimétrica tem vantagens em relação a Criptografia Simétrica, mas também tem desvantagens. Em geral, as chaves simétricas são bem menores que as chaves assimétricas. Dessa forma, a Criptografia Assimétrica chega a ser até cem vezes mais lenta que a Criptografia Simétrica. Por essa razão, é comum a utilização de uma Criptografia Híbrida, ou seja, uma combinação da Criptografia Simétrica e Criptografia Assimétrica.

Basicamente, utiliza-se um algoritmo de Criptografia Assimétrica apenas para trocar chaves simétricas – chamadas de chaves de sessão – de forma segura. Logo, após a troca, toda comunicação é realizada utilizando um algoritmo de Criptografia Simétrica. Protocolos como *Secure Sockets Layer* (SSL) utilizam chaves de sessão para criptografar e descriptografar informações. *Fechou?*

(FCC / TJ-PA - 2009) Para manter a segurança das comunicações via Internet, o protocolo SSL (Secure Sockets Layer) utiliza sistemas criptográficos:

- a) simétricos de chaves públicas.
- b) assimétricos de chaves privadas.
- c) simétricos de chaves privadas.
- d) assimétricos de chaves de sessão.
- e) simétricos de chaves de sessão.

Comentários: (a) Errado. A criptografia simétrica não usa chaves públicas, mas sim chaves privadas compartilhadas; (b) Errado. A criptografia assimétrica usa um par de chaves (pública e privada), e não apenas chaves privadas; (c) Errado. Embora o SSL use criptografia simétrica para o tráfego principal, ele utiliza chaves de sessão, não chaves privadas permanentes; (d) Errado. A troca da chave de sessão é feita por criptografia assimétrica, mas a comunicação principal é feita com criptografia simétrica; (e) Correto. O SSL estabelece uma chave de sessão com criptografia assimétrica e, após isso, usa criptografia simétrica com a chave de sessão para proteger os dados transmitidos (Letra E).

Para finalizar esse assunto, precisamos falar de mais um conceito: Princípio de Kerckhoff! Esse princípio afirma que a segurança de um sistema criptográfico deve depender da chave utilizada e, não, do conhecimento do algoritmo. *Como é, Diego?* Dito de outra forma, isso significa que não existe nenhum problema em um possível atacante conhecer os detalhes de implementação e funcionamento de um algoritmo – ele inclusive deve ser público.

Nós vimos vários exemplos de algoritmos criptográficos! Se você quiser entender seus detalhes para compreender como eles funcionam, basta buscar no Google – é tudo público! O surgimento de um novo algoritmo criptográfico cuja implementação não seja conhecida não aumenta a sua confiabilidade. Na verdade, o melhor algoritmo é aquele que é público e que vem sofrendo ataques diversos sem quebrar – permanecendo seguro.

Existem três fatores que influenciam a segurança de um sistema criptográfico: (1) a força computacional de seu algoritmo – no sentido de que um algoritmo muito simples seria fraco⁵; (2) o sigilo da chave – a chave secreta ou privada não deve ser exposta; (3) e o comprimento da chave – chaves pequenas demais podem ser frágeis. Por outro lado, os detalhes de implementação do algoritmo são irrelevantes, podendo (na verdade, devendo) ser públicos.

(CEBRASPE / TJ-AM - 2019) A segurança de um sistema criptográfico simétrico deve estar na chave e no tamanho dessa chave, e não nos detalhes do algoritmo.

⁵ Um algoritmo é considerado **computacionalmente** seguro quando o tempo despendido para efetuar a sua quebra é maior que o tempo de vida útil da informação ou quando o valor gasto para efetuar a quebra é maior que o valor intrínseco da informação.



Comentários: tanto no sistema criptográfico simétrico quanto no assimétrico, a segurança deve estar na força do algoritmo, no sigilo de sua chave e no tamanho da chave e, não, nos detalhes do algoritmo – conforme Princípio de Kerckhoff (Correto).

(CEBRASPE / TJ-AM - 2019) A segurança de um sistema criptográfico simétrico tem como características básicas a força do algoritmo e o comprimento da chave.

Comentários: tanto no sistema criptográfico simétrico quanto no assimétrico, a segurança deve estar na força do algoritmo, no sigilo de sua chave e no tamanho da chave e, não, nos detalhes do algoritmo – conforme Princípio de Kerckhoff (Correto).

(CEBRASPE / TCU - 2007) Atualmente, os sistemas criptográficos utilizados são incondicionalmente seguros por se basearem na dificuldade de resolução de problemas matemáticos específicos ou em limitações na tecnologia computacional vigente.

Comentários: na verdade, os sistemas criptográficos utilizados atualmente são ~~incondicionalmente~~ computacionalmente seguros (Errado).

(FCC / TRT19 - 2011) Uma regra fundamental da criptografia é:

- a) A chave criptográfica deve ser modificada a cada período de alguns anos.
- b) Deve-se presumir que o criptoanalista conhece os métodos genéricos de criptografia e descryptografia que são utilizados.
- c) Tanto os algoritmos quanto as chaves devem ser secretos, segundo o princípio de Kerckhoff.
- d) O sigilo deve decorrer da presença de um algoritmo forte e secreto, independentemente do tamanho da chave.
- e) Deve-se supor que, se uma cifra puder resistir a uma estratégia de texto cifrado, ela é segura.

Comentários: (a) Errado, não existe essa exigência de modificação a cada período; (b) Correto, podemos assumir que o criptoanalista (o cara que deseja quebrar o algoritmo) conhece métodos genéricos de criptografia e descryptografia utilizados já que o algoritmo deve ser público; (c) Errado, os algoritmos devem ser públicos e as chaves devem ser secretas; (d) Errado, o algoritmo deve ser público e depende – sim – do tamanho da chave; (e) Errado, a estratégia de texto cifrado indica que o atacante conhece apenas o texto cifrado, logo não conhece o texto original nem a chave. Resistir a essa estratégia não indica que a cifra é segura. Aliás, mesmo que o atacante conheça o texto original e o texto cifrado, o atacante não conheceria a chave, logo não poderia descryptografar outras mensagens. Por outro lado, resistir também a essa estratégia não indica que a cifra é necessariamente segura (Letra B).



Principais Algoritmos

INCIDÊNCIA EM PROVA: BAIXA

Vejamos agora uma tabela comparativa entre os principais algoritmos de criptografia simétrica e assimétrica:

ALGORITMO	DESCRIÇÃO
DES	Algoritmo simétrico de chave privada com 56 bits de tamanho de chave. Desenvolvido na década de 1970, é considerado fraco pelos padrões atuais de segurança.
3DES	Versão atualizada do DES, que usa três vezes a cifra DES para melhorar a segurança. Suas chaves podem ter 112 ou 168 bits.
AES	Algoritmo simétrico de chave privada que substituiu o DES como padrão de criptografia em 2001. Suas chaves podem ter 128, 192 ou 256 bits.
IDEA	Algoritmo simétrico de chave privada desenvolvido na década de 1990, com chave de 128 bits. Foi uma alternativa ao DES, mas é menos utilizado atualmente.
RC4	Algoritmo simétrico de chave privada usado em várias aplicações, como redes sem fio e SSL/TLS. Possui chaves de 40 a 2048 bits.
RSA	Algoritmo assimétrico de chave pública usado para criptografia e assinaturas digitais. É um dos algoritmos mais amplamente usados na criptografia moderna.
DIFFIE-HELLMAN	Algoritmo de troca de chaves que permite a comunicação segura em um canal inseguro. É amplamente utilizado em sistemas criptográficos baseados em chave pública.
BLOWFISH	Algoritmo simétrico de chave privada usado em diversas aplicações de segurança, com chaves de 32 a 448 bits. É conhecido por sua velocidade e segurança.

ALGORITMO	SEGURANÇA	VELOCIDADE	TAMANHO DA CHAVE	UTILIZAÇÃO	TIPO
DES	Fraco	Rápido	56 bits	Legado	Simétrico
3DES	Moderado	Lento	112-168 bits	Legado	Simétrico
AES	Forte	Rápido	128-256 bits	Atual	Simétrico
IDEA	Moderado	Rápido	128 bits	Legado	Simétrico
RC4	Moderado	Rápido	40-2048 bits	Legado	Simétrico
RSA	Forte	Lento	2048-4096 bits	Atual	Assimétrico
DIFFIE-HELLMAN	Forte	Moderado	Variável	Chave Pública	Assimétrico
BLOWFISH	Forte	Rápido	32-448 bits	Legado	Simétrico



AUTENTICIDADE

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

A autenticidade é um dos pilares fundamentais da segurança da informação e diz respeito à garantia de que uma informação, transação ou comunicação é realmente proveniente de quem declara tê-la originado. Em um mundo cada vez mais digital, onde interações ocorrem à distância e dados circulam constantemente, assegurar a autenticidade é essencial para evitar fraudes, acessos não autorizados e manipulação de informações.

Nesse tópico, veremos os principais métodos de autenticação. Os métodos de autenticação são técnicas utilizadas para verificar a identidade de um usuário ao acessar um sistema ou serviço. Eles se baseiam em três categorias principais: "o que você sabe", "o que você tem" e "o que você é". Cada uma dessas formas oferece um nível diferente de segurança e, quando combinadas (como na autenticação multifator), tornam o processo de verificação muito mais robusto.



Método de Autenticação: O que você sabe?

Esse tipo de autenticação baseia-se em informações que apenas o usuário deveria saber, como senhas, PINs (números de identificação pessoal), respostas a perguntas de segurança e códigos de acesso. É o método mais comum e amplamente utilizado. No entanto, também é o mais vulnerável, já que senhas fracas, reutilizadas ou expostas em vazamentos podem ser facilmente exploradas por atacantes. Por isso, é fundamental o uso de senhas fortes, atualizações periódicas e boas práticas de armazenamento.

Senhas

Hoje em dia, quando falamos de autenticação em sistemas de informação, a forma mais comum e amplamente utilizada ainda é aquela combinação clássica de "usuário e senha". É simples, fácil de



implementar e funciona para quase tudo – desde o acesso a redes sociais até sistemas corporativos. Mas tem um detalhe importante: essa praticidade tem um preço, principalmente quando as senhas escolhidas são fracas. Não é à toa que, ano após ano, uma das senhas mais usadas no mundo continua sendo “12345”. Sim, isso mesmo. E se você está usando algo parecido, talvez seja hora de repensar...

Veja bem: uma senha com cinco dígitos numéricos tem só 100.000 combinações possíveis. Parece muito? Para um computador, isso é fchinha. Um ataque chamado força bruta consegue testar todas essas combinações em frações de segundo – até acertar. Mas calma, existem algumas estratégias simples para reduzir esse risco. Quer um exemplo prático? Já reparou que, quando você erra a senha do celular várias vezes, ele bloqueia temporariamente o acesso? Isso é uma forma de dificultar ataques automatizados. Outra medida é exigir que as senhas tenham um mínimo de complexidade, com letras maiúsculas, minúsculas, números e símbolos – isso já torna a tarefa do invasor muito mais difícil.

Então, fica a dica: nada de “12345”, “senha123” ou “qwerty”. Invista em senhas mais seguras, evite repetir a mesma senha em vários lugares e, se possível, ative a autenticação em dois fatores (2FA). Isso sim é um passo importante para proteger suas informações. Vocês já devem ter visto algumas estratégias de criação de senhas mais ou menos assim:

ESTRATÉGIAS DE SENHAS	DESCRIÇÃO
USE SENHAS LONGAS	Quanto maior a senha, mais difícil de quebrar. Recomenda-se no mínimo 12 a 14 caracteres.
MISTURE DIFERENTES TIPOS DE CARACTERES	Utilize letras maiúsculas, minúsculas, números e símbolos para aumentar a complexidade.
EVITE PALAVRAS COMUNS OU SEQUÊNCIAS ÓBVIAS	Não use senhas como “123456”, “senha”, “admin”, “abcdef” ou datas de nascimento.
CRIE FRASES-SENHA (PASSPHRASES)	Use uma frase fácil de lembrar, mas difícil de adivinhar, como “Sol&Chuva1987!CaféQuente”.
NÃO REUTILIZE SENHAS	Cada conta deve ter uma senha única, para evitar vazamentos em cadeia.
EVITE INFORMAÇÕES PESSOAIS	Não use nomes, aniversários, placas de carro ou qualquer dado facilmente associável a você.
USE GERENCIADORES DE SENHAS	Ferramentas como Bitwarden, 1Password ou LastPass ajudam a criar e armazenar senhas fortes.
ATIVE A AUTENTICAÇÃO EM DOIS FATORES (2FA)	Complementa a senha com um segundo fator, como código por app ou biometria.
ATUALIZE SENHAS PERIODICAMENTE	Troque senhas antigas, especialmente se houver suspeita de vazamento.
TESTE A FORÇA DA SENHA	Utilize ferramentas confiáveis para verificar se a senha é forte o suficiente.

Uma senha de oito dígitos numéricos tem apenas um milhão de combinações possíveis – é ridiculamente fácil para um computador testar todas as possibilidades em pouco tempo utilizando um ataque de força bruta. No entanto, uma senha de oito caracteres que podem ser números, símbolos, maiúsculos, minúsculos, entre outros, pode ter mais de 600 trilhões de combinações. Aí fica bem mais complexo para qualquer computador pessoal!

(FÊNIX / Prefeitura de Rancho Queimado-SC - 2024) A segurança na Internet é um aspecto crucial para a proteção de dados pessoais e empresariais. Um dos principais métodos de prevenção de ataques cibernéticos é o uso de senhas fortes. Qual das características a seguir é essencial para a criação de uma senha segura?

a) Utilizar apenas números.



- b) Utilizar palavras comuns do dicionário.
- c) Utilizar uma combinação de letras maiúsculas, minúsculas, números e símbolos.
- d) Reutilizar senhas antigas comumente usadas em diferentes contas.
- e) Manter a senha simples e curta para fácil memorização.

Comentários: (a) Errado. Senhas compostas apenas por números são facilmente previsíveis e mais vulneráveis a ataques de força bruta ou dicionário; (b) Errado. Palavras comuns do dicionário são facilmente descobertas por ataques baseados em listas de palavras conhecidas; (c) Correto. Senhas fortes devem combinar letras maiúsculas, minúsculas, números e símbolos, aumentando a complexidade e dificultando a quebra por atacantes; (d) Errado. Reutilizar senhas antigas ou em várias contas aumenta o risco de comprometimento em caso de vazamentos; (e) Errado. Senhas simples e curtas são mais fáceis de serem adivinhadas ou quebradas, comprometendo a segurança (Letra C).

PIN

Você com certeza já usou um PIN – talvez para sacar dinheiro no caixa eletrônico, desbloquear o celular ou autorizar uma compra com o cartão. O termo vem de Personal Identification Number, e nada mais é do que um número pessoal de identificação. Na prática, ele funciona como uma senha curta, composta só por números. O PIN é um exemplo clássico de autenticação baseada em “algo que você sabe”. Ele é amplamente usado em situações que exigem agilidade e praticidade, como em cartões de crédito e débito, terminais de autoatendimento e smartphones. Justamente por ser mais curto que uma senha tradicional, o PIN é ideal para dispositivos com teclados numéricos ou telas sensíveis ao toque.

Mas essa praticidade vem com um alerta: muita gente ainda escolhe combinações óbvias, tipo “1234”, “0000” ou datas de aniversário – o que deixa tudo mais vulnerável. Por isso, sempre que possível, use PINs mais longos e menos previsíveis. Algumas plataformas já permitem PINs com mais de quatro dígitos, o que aumenta bastante a segurança.

O PIN também costuma ser usado em autenticação de dois fatores. Por exemplo: quando você usa um cartão com chip (SmartCard), o sistema pede o cartão (Algo que você tem) e o PIN (Algo que você sabe). Essa combinação reforça a segurança e reduz muito o risco de acesso indevido. Além disso, muitos dispositivos modernos permitem que você configure um PIN para desbloqueio rápido – é mais prático que digitar uma senha longa toda vez. E, para evitar abusos, eles costumam ter limite de tentativas e até bloqueio temporário após erros consecutivos.

Perguntas de Segurança

As famosas perguntas de segurança são um método de autenticação baseado em “algo que você sabe”. Você provavelmente já se deparou com elas ao tentar recuperar uma senha ou acessar uma conta bloqueada. Funciona assim: durante o cadastro, você escolhe algumas perguntas pessoais – tipo “Qual o nome do seu primeiro pet?” ou “Em que escola você estudou na infância?” – e fornece as respostas. Mais tarde, se precisar confirmar sua identidade, o sistema pede essas mesmas respostas.

A ideia até parece segura, né? Mas, na prática, esse método tem várias fragilidades. Um dos principais problemas é que as respostas muitas vezes envolvem informações fáceis de descobrir, especialmente com o tanto de dados que a gente expõe nas redes sociais. Se você posta uma foto com o seu cachorro “Rex” e marca com legenda fofa, adivinha? A resposta à sua pergunta de segurança já não é tão secreta assim.

Outro ponto é que muita gente escolhe respostas genéricas ou óbvias – como “Maria” ou “123”. E ainda tem os erros de digitação ou variações de escrita (“São Paulo” vs. “Sao Paulo”), que podem impedir o acesso mesmo do dono da conta. Apesar disso, as perguntas de segurança ainda são usadas em muitos sistemas, principalmente como uma etapa adicional de verificação. Quando bem configuradas – com



perguntas personalizadas e respostas criativas –, elas até podem dar uma camada extra de proteção. Mas nunca devem ser usadas como único método de autenticação.

Método de Autenticação: O que você é?

Esse tipo de autenticação usa características físicas ou comportamentais do usuário, ou seja, dados biométricos. Exemplos incluem impressão digital, reconhecimento facial, leitura de íris, reconhecimento de voz e até padrões de digitação. Esse método é altamente seguro, pois as características biométricas são únicas para cada indivíduo. No entanto, ele também levanta preocupações quanto à privacidade e à possibilidade de falsificação em sistemas mal projetados.

Biometria

Você já parou para pensar no que é biometria? A palavra vem do grego – “bio” significa vida, e “metria” vem de medida. Em outras palavras, estamos falando da medição de características biológicas. E isso tem tudo a ver com identificação pessoal. A forma mais conhecida de biometria é a impressão digital, que você provavelmente já usou para desbloquear o celular ou fazer login no computador. Mas a biometria vai muito além disso! Hoje em dia, já existem sistemas que reconhecem você pela voz, rosto, retina, íris, padrão de veias da mão, e até mesmo pelo DNA.

E por que a biometria é tão usada? Simples: cada pessoa tem características físicas únicas, que são difíceis de copiar ou falsificar. Isso faz com que a autenticação biométrica seja uma forma muito segura e prática de confirmar a identidade de alguém. Tanto que, atualmente, muitos notebooks já vêm com leitores de digitais embutidos, permitindo que você faça login no sistema operacional com um simples toque – sem precisar lembrar senhas complicadas.

E a tendência é só crescer: com o avanço da tecnologia, a biometria está sendo integrada em cada vez mais áreas, desde acesso a aplicativos bancários até controle de entrada em prédios e aeroportos.

(IBADE / CIMCERO - 2023) A biometria é uma ferramenta que assegura qual princípio básico da segurança da informação?

- a) Integridade.
- b) Confidencialidade.
- c) Autenticidade.
- d) Disponibilidade.

Comentários: (a) Errado. A integridade garante que os dados não foram alterados, mas não está diretamente relacionada ao uso da biometria; (b) Errado. A confidencialidade assegura que apenas usuários autorizados tenham acesso à informação, mas a biometria não é seu principal mecanismo de garantia; (c) Correto. A biometria autentica a identidade do usuário por meio de características únicas (como digitais ou reconhecimento facial), garantindo o princípio da autenticidade; (d) Errado. A disponibilidade garante que os dados estejam acessíveis quando necessário, sem relação direta com o uso de biometria (Letra C).

Método de Autenticação: O que você tem?

Esse método se baseia em algo físico ou digital que o usuário possui, como um token, um cartão de acesso, um smartphone com aplicativo autenticador (como Google Authenticator), ou ainda um código enviado por SMS ou e-mail. Ele é bastante utilizado em sistemas de autenticação em dois fatores (2FA), oferecendo uma camada adicional de segurança. Mesmo que a senha do usuário seja comprometida, o invasor ainda precisaria ter acesso ao dispositivo ou objeto para concluir o login.



Smart Cards



Os smartcards – ou cartões inteligentes – são cartões físicos com um chip embutido que guarda informações criptografadas, usados principalmente para autenticação segura. Eles funcionam com base no princípio de “algo que você tem”, o que os torna uma solução muito usada em ambientes que exigem alto nível de proteção, como empresas, órgãos do governo e até instituições militares.

Dentro do chip, podem estar armazenados certificados digitais, chaves criptográficas e dados pessoais. Para que o cartão funcione, ele precisa ser lido por um leitor específico – um dispositivo conectado ao computador. E não para por aí: além do cartão, o usuário geralmente precisa digitar uma senha ou PIN, o que transforma esse processo em uma autenticação de dois fatores: o cartão (algo que você tem) + a senha (algo que você sabe).

Uma das suas grandes vantagens é a robustez da segurança. Como os dados ficam armazenados com criptografia dentro do chip, é extremamente difícil cloná-los ou extrair essas informações. Isso protege contra vários tipos de ataques, como engenharia reversa ou interceptação de dados. E os usos vão além do simples login em sistemas, servindo para assinatura digital de documentos; controle de acesso físico, como portas de áreas restritas; e também para autenticação em redes e sistemas corporativos.

Muita gente já viu isso na prática sem perceber: os crachás com chip usados por funcionários em grandes empresas ou universidades. Esses cartões funcionam ao mesmo tempo como identificação visual e chave de acesso digital, o que é prático e seguro.

Aplicativos Autenticadores

Os aplicativos autenticadores se tornaram grandes aliados na proteção das nossas contas online. Eles fazem parte da categoria de autenticação baseada em “algo que você tem” e são muito usados na famosa verificação em dois fatores (2FA) – aquela etapa extra que deixa o login bem mais seguro. Funciona assim: ao configurar um aplicativo autenticador no seu celular, ele começa a gerar códigos temporários (OTP – One-Time Password) que mudam a cada poucos segundos. Esses códigos são usados como um segundo passo no processo de login. Em outras palavras, você digita sua senha (algo que você sabe) e depois o código atual gerado pelo app (Algo que você tem). Isso forma uma dupla poderosa contra invasões.

E o melhor: esses apps não precisam de internet ou sinal de celular para funcionar. Eles geram os códigos direto no aparelho, o que evita vários riscos, como: interceptação de SMS em redes inseguras; clonagem de chip; ou aquele atraso chato na entrega do código. Os aplicativos mais conhecidos são o Google Authenticator, Microsoft Authenticator, Authy, LastPass Authenticator, entre outros. A configuração costuma ser simples: você escaneia um QR Code fornecido pelo site ou serviço que quer proteger, e pronto – o app começa a gerar os códigos automaticamente.

Alguns desses apps ainda oferecem recursos extras de segurança, como: proteção por senha ou biometria e até backup criptografado na nuvem, como no caso do Authy – o que ajuda bastante caso você perca ou troque de celular (desde que essa função seja ativada com cuidado). A grande sacada do OTP é que ele adiciona uma camada extra de proteção. Mesmo que alguém descubra sua senha, não consegue acessar sua conta sem o código temporário válido – o que dificulta muito a vida dos invasores. Esses códigos são gerados com base em dois algoritmos:

- **TOTP (Time-Based One-Time Password):** esse código de acesso temporário muda conforme o tempo, geralmente a cada 30 ou 60 segundos.



- **HOTP (HMAC-Based One-Time Password):** esse código de acesso temporário muda com base em um contador de uso.

Ambos garantem que os códigos sejam imprevisíveis, sincronizados e válidos apenas no momento certo, o que os torna extremamente seguros. Outra vantagem é que o OTP não precisa ficar armazenado como uma senha tradicional – e como ele só funciona uma vez, mesmo que alguém veja ou capture o código, não consegue usá-lo depois. Agora, um alerta importante: códigos enviados por SMS ou e-mail não são tão seguros quanto os gerados em apps autenticadores ou tokens físicos. Isso porque, se o celular ou o e-mail do usuário for invadido, o OTP pode ser interceptado. Por isso, os métodos mais seguros hoje em dia são os apps de autenticação e os dispositivos dedicados.

Tokens

Você já usou algum sistema que pede, além da senha, um código temporário para confirmar que é você mesmo? Então, isso provavelmente envolveu o uso de um token, um dos métodos mais populares de autenticação em dois fatores. Um token é baseado no conceito de “algo que você tem” – ou seja, um dispositivo físico ou digital que serve como chave de acesso temporária. Ele é muito usado em ambientes onde a segurança precisa ser reforçada: bancos, empresas, sistemas internos e até redes sociais. Existem dois tipos principais:

- **Tokens Físicos (Hardware):** geralmente parecem um chaveiro ou um cartão com visor, e geram códigos numéricos que mudam a cada 30 segundos ou permitem autenticação via porta USB.
- **Tokens Digitais (Software):** funcionam por meio de aplicativos autenticadores (Ex: Google/Microsoft Authenticator ou o próprio app do seu banco) – geram códigos temporários e únicos.

Quando você entra num sistema com autenticação em dois fatores (ou 2FA), digita sua senha (algo que você sabe) e depois o código gerado pelo token (algo que você tem). Isso significa que, mesmo que alguém descubra sua senha, não consegue acessar sua conta sem o token. Esses tokens usam algoritmos como o TOTP/HOTP, que garantem que cada código seja único e válido só por alguns segundos – o que dificulta muito qualquer tentativa de invasão.



Ah, e vale lembrar: em alguns casos, o código do token pode ser enviado por SMS, mas esse método já não é tão seguro hoje em dia, por causa do risco de interceptação. Por isso, os aplicativos autenticadores e dispositivos como o YubiKey têm sido preferidos, especialmente em ambientes corporativos.

Autenticação Forte

INCIDÊNCIA EM PROVA: BAIXA

Autenticação Forte⁶ é um processo de verificação de identidade que exige dois ou mais fatores distintos de autenticação, tornando o acesso a sistemas e informações muito mais seguro. Seu principal objetivo é reduzir o risco de acessos indevidos, mesmo quando uma das credenciais, como uma senha, é comprometida. A autenticação forte é amplamente utilizada em ambientes corporativos, bancários e governamentais, além de ser cada vez mais comum em serviços online acessados por usuários comuns.

Um exemplo típico de autenticação forte é o login em um sistema com senha + código gerado por aplicativo autenticador. Outro exemplo seria biometria + smartcard. Essa combinação de fatores proporciona uma barreira significativa contra ataques cibernéticos, como phishing, força bruta, vazamento de senhas e engenharia social, já que dificulta que um invasor tenha acesso simultâneo aos diferentes elementos de autenticação.

Saiba mais:

Imagine que você quer entrar em um cofre muito importante dentro de um banco. Para abrir esse cofre, não basta apenas ter uma chave – o sistema de segurança exige duas formas diferentes de verificação, cada uma de um tipo diferente, para garantir que você é realmente quem diz ser.

A primeira verificação pode ser algo que você sabe, como o código secreto do cofre (a senha). Mas saber o código não é suficiente. A segunda verificação precisa ser de outro tipo – por exemplo, algo que você tem, como um cartão magnético exclusivo ou um dispositivo que gera códigos temporários, que só você carrega. Ou, ainda, pode ser algo que você é, como sua impressão digital ou reconhecimento facial.

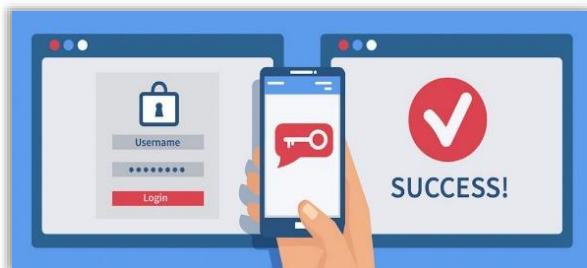
Agora, imagine alguém tentando abrir esse cofre. Se a pessoa souber o código, mas não tiver o cartão, não entra. Se roubar o cartão, mas não souber o código, também não entra. E mesmo que tentasse falsificar sua impressão digital, o sistema ainda exigiria o outro fator. Ou seja, a autenticação forte é como um cofre com várias camadas de segurança diferentes, que só se abrem juntas – misturar chaves diferentes garante que apenas o verdadeiro dono tenha acesso.

Essa combinação de “tipos de barreiras” – e não só a quantidade – é o que torna a autenticação forte tão confiável. Não adianta ter duas chaves parecidas (como duas senhas diferentes); o que garante segurança de verdade é ter chaves de naturezas distintas. É isso que impede que invasores entrem facilmente, mesmo que consigam uma das partes.

A autenticação forte é uma exigência em diversos padrões e regulamentações de segurança, como o PCI DSS (para o Setor Financeiro), a LGPD (no Brasil), a GDPR (na Europa), e diretrizes de segurança digital do governo e de grandes corporações. Em muitos casos, ela é implementada como parte de uma política mais ampla de Autenticação Multifator (MFA), reforçando a proteção de dados sensíveis e sistemas críticos.

⁶ Muitas vezes, as bancas utilizam os termos Autenticação Forte e Autenticação Multifator (MFA) de forma intercambiável. Sendo tecnicamente rigoroso, a diferença entre eles é que o primeiro exige que os fatores sejam de categorias diferentes e o segundo permite que os fatores sejam da mesma categoria ou não. Toda autenticação forte é multifator, mas nem toda autenticação multifator é forte. No entanto, muitas vezes as bancas vão considerar ambos como sinônimos.





Já a Autenticação em Dois Fatores (2FA) exige exatamente dois fatores distintos para validar a identidade do usuário. Trata-se de um método de segurança que exige dois elementos distintos para validar a identidade de um usuário ao acessar um sistema ou serviço online. Em vez de depender apenas de uma senha, o 2FA adiciona uma camada extra de proteção, tornando mais difícil para invasores acessarem contas mesmo que tenham a senha correta.

Essa parada de verificação em duas etapas está indo longe demais



Hoje em dia esse tipo de autenticação está ficando cada vez mais comum. Em geral, você utiliza algo que você sabe (Ex: Senha) para acessar um sistema. Ele, então, envia uma mensagem com um código para algo que você tem (Ex: Smartphone). Você insere esse código e pronto... estará autenticado, ou seja, o sistema saberá que você é realmente você. **Quando você saca dinheiro em um caixa eletrônico, você também utiliza dois métodos de autenticação.** Primeiro, você insere seu cartão (algo que você tem). Após escolher o valor que você deseja sacar, você insere ou uma senha (algo que você sabe) ou sua impressão digital (algo que você é).

(FAU / Prefeitura de Porto Amazonas-PR - 2025) O que é autenticação multifator (MFA)?

- a) Um método de autenticação que exige apenas uma senha.
- b) Um processo de validação que requer dois ou mais fatores de autenticação para acessar um sistema.
- c) Um tipo de firewall avançado.
- d) Um sistema de criptografia de dados.
- e) Uma tecnologia usada para acelerar conexões de rede.

Comentários: (a) Errado. Autenticação com apenas uma senha é chamada de autenticação de fator único, e não multifator; (b) Correto. A autenticação multifator (MFA) exige dois ou mais fatores diferentes (como senha, token, biometria) para validar a identidade do usuário e reforçar a segurança; (c) Errado. Firewall é um mecanismo de controle de tráfego de rede, não está relacionado à autenticação multifator; (d) Errado. Criptografia protege dados em repouso ou em trânsito, mas não envolve diretamente múltiplos fatores de autenticação; (e) Errado. Tecnologias de aceleração de rede não têm relação com autenticação ou verificação de identidade (Letra B).

(IBEST / Prefeitura de Muriaé-MG - 2024) O conceito de Autenticação Multifator (MFA) diz respeito ao

- a) processo de verificação de identidade que utiliza apenas senhas complexas.
- b) método de criptografia que garante a segurança dos dados em trânsito.
- c) sistema que bloqueia, automaticamente, o acesso a sites não seguros.
- d) procedimento de segurança que requer duas ou mais formas de autenticação para verificar a identidade de um usuário.



Comentários: (a) Errado. O uso apenas de senhas, mesmo que complexas, caracteriza autenticação de fator único, não multifator; (b) Errado. Criptografia protege dados, mas não se refere ao processo de autenticação com múltiplos fatores; (c) Errado. Bloqueio de sites é uma funcionalidade típica de firewalls ou filtros de conteúdo, não relacionada à autenticação multifator; (d) Correto. A autenticação multifator (MFA) é um procedimento de segurança que exige dois ou mais métodos distintos (como senha, token, biometria) para verificar a identidade do usuário (Letra D).

(CEBRASPE / EMBRAPA - 2025) A implementação de autenticação multifator (MFA) reduz significativamente o risco de acesso não autorizado ao sistema.

Comentários: a autenticação multifator (MFA) aumenta a segurança ao exigir múltiplas formas de verificação, como senha e biometria, dificultando o acesso por invasores mesmo que um fator seja comprometido (Correto).

(IBADE / CRC-MS - 2024) Considerando os princípios de proteção e segurança da informação no ambiente digital, escolha a alternativa que melhor define o conceito de autenticação multifator (MFA) e sua importância em evitar acessos não autorizados.

a) A autenticação multifator é um sistema de backup de senhas que solicita respostas a perguntas pessoais, utilizadas quando o usuário esquece sua senha principal.

b) A autenticação multifator é uma funcionalidade exclusivamente presente em servidores corporativos e não está disponível para usuários domésticos.

c) A autenticação multifator combina dois ou mais métodos de verificação, como senhas e códigos enviados a dispositivos móveis, tornando o acesso não autorizado significativamente mais difícil para invasores.

d) A autenticação multifator é uma técnica que utiliza somente senhas complexas para garantir a segurança de contas, sem a necessidade de dispositivos adicionais.

e) A autenticação multifator permite que o usuário escolha entre inserir uma senha ou realizar um reconhecimento biométrico, mas nunca ambos ao mesmo tempo.

Comentários: (a) Errado. Perguntas pessoais como backup de senha não caracterizam autenticação multifator, pois representam apenas um único fator de verificação; (b) Errado. A autenticação multifator está amplamente disponível para usuários domésticos em serviços como e-mail, redes sociais e bancos online; (c) Correto. A MFA combina dois ou mais fatores (como senha + código via SMS ou biometria), aumentando significativamente a segurança e dificultando o acesso não autorizado mesmo que um fator seja comprometido; (d) Errado. O uso exclusivo de senhas, mesmo complexas, não configura MFA, pois ainda se trata de um único fator de autenticação (algo que o usuário sabe); (e) Errado. A MFA pode exigir múltiplos fatores combinados (como senha e biometria), e não apenas a escolha entre eles (Letra C).



Assinatura Digital

Conceitos Básicos

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Há situações em que as soluções antigas simplesmente não dão mais conta das nossas necessidades atuais. Já pararam para pensar como é ultrapassado (e até inseguro) assinar documentos importantes com papel e caneta? Pois é... aqui no Brasil mesmo, volta e meia a gente vê notícia de cartório pegando fogo, perdendo arquivos, ou então de casos em que alguém falsificou uma assinatura com facilidade. Em um mundo cada vez mais digital, as nossas demandas pedem mais agilidade e segurança.

Agora imaginem a seguinte situação: Felipe mora na Itália e quer fechar um contrato com Lucas, que está em Londres. Se eles dependessem de um contrato físico, esse documento teria que viajar por avião ou correio, demorando semanas até ir e voltar com todas as assinaturas. Um atraso de vida! Agora, se eles estivessem usando assinaturas digitais, tudo seria resolvido em questão de minutos! É só selecionar o documento, clicar com o botão direito, assinar digitalmente com um código de segurança e enviar por e-mail. Tudo sem papel. E o melhor: esse contrato digital tem o mesmo valor legal que um contrato assinado à mão. Bem mais prático e seguro, né?

E aqui entra um ponto que a gente já viu: Criptografia Assimétrica. Lembram? Quando você criptografa com a chave pública do outro, garante o Princípio da Confidencialidade; e quando você assina com a sua chave privada, garante o Princípio da Autenticidade. Mas a Assinatura Digital vai além: ela garante três coisas muito importantes:

- **Autenticidade:** confirma que foi você quem assinou;
- **Integridade:** prova que o conteúdo do documento não foi alterado depois da assinatura;
- **Irretratabilidade:** você não pode dizer depois que “não foi você” que assinou.

E para que tudo isso funcione, a gente precisa entender um conceito-chave: o Algoritmo de Hash (também conhecido como Função Módulo ou Função de Resumo). Em resumo (sem trocadilho), o algoritmo de hash pega qualquer tipo de dado, não importa se é um textinho de 2 linhas ou um arquivo gigantesco com vídeos, imagens, etc, e transforma tudo isso em uma sequência de tamanho fixo. Isso mesmo: não importa o tamanho da entrada, a saída tem sempre o mesmo tamanho.

Querem uma analogia? Lembra das aulas lá do ensino fundamental, quando a professora ensinava a fazer divisão com resto? A gente tinha dividendo, divisor, quociente... e o que sobrava era o resto. Pois então, esse “resto” tem muito a ver com o funcionamento básico de uma função de hash – é como um número de identificação único para aquele conteúdo. Se você muda qualquer letrelinha no conteúdo original, o resultado do hash muda completamente. Vejam só:

The image shows two division problems side-by-side, illustrating how a small change in the dividend affects the quotient and remainder.

Left Problem:

$$\begin{array}{r} \text{DIVIDENDO } 10 \quad | \quad 3 \text{ DIVISOR} \\ -9 \quad 3 \text{ QUOCIENTE} \\ \hline \text{RESTO } 1 \end{array}$$

Right Problem:

$$\begin{array}{r} \text{DIVIDENDO } 942386 \quad | \quad 3 \text{ DIVISOR} \\ -942384 \quad 314128 \text{ QUOCIENTE} \\ \hline \text{RESTO } 2 \end{array}$$



A Função Resto ou Módulo funcionava assim: dado um dividendo e um divisor, a função retornava um resto. Na imagem à esquerda, se o dividendo for 10 e o divisor for 3, o resto da divisão é 1. Simples: 3 cabe 3 vezes dentro de 10 ($3 \times 3 = 9$) e sobra 1; já na imagem à direita, se o dividendo for 942.386 e o divisor ainda for 3, o resto é 2. Mesmo com um número enorme, a ideia é a mesma. Beleza, mas... o que isso tem a ver com a tal função hash?

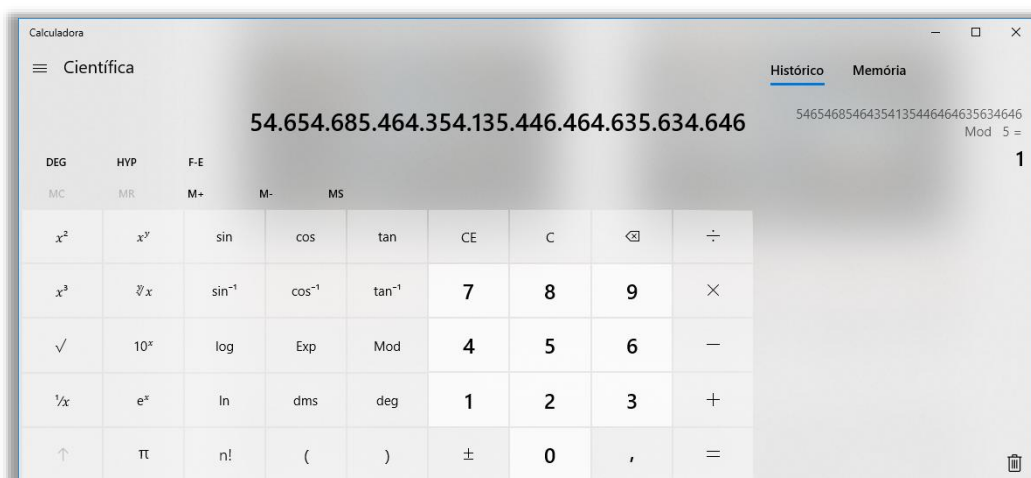
Pensem comigo: na primeira divisão (10 por 3), a entrada tinha dois dígitos, e o resultado (resto) foi um único dígito. Na segunda, a entrada tinha seis dígitos, e o resultado também foi um único dígito. Em outras palavras, não importa o tamanho da entrada, a saída tem sempre o mesmo formato e tamanho. Esse é justamente um dos comportamentos fundamentais de uma função hash!

Ela pega qualquer quantidade de dados – pode ser uma palavra, uma frase, ou até um arquivo inteiro com milhões de páginas – e transforma tudo isso em uma sequência de saída com tamanho fixo. Um hash é como uma “impressão digital” daquele conteúdo. E mais: se você mudar uma vírgula sequer na entrada, o hash gerado será completamente diferente – o que garante a integridade dos dados. Vamos ver sua aplicação em algumas frases:

FRASE DE ENTRADA	HASH DE SAÍDA
Oi	0f3abd55f538f9f343524200a452ffbc
Oi!	7349da19c2ad6654280ecf64ce42b837
Oi, pessoal! O professor Diego é flamenguista e o professor Renato é vascaíno.	9ed868b2aa98ce95aaa08ef1065ad8fc

Note que a única diferença das duas primeiras frases de entrada é o ponto de exclamação, mas o hash resultante dessas duas frases será totalmente diferente – como se fossem mensagens completamente distintas. Isso acontece porque até uma alteração minúscula muda todo o resultado final. E isso é exatamente o que queremos quando falamos em garantir integridade de dados: se alguém alterar qualquer coisa, a assinatura não bate mais – e a fraude é detectada na hora.

Então, voltando ao nosso exemplo: pode colocar mil dígitos, pode colocar só um – o hash sempre gera uma saída padronizada, que pode ser comparada, armazenada ou usada em processos como a assinatura digital. Legal, né? Essa é a base do que a gente vai usar para garantir que um documento não foi alterado, mesmo que ele esteja sendo assinado e enviado digitalmente de um lado do mundo para o outro. Vejam quantos dígitos temos no dividendo apresentado a seguir e a saída foi... 1.



Pois bem, tem exemplos bem práticos disso no nosso dia a dia que funcionam de maneira bem parecida com essa lógica. Deem uma olhada nesse boleto bancário do Bradesco, por exemplo:



Repararam naquele número 1 isolado no meio da linha? Ele se chama Dígito Verificador. Esse número é calculado com base em todos os outros dígitos do boleto. A ideia é simples: se alguém digitar o número errado na hora do pagamento – trocando ou esquecendo um número – o dígito verificador não vai bater, e o sistema bancário identifica o erro automaticamente. Isso é um ótimo exemplo de como funciona um algoritmo de hash: você fornece uma entrada grande (todos os números do boleto), e ele gera uma saída pequena e fixa (o dígito). Se qualquer parte da entrada mudar, a saída também muda.

Outro exemplo muito familiar é o CPF. Os dois últimos números (após o traço) são, adivinhem... dígitos verificadores! Eles também são calculados com base nos nove primeiros números. O CPF 123.456.789-12, por exemplo, não é válido – porque os dígitos finais não batem com os primeiros; já o 105.828.626-98 é válido – e só faz sentido com esse final. Agora vem uma pergunta importante: se eu souber a saída (o dígito verificador), consigo descobrir a entrada? Não!!!

Isso porque o algoritmo de hash funciona em apenas uma direção – a gente chama isso de "função unidirecional" ou one-way. Ele transforma, mas não volta. Por isso, se eu te disser que o dígito verificador do meu CPF é 71 (e é mesmo), você não consegue descobrir o restante dos números. E isso é ótimo para segurança!

Outra característica importante do hash é que, se você fornecer a mesma entrada, teremos sempre a mesma saída. Por exemplo, o resto da divisão de 10 por 3 vai ser sempre 1, nunca 2 ou 4. Isso garante consistência e confiabilidade. Mas nem tudo é perfeito: hashes também têm uma limitação chamada colisão. Isso acontece quando duas entradas diferentes produzem a mesma saída. Lembra do exemplo:

- Resto da divisão de 10 por 3 = 1
- Resto da divisão de 13 por 3 = 1

Duas entradas diferentes e mesmo resultado de saída. Em algoritmos de hash modernos, colisões são raríssimas e difíceis de encontrar – mas ainda assim, matematicamente possíveis. Nós mostramos o exemplo da Função Resto para ilustrar uma analogia com o funcionamento do algoritmo de hash, mas essa função definitivamente não serve como algoritmo de hash para criptografia de senhas. Sabe por quê? Porque ela é altamente suscetível a colisões!

Em outras palavras, é muito fácil encontrar entradas diferentes que geram a mesma saída. Isso compromete completamente a segurança. E como a gente reduz a chance de colisões? Aumentando o tamanho da saída! Quanto maior o número de bits, mais combinações possíveis, e mais difícil fica duas entradas diferentes produzirem o mesmo resultado.

Hoje, os algoritmos de hash criptográficos modernos exigem, no mínimo, 128 bits de saída. Isso representa 2^{128} possibilidades – um número maior que todos os grãos de areia do nosso planeta.



Aluno: Fernando
Curso: Informática p/ ISS-Campo Grande (Auditor Fiscal) Com Videoaulas - Pós-Edital
Aula: Aula 04
PDF: [curso-88710-aula-04-v1.pdf](#)
Segurança da Informação - Princípios Fundamentais
Segurança da Informação - Confidencialidade, Criptografia
Videos: [Segurança da Informação - Autenticidade](#)
[Segurança da Informação - Integridade: HASH](#)
[Segurança da Informação - Certificação Digital e Assinatura Digital](#)
[Segurança da Informação - Integridade: Recape \(Backup\)](#)
Ignorada: não
Data: 10/04/2019 01:06
Coloquei os pontos :)
Boa noite professor. Sobre a Aula 04, página 33.
Em um litro temos 1×10^9 grãos de areia (Wikipédia)
(considerando o tamanho médio de um grão = 1×10^{-12} m³).
Pergunta: 1 L >>>> 1×10^9 grãos de areia.
A Terra tem aproximadamente $1,083 \times 10^{12}$ Km³ (Wikipédia).
1 km³ = 1×10^{12} litros.
Portanto a Terra tem $1,083 \times 10^{12} \times 10^{12}$ litros = $1,083 \times 10^{24}$ litros.
Assim, se considerarmos que 70% do volume da Terra (chutei pra mais) pode ser transformado em grãos de areia, a Terra possui $0,7 \times 1,083 \times 10^{24} \times 10^9$ grão de areia. Simplificando $0,758 \times 10^{33}$ grãos de areia.
Como $2^{128} \approx 3,4 \times 10^{38}$ e $0,758 \times 10^{33} < 3,4 \times 10^{38}$
Conclui-se que realmente existem mais Hash de 128 bits do que grãos de areia no Planeta Terra.

UM ALUNO FEZ QUESTÃO DE FAZER AS CONTAS PARA PROVAR QUE ISSO É VERDADE :)

Vamos recapitular o que aprendemos: o algoritmo de hash é uma função unidirecional (one-way): você consegue gerar a saída a partir da entrada, mas não consegue fazer o caminho inverso. Ele aceita entradas de qualquer tamanho, mas sempre gera uma saída de tamanho fixo. A mesma entrada sempre gera a mesma saída. Pequenas alterações na entrada geram saídas completamente diferentes – até mesmo se você mudar um único caractere ou bit. E quanto maior o tamanho da saída, menor a chance de colisão.

Um exemplo clássico de função de hash é o MD5. Ele gera uma saída de 128 bits – e apesar de ser rápido e muito usado no passado, hoje não é mais recomendado para segurança, justamente porque colisões já foram encontradas; mas ele ainda é um bom exemplo para entender o funcionamento da lógica. Quem quiser brincar um pouquinho com hash, basta acessar a página abaixo:

[HTTPS://WWW.MD5HASHGENERATOR.COM](https://www.md5hashgenerator.com)

Saiba mais:

Sabe quando você cria uma conta em um site e escolhe uma senha? Pois bem, o site não salva a sua senha como ela é digitada. Na verdade, ele guarda apenas o hash da sua senha – e isso é fundamental para sua segurança. Imagine se o sistema simplesmente armazenasse sua senha original, do jeitinho que você digitou. Se alguém invadissem o banco de dados – ou até se um administrador mal-intencionado tivesse acesso – ele poderia ver suas senhas em texto puro e usá-las em outros sites, redes sociais, bancos... já que muita gente repete senhas (infelizmente).

Ao utilizar um algoritmo de hash, a senha vira uma espécie de "impressão digital" criptográfica: uma sequência única de caracteres que representa sua senha, mas que não pode ser revertida facilmente. E como funciona na prática? Você cria sua senha e o sistema gera o hash dela, que é salvo no banco de dados. Depois, toda vez que você faz login, o sistema pega a senha que você digitou, gera o hash novamente e compara com o hash que já está salvo. Se os dois hashes baterem, bingo: o acesso é liberado.

Logo, o sistema nunca precisa saber qual é sua senha verdadeira – ele só precisa verificar se o hash gerado bate com o hash armazenado. E como a única maneira de gerar aquele mesmo hash é digitando a senha correta, isso garante a segurança sem expor seus dados sensíveis :)

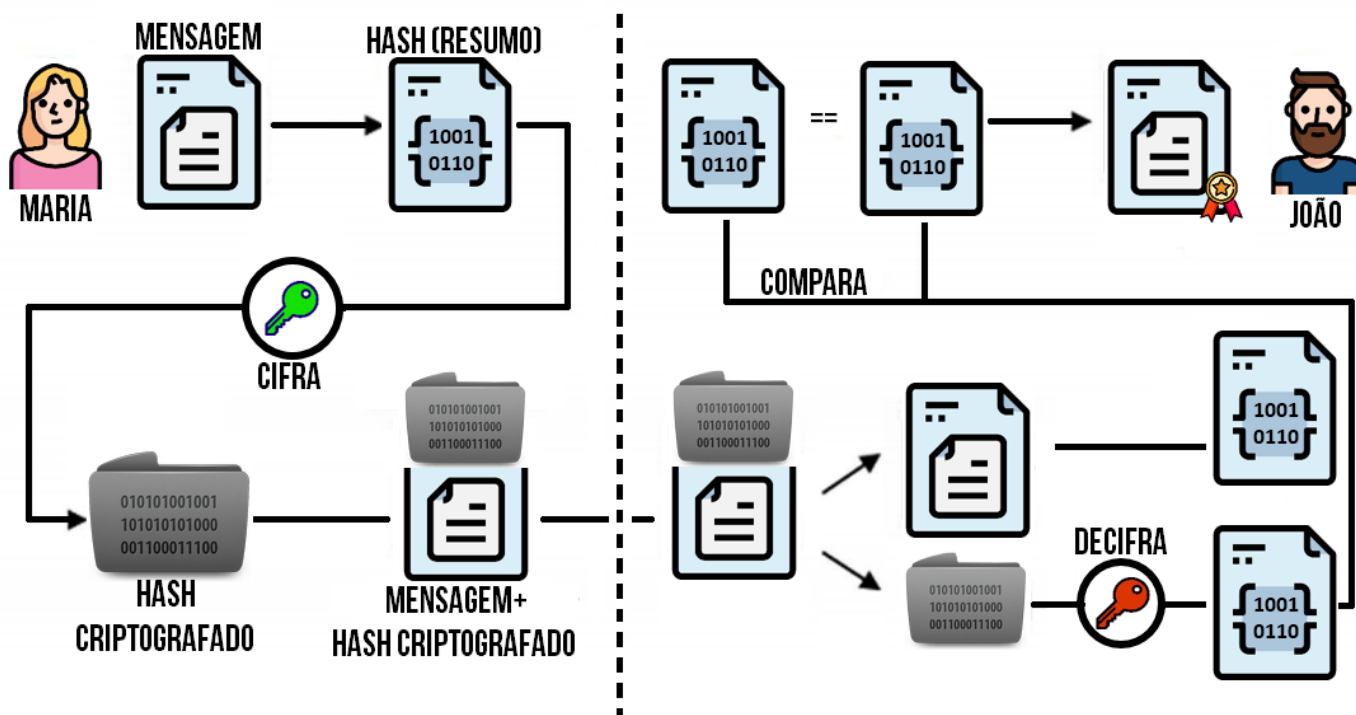
Dito tudo isso, fica a pergunta: qual é a relação entre Algoritmo de Hash e Assinatura Digital? **Nosso objetivo é garantir Autenticidade, Integridade e Irretratabilidade do emissor.** Nós já sabemos que –



para garantir autenticidade – basta utilizar a Criptografia Assimétrica e cifrar a informação com a minha chave privada. Nós também sabemos que – para garantir a integridade – basta utilizar um Algoritmo de Hash. Então, combinamos essas duas estratégias para alcançar nosso objetivo.

Vejam na imagem seguinte que Maria escreve sua mensagem original, em texto claro (sem criptografia). Em seguida, ela gera o hash da mensagem – ou seja, um resumo digital. Agora vem o segredo: ela criptografa esse hash com a sua chave privada (isso é o que chamamos de assinatura digital). Por fim, ela envia para João: a mensagem original + o hash criptografado (a assinatura).

Do lado de João, ele recebe a mensagem e o hash criptografado e faz duas coisas: primeiro, ele gera um novo hash da mensagem que recebeu; depois, ele descriptografa o hash original (a assinatura) usando a chave pública da Maria. Agora, portanto, ele tem dois hashes: um que ele mesmo calculou e outro que foi enviado e assinado pela Maria. Se os dois valores forem iguais, temos que: a mensagem não foi modificada (garantia de integridade) e a mensagem foi assinada com a chave privada da Maria (garantia de autenticidade). Logo, Maria não pode negar que enviou (garantia de irretratabilidade).



ASSINATURA

INTEGRIDADE

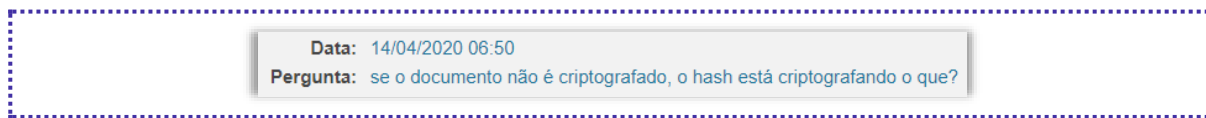
NÃO REPÚDIO

AUTENTICIDADE

Um detalhe importante: essa técnica não tem como foco a confidencialidade. A mensagem enviada não é criptografada – qualquer pessoa pode lê-la. O objetivo aqui é provar que a mensagem é legítima, original e não adulterada. E como o João sabe que foi a Maria quem assinou? Porque só a chave pública



dela consegue descriptografar algo que foi criptografado com a chave privada dela, ou seja, só pode ter sido ela – ou alguém com acesso à chave privada dela – o que já seria um problema de segurança pessoal.



Pessoal, eu recebi uma pergunta muito boa no fórum esses dias – e acho que vale a pena esclarecer com calma aqui também. Muita gente se confunde achando que o algoritmo de hash “criptografa” o documento, mas não é bem isso! Na verdade, o hash não criptografa nada – ele gera um resumo (uma impressão digital) da mensagem. E o que a gente criptografa mesmo é o hash, usando a nossa chave privada. E por que fazemos isso? Vamos imaginar um cenário:

Você precisa enviar uma mensagem para alguém, mas não se importa se outras pessoas lerem no caminho. O que você quer mesmo é garantir que a mensagem chegue exatamente como você mandou, sem alterações e que a outra pessoa saiba que foi você quem enviou. Então o que você faz? Gera o hash da sua mensagem, depois criptografa esse hash com sua chave privada e, por fim, envia a mensagem original (em texto claro) junto com o hash criptografado. Agora vamos para a prática:

Imagine que você escreveu duas cópias idênticas da mesma carta. Uma você manda em envelope comum. A outra, você guarda dentro de uma caixa de metal com cadeado – um cadeado que só você tem. Mas aqui vem o truque: a chave do cadeado está exposta publicamente. Todo mundo pode usá-la para verificar se aquele cadeado foi mesmo trancado por você. Quando a pessoa do outro lado (digamos, o João) recebe a carta normal + a caixa trancada, ele usa a chave pública para abrir a caixa e compara o conteúdo da carta dentro da caixa com a carta em texto claro.

Se as duas cartas forem iguais, significa que a mensagem não foi alterada (garantia de integridade) e só você poderia tê-la enviado, porque só sua chave privada poderia ter trancado aquela caixa (garantia de autenticidade). E se isso tudo for verdadeiro, temos ainda a irretratabilidade (ou não-repúdio): você não pode dizer depois que não foi você quem enviou. Afinal, a “tranca” (assinatura) só pode ter sido feita com a sua chave privada.

(FCC / BAHIA GÁS - 2010) Uma assinatura digital é um recurso de segurança cujo objetivo é:

- a) identificar um usuário apenas por meio de uma senha.
- b) identificar um usuário por meio de uma senha, associada a um token.
- c) garantir a autenticidade de um documento.
- d) criptografar um documento assinado eletronicamente.
- e) ser a versão eletrônica de uma cédula de identidade.

Comentários: (a) Errado. O uso de senha para identificação é um método de autenticação, não uma assinatura digital; (b) Errado. Senha e token são usados para autenticação de dois fatores, não para assinatura digital; (c) Correto. A assinatura digital garante a autenticidade, integridade e o não repúdio de um documento eletrônico, validando a autoria; (d) Errado. A assinatura digital não tem como objetivo principal criptografar documentos, embora possa ser combinada com criptografia; (e) Errado. A assinatura digital não é uma identidade eletrônica, mas sim uma evidência de autoria e integridade de uma informação (Letra C).

Algoritmos de Hash

INCIDÊNCIA EM PROVA: MÉDIA

Os algoritmos de hash são funções criptográficas fundamentais na segurança da informação, utilizadas para gerar um resumo (ou impressão digital) de dados, como senhas, arquivos e mensagens. Eles desempenham um papel crucial em processos como verificação de integridade, autenticação, assinatura



digital e armazenamento seguro de credenciais. Neste tópico, vamos conhecer os principais algoritmos de hash utilizados atualmente, entender suas características, aplicações e o motivo pelo qual alguns deles foram considerados inseguros ao longo do tempo, sendo substituídos por versões mais robustas.

MD5

O MD5 (Message Digest 5) é um algoritmo de hash criptográfico criado lá em 1991 com o objetivo de gerar uma espécie de “impressão digital” de dados, ou seja, um resumo fixo de 128 bits (16 bytes), independentemente do tamanho da informação original. Na prática, ele foi usado por muito tempo em várias situações, como: verificação de integridade de arquivos; assinaturas digitais; armazenamento de senhas (em hash); e até autenticação em sistemas.

A ideia era simples: você aplica o MD5 a uma informação e gera um hash único. Depois, ao precisar verificar se aquele conteúdo está intacto, basta gerar o hash de novo e comparar. Se bater, está tudo certo. Mas aí vieram os problemas: com o passar do tempo e o avanço dos estudos em criptografia, foram descobertas falhas sérias no MD5 – principalmente a ocorrência de colisões. E isso, em um contexto de segurança digital, é um baita problema.

Imagine duas mensagens diferentes produzindo o mesmo hash: um atacante poderia manipular arquivos ou mensagens assinadas digitalmente sem que o sistema percebesse a diferença. Isso quebra a confiança em qualquer sistema que dependa do hash para validar autenticidade ou integridade. Por conta disso, o MD5 deixou de ser recomendado para contextos que exigem segurança, como: certificação digital; autenticação de identidade; e proteção de senhas e dados sensíveis.

Hoje, algoritmos como o SHA-256 ou SHA-3 são os preferidos nessas situações, porque oferecem mais resistência a colisões e ataques de força bruta. Ainda assim, o MD5 ainda é encontrado por aí – principalmente em sistemas legados ou em situações em que a segurança não é prioridade, como: checagem rápida de arquivos baixados e comparação de dados em ambientes internos e controlados. Mas vale o alerta: mesmo nesses casos, seu uso deve ser feito com cautela, e sempre que possível, é melhor optar por alternativas mais robustas.

SHA-1

O SHA-1 (Secure Hash Algorithm 1) é um algoritmo de hash criptográfico criado pela NSA (Agência de Segurança Nacional dos EUA) em 1995. Seu objetivo era o mesmo de outros algoritmos de hash: gerar uma espécie de “impressão digital” de dados, ou seja, um resumo fixo de 160 bits (20 bytes), independentemente do tamanho da entrada original. Durante muitos anos, o SHA-1 foi o queridinho do mercado. Era amplamente utilizado em assinaturas digitais, certificados SSL/TLS (usados para segurança de sites), verificação de integridade de arquivos e também em sistemas de autenticação e protocolos de segurança.

Como todo bom algoritmo de hash, o SHA-1 seguia alguns princípios básicos: unidirecional (não dava para reverter o hash e descobrir os dados originais), determinístico (a mesma entrada sempre gerava o mesmo resultado) e – em teoria – deveria ser resistente a colisões (duas entradas diferentes não deveriam gerar o mesmo hash). Mas aí, também vieram os problemas...

A partir dos anos 2000, começaram a surgir estudos mostrando que o SHA-1 não era tão resistente a colisões assim. E em 2017, o Google quebrou oficialmente o SHA-1: eles conseguiram gerar duas entradas diferentes com o mesmo hash SHA-1. Foi a primeira colisão real e comprovada, e isso foi um divisor de águas na segurança digital. Com isso, o SHA-1 perdeu completamente a confiança em aplicações que exigem alta segurança.



Grandes empresas e organizações (Ex: NIST, Microsoft, Google, Mozilla, etc) passaram a desencorajar o uso do SHA-1 e até bloquear seu uso em navegadores e servidores. Hoje, o SHA-1 é considerado obsoleto, e o recomendado é usar versões mais seguras da mesma família, como o SHA-256 (256 bits) ou o SHA-512 (512 bits) – ambas pertencentes à família SHA-2. Ainda assim, ele pode aparecer por aí em sistemas antigos (legados) ou em situações onde a segurança não é crítica. Mas o ideal é evitar totalmente o uso do SHA-1 em qualquer contexto que envolva segurança, autenticação ou dados sensíveis.

SHA-256

O SHA-256 (Secure Hash Algorithm de 256 bits) é um dos algoritmos de hash criptográfico mais seguros e utilizados atualmente. Ele faz parte da família SHA-2 desenvolvida pela NSA (Agência de Segurança Nacional dos EUA). Como o nome já entrega, ele gera uma “impressão digital” de 256 bits (32 bytes) para qualquer entrada, não importa se é um texto curto ou um arquivo gigantesco. Essa saída é sempre do mesmo tamanho – o que torna o algoritmo ideal para verificação de integridade e autenticação.

O SHA-256 foi projetado para atender aos três pilares de uma boa função de hash: unidirecionalidade, determinismo e resistência a colisões (é extremamente difícil encontrar duas entradas diferentes que gerem o mesmo hash). Ao contrário de seus antecessores, que já foram “quebrados” com colisões comprovadas, o SHA-256 ainda é considerado seguro. Nenhuma colisão prática foi descoberta até hoje, o que o torna confiável para aplicações que exigem altíssimo nível de segurança.

Onde o SHA-256 é utilizado? Em criptomoedas, como o Bitcoin, ele é o coração da segurança da blockchain – usado para validar transações e minerar blocos. Em certificados digitais e protocolos como SSL/TLS, que protegem sites e dados online; em assinaturas digitais, garantindo que documentos e mensagens não foram alterados; e também no armazenamento seguro de senhas, principalmente quando combinado com técnicas como salting e stretching para aumentar a proteção.

Um ponto a se considerar é que o SHA-256, por ser mais robusto, demanda mais poder de processamento do que algoritmos mais antigos. Isso pode ser um fator em dispositivos com pouca capacidade de hardware, como smartwatches ou sistemas embarcados. Mas, com o avanço da tecnologia e a crescente preocupação com a segurança digital, esse custo extra vale muito a pena – e é o que tem garantido a confiança do SHA-256 em sistemas modernos.

Por fim, vale muito a pena destacar o papel fundamental do hash nas investigações criminais – especialmente quando estamos falando de evidências digitais. Em um processo judicial, qualquer tipo de arquivo digital (seja um e-mail, um log de sistema, uma imagem de disco ou um simples documento de texto) precisa ser tratado com extremo cuidado. Do contrário, corre o risco de ser descartado como prova por falta de confiabilidade.

É justamente aí que entra um conceito essencial chamado Cadeia de Custódia. Esse nome pomposo nada mais é do que uma sequência rigorosa de controle e proteção de tudo o que for coletado durante a investigação. A ideia é garantir que os materiais encontrados permaneçam intactos, sem alterações, e com um histórico claro de onde estiveram e quem os manuseou. E adivinha quem é o “guarda-costas” digital que assegura tudo isso? Exatamente: o hash.

(FEPESE / SEFAZ-SC - 2010 - ITEM C) Um elemento importante em qualquer investigação de tipo forense é a manutenção da “cadeia de custódia”, que consiste em salvaguardar a amostra (dados digitais), de forma documentada, de modo a que não se possa alegar que foi modificada ou alterada durante o processo de investigação. A garantia da integridade dos dados digitais coletados requer a utilização de ferramentas que aplicam algum tipo de algoritmo hash.



Comentários: na computação forense, a cadeia de custódia garante que os dados coletados sejam preservados de forma íntegra e verificável durante toda a investigação. Para isso, utilizam-se algoritmos de hash (como SHA-256 ou MD5), que geram um resumo criptográfico único do conteúdo original. Qualquer modificação, mesmo mínima, altera o hash, permitindo detectar adulterações (Correto).

O hash funciona como uma espécie de impressão digital da evidência. E ele começa a ser usado logo no primeiro e mais crítico passo da coleta: a criação da chamada imagem forense – que, basicamente, é uma cópia bit a bit do dispositivo original, como um HD, um celular ou até um simples pendrive.

Antes mesmo de começar essa cópia, o perito calcula o hash do dispositivo original. Depois, ele faz a cópia completa, e então calcula o hash da imagem gerada. Se os dois hashes forem idênticos, é sinal de que a cópia é perfeita – nenhum bit foi alterado no processo. Isso é fundamental para garantir que o que será analisado depois é, de fato, uma réplica exata do que foi encontrado na cena do crime.

Mas não para por aí! Nas etapas seguintes – seja na transferência da evidência, na análise dos dados ou na hora de apresentá-la no tribunal – o hash continua sendo verificado. Antes e depois de qualquer manipulação, lá está ele, servindo como prova de que ninguém alterou nada. Se alguém questionar a integridade da prova, o perito mostra os hashes: o do início e o do fim. Se batem, fim de papo.

Dá para dizer, sem exagero, que na área de forense digital e segurança da informação, o hash é como um selo de autenticidade. É ele que transforma um arquivo comum em uma evidência sólida e legalmente admissível. Sem ele – e sem algoritmos robustos como o SHA-256 – seria muito mais fácil alguém questionar a validade de uma prova, colocando toda a investigação em risco.

Controle de Acesso

INCIDÊNCIA EM PROVA: BAIXA



O Controle de Acesso é um conjunto de práticas e tecnologias que garantem que apenas usuários autorizados possam acessar sistemas, redes e informações digitais. Ele envolve processos como identificação, autenticação e autorização, permitindo que organizações protejam seus dados contra acessos não autorizados. Com o avanço da tecnologia e o aumento das ameaças cibernéticas, métodos modernos como autenticação multifator, biometria e permissões baseadas em funções têm se tornado essenciais para reforçar a segurança digital.

Identificação



A identificação é o primeiro passo de qualquer controle de acesso. É o momento em que o sistema pergunta: "Quem é você?". E aí o usuário responde, geralmente com um nome de login, CPF, número de matrícula ou e-mail – qualquer informação que funcione como um identificador único.

Mas atenção: nesse momento, o sistema ainda não sabe se a pessoa está falando a verdade. Ele só recebeu uma declaração de identidade. É como quando alguém bate na porta e diz: "Sou o João!". A pessoa pode estar falando a verdade... ou não. O sistema só anotou quem é que está tentando entrar.

Um exemplo bem comum: você entra no site do banco e digita seu usuário. Pronto, você se identificou. Agora o sistema precisa verificar se você é mesmo essa pessoa. E é aí que entra o próximo passo.

Autenticação

Depois de se identificar, vem a hora da verdade: a autenticação. É quando o sistema pergunta: "Prove que você é quem diz ser." Essa prova pode vir de várias formas: uma senha, um código enviado por SMS, uma biometria, um token físico ou digital, um smartcard, entre outros. Se a identificação é o "eu sou o fulano", a autenticação é o "então me mostre que é verdade". Esse processo pode usar: um único fator ou múltiplos fatores, como senha + impressão digital, o que chamamos de Autenticação Multifator (MFA).

O objetivo da autenticação é simples: evitar acessos indevidos. Afinal, não basta dizer que você é alguém – é preciso comprovar!

Autorização

Agora que o sistema já sabe quem você é, vem a terceira etapa: o que você pode fazer? A autorização define: quais recursos, informações ou ações você tem permissão para acessar. Em outras palavras, o que está ou não liberado para o seu perfil. Por exemplo: dois usuários entram no mesmo sistema; um pode apenas ler relatórios e o outro pode editar e excluir dados. Essa diferença existe porque cada usuário tem níveis de acesso diferentes, definidos por políticas internas, cargos, grupos ou regras de segurança.

A autorização é essencial para manter a ordem e a segurança dentro de sistemas – evita que usuários acessem ou modifiquem informações que não deveriam. Em suma, temos: Identificação (Quem está tentando acessar?), Autenticação (Essa pessoa é mesmo quem diz ser?) e Autorização (O que ela está autorizada a fazer?). Essas três etapas trabalham juntas para garantir que apenas as pessoas certas entrem no sistema – e que cada uma fique apenas no que é de sua competência.

ASPECTO	IDENTIFICAÇÃO	AUTENTICAÇÃO	AUTORIZAÇÃO
DEFINIÇÃO	Processo pelo qual um usuário se apresenta ao sistema.	Verificação de identidade do usuário para garantir que ele é quem diz ser.	Processo que define os privilégios e permissões do usuário dentro do sistema.
EXEMPLO	Nome de usuário, número de matrícula, e-mail.	Senha, biometria, autenticação em dois fatores.	Permissão para modificar configurações, acessar arquivos e executar ações.
OBJETIVO	Reconhecer quem está tentando acessar o sistema.	Garantir que a pessoa identificada é realmente quem diz ser.	Controlar o que um usuário pode ou não pode fazer dentro do sistema.
FATOR DE SEGURANÇA	Baixo – apenas identifica o usuário, sem validar sua identidade.	Médio – exige prova de identidade para garantir acesso.	Alto – limita as ações de um usuário mesmo após autenticação bem-sucedida.
MOMENTO DE USO	Primeira etapa do acesso a um sistema.	Segunda etapa, logo após a identificação.	Aplicado após autenticação bem-sucedida para restringir ou conceder acesso.



(FCC / MPE-MA - 2013) Para permitir que seja possível aplicar medidas de segurança na internet, é necessário que os serviços disponibilizados e as comunicações realizadas por este meio garantam alguns requisitos básicos, como Identificação, Autenticação e Autorização. A Autorização visa:

- a) proteger uma informação contra acesso não autorizado.
- b) proteger a informação contra alteração não autorizada.
- c) determinar as ações que a entidade pode executar.
- d) evitar que uma entidade possa negar que foi ela quem executou uma ação.
- e) garantir que um recurso esteja disponível sempre que necessário.

Comentários: (a) Errado. Proteger contra acesso não autorizado está relacionado à confidencialidade, não à autorização; (b) Errado. Proteger contra alterações não autorizadas refere-se à integridade, não à autorização; (c) Correto. Autorização é o processo que determina quais ações um usuário ou entidade pode executar após ter sido autenticado; (d) Errado. Impedir a negação de autoria de uma ação é atribuição do não repúdio, não da autorização; (e) Errado. Garantir acesso contínuo está relacionado à disponibilidade, e não à autorização (Letra C).

Classificação de Dados

A classificação de dados é o processo de identificar, categorizar e rotular informações de acordo com o seu nível de sensibilidade, criticidade e impacto para a organização. Seu objetivo é determinar quais dados precisam de maior proteção, definindo controles adequados de acesso, armazenamento, transmissão e descarte. Ao classificar os dados, a organização consegue aplicar medidas de segurança proporcionais ao risco, evitando tanto a exposição indevida de informações sensíveis quanto o uso excessivo de controles em dados de baixo valor.

A classificação normalmente considera critérios como confidencialidade, integridade e disponibilidade, alinhados aos princípios da tríade CID. Com base nesses critérios, os dados são organizados em níveis, como público, interno, confidencial e restrito (ou equivalentes), sendo que cada nível impõe regras específicas sobre quem pode acessar a informação, como ela pode ser compartilhada e quais mecanismos de proteção devem ser utilizados, como criptografia, controle de acesso e auditoria.

Além de apoiar a proteção técnica, a classificação de dados possui forte dimensão organizacional e normativa, pois orienta políticas internas, treinamentos, conformidade legal e resposta a incidentes. Em ambientes regulados, como aqueles sujeitos à LGPD, à ISO/IEC 27001 ou a normas setoriais, a classificação é fundamental para demonstrar governança da informação e responsabilidade no tratamento de dados, reduzindo riscos operacionais, legais e reputacionais.

NÍVEIS	DESCRIÇÃO	EXEMPLOS	CONTROLES DE SEGURANÇA TÍPICOS
PÚBLICO	Informações destinadas à divulgação externa, cujo acesso irrestrito não causa prejuízo à organização ou aos titulares dos dados.	Conteúdo institucional em sites, comunicados oficiais, material publicitário.	Acesso livre, integridade básica, controle de versão e backups simples.
INTERNO	Dados de uso exclusivo da organização, cujo vazamento pode causar impactos operacionais moderados, mas sem danos críticos.	Procedimentos internos, organogramas, manuais operacionais, relatórios não estratégicos.	Controle de acesso interno, autenticação de usuários, políticas de uso aceitável.



CONFIDENCIAL	Informações sensíveis que, se divulgadas sem autorização, podem gerar prejuízos financeiros, legais ou à imagem da organização.	Dados pessoais, contratos, relatórios financeiros, dados de clientes e fornecedores.	Controle de acesso restrito, criptografia, registro de logs, monitoramento e classificação explícita.
RESTRITO	Informações altamente sensíveis e críticas, cujo acesso indevido pode causar danos graves ou irreversíveis à organização ou aos titulares.	Segredos industriais, chaves criptográficas, dados estratégicos, informações de segurança.	Acesso mínimo necessário, criptografia forte, segregação de ambientes, auditoria contínua e controles rígidos.



Certificado Digital

Conceitos Básicos

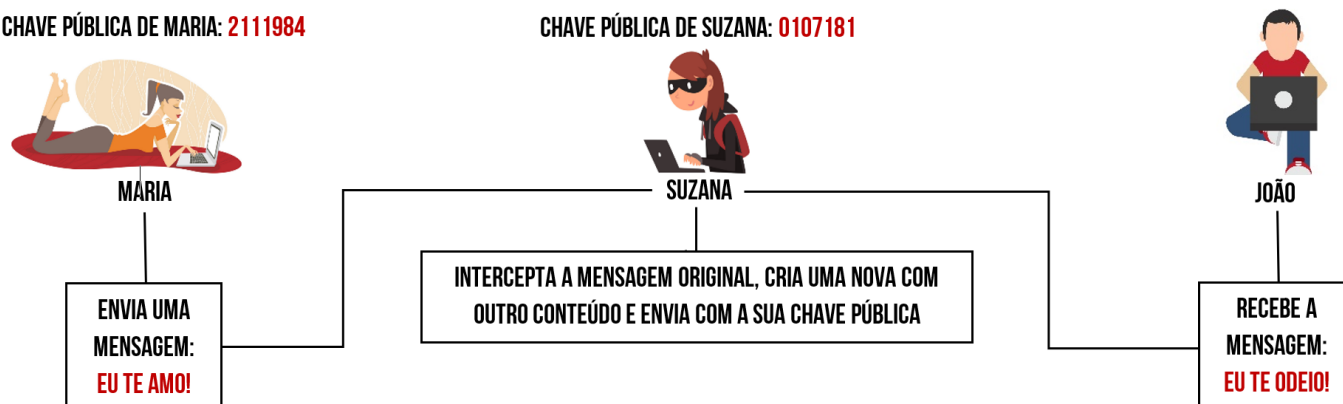
INCIDÊNCIA EM PROVA: ALTÍSSIMA

Foi legal estudar Assinatura Digital, mas ela tem um problema grave! Nós falamos que – se Maria quisesse enviar uma mensagem para João – ela deveria criptografá-la com a sua chave privada. Entende-se, portanto, que a chave pública de Maria esteja divulgada em algum lugar para que possa ser encontrada por qualquer pessoa ou que Maria tenha enviado de alguma forma a sua chave pública para o João.

No entanto, Suzana poderia interceptar a mensagem de Maria para João. Ela poderia jogar mensagem original fora, criar uma nova mensagem com um recado diferente, criptografá-la com a sua chave privada e enviá-la junto com a sua chave pública para João. Quando João recebesse a mensagem, ele utilizaria a chave pública recebida (de Suzana) para descriptografar a mensagem e acharia que se tratava realmente de uma mensagem de Maria.

CHAVE PÚBLICA DE MARIA: 2111984

CHAVE PÚBLICA DE SUZANA: 0107181



É como se você criasse uma corrente em uma rede social pedindo doações para ajudar alguém que esteja precisando de um tratamento de saúde. No entanto, em vez de publicar o número da conta corrente dessa pessoa, você publicasse o seu número de conta corrente. Isso significa que a Assinatura Digital possui uma autenticação relativamente frágil, porque não é possível saber se a chave pública que foi utilizada é realmente de quem diz ser.

Notem que João utilizou a chave pública recebida (que ele pensava ser de Maria, mas era de Suzana) e conseguiu descriptografar a mensagem. Coitado, ele acreditou que tinha sido Maria que havia enviado e agora acha que ela o odeia! Legal, mas agora chegamos em um impasse! *Como eu vou confiar na chave pública de alguém agora, Diego?* Para resolver esse problema, é necessária uma terceira parte confiável chamada Autoridade Certificadora (AC).

A Autoridade Certificadora é uma entidade responsável por emitir certificados digitais – ela é uma espécie de Cartório Digital. Antes da existência de cartórios, existiam muitas fraudes porque contratos eram fraudados utilizando uma cópia assinatura do contratante. Foi necessária a criação de um cartório – uma terceira parte confiável – que armazenava a assinatura de várias pessoas. Se alguém quisesse confirmar essa assinatura, bastava ir a um cartório.

Um contrato de locação, por exemplo, possui a assinatura do locatário, locador e fiador. Cada um desses tem que ir ao cartório reconhecer firma – criada anteriormente. *Quem nunca fez isso?* Você vai ao cartório, mostra o contrato assinado e assina na frente do tabelião ou do registrador. Dessa forma, você atesta a autoria da assinatura que consta em um documento. *É meio frágil, vocês concordam comigo?*



A Autoridade Certificadora faz algo similar: ela mantém documentos chamados Certificados Digitais. Esse documento contém o nome, registro civil e chave pública do dono do certificado, a data de validade, versão e número de série do certificado, o nome e a assinatura digital da autoridade certificadora, algoritmo de criptografia utilizado, etc. A Autoridade Certificadora é responsável por emitir, distribuir, renovar, revogar e gerenciar certificados digitais.

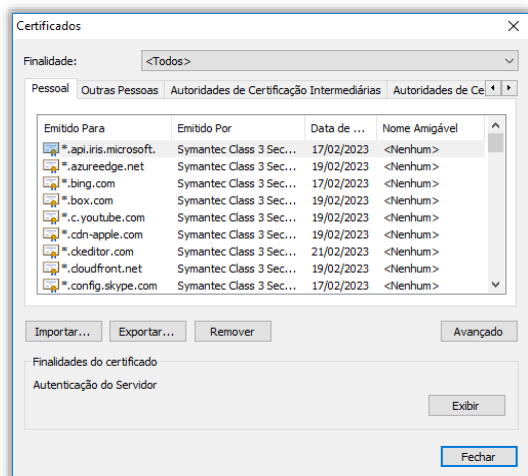
Para que uma Autoridade Certificadora também seja confiável, sua chave pública deve ser amplamente difundida de tal modo que todos possam conhecer e atestar a sua assinatura digital nos certificados gerados, o que dificulta possíveis fraudes. Vamos pensar no nosso dia-a-dia agora! *Vocês estão vendo aquele cadeado no canto esquerdo da Barra de Endereço? Pois é... o que será que significa esse cadeado?*



Esse cadeado significa que essa página web fornece um serviço possivelmente crítico em que trafegam informações sigilosas, portanto ela oferece um canal de comunicação criptografado e seguro. No caso, trata-se da utilização do protocolo HTTPS, que é uma implementação do protocolo HTTP sobre uma camada adicional de segurança que utiliza o protocolo SSL/TLS (Secure Sockets Layer / Transport Layer Security).

Essa camada adicional de segurança permite que os dados possam ser transmitidos por meio de uma conexão criptografada/segura e que se verifique a autenticidade do servidor web por meio do uso de certificados digitais (é a autenticidade do servidor e, não, do cliente). Nesse caso específico, o seu navegador precisa ter garantias de que ele está trocando informações com o banco e não com outra página web se passando pelo banco. *Bacana?*

Para tal, a página do banco envia seu certificado digital, que contém seu algoritmo de criptografia, sua chave pública e a assinatura da autoridade certificadora que emitiu seu certificado. O seu navegador web possui uma lista de certificados confiáveis conforme é apresentado na imagem abaixo. No caso do Google Chrome, essa lista fica em Configurações > Privacidade e Segurança > Gerenciar Certificados.

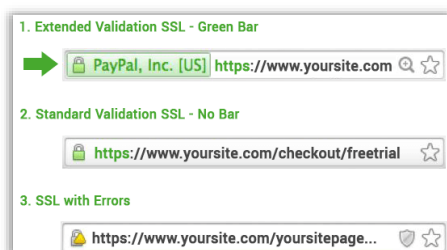


O navegador verifica se a autoridade certificadora que assinou seu certificado é uma das autoridades certificadoras cadastradas. Se realmente for, isso significa que o navegador pode confiar que o banco é legítimo e autêntico e aparecerá o cadeado (em alguns casos, verde) mostrando que a comunicação é segura.

Em algumas situações, você tentará utilizar um site cujo certificado não é confiável e o navegador informará sobre esse risco você poderá assumir o risco de acessar assim mesmo ou não. Uma Autoridade Certificadora é também responsável por publicar informações sobre certificados que não são mais confiáveis.



Sempre que ela descobre ou é informada de que um certificado não é mais confiável, ela o inclui em uma "Lista Negra", chamada de Lista de Certificados Revogados (LCR). A LCR é um arquivo eletrônico publicado periodicamente pela Autoridade Certificadora, contendo o número de série dos certificados que não são mais válidos e a data de revogação. Quando isso ocorre, geralmente aparece a mensagem abaixo ao tentar acessar um site.



Por fim, falemos sobre EV-SSL (Extended Validation)! Eles são tipos especiais de certificados digitais X.509 que requerem algumas exigências a mais de segurança para serem emitidos, tais como recursos visuais na barra de endereço do navegador. *Quem nunca viu uma barrinha verde ao lado do endereço?* Isso significa que não se trata de um certificado comum, mas de um certificado EV-SSL - que possui uma segurança maior!

Eu recebo frequentemente algumas perguntas no fórum de dúvidas, logo vamos saná-las de uma vez por todas. A primeira é sobre a diferença entre assinatura digital e certificado digital:

ASPECTO	ASSINATURA DIGITAL	CERTIFICADO DIGITAL
DEFINIÇÃO	Método matemática de autenticação que garante a integridade e autenticidade de uma entidade.	<u>Documento eletrônico</u> assinado digitalmente que vincula uma chave pública a uma entidade.
OBJETIVO	Validar a autoria e garantir que o documento não foi alterado após a assinatura.	Identificar e autenticar digitalmente um usuário ou entidade.
USO	Assinar contratos, documentos e transações digitais com validade jurídica.	Emitir assinaturas digitais, acessar sistemas seguros e realizar transações online.
DEPENDÊNCIA	Necessita de um certificado digital para ser gerada.	Emitido por uma Autoridade Certificadora e usado para autenticação e assinatura digital.
SEGURANÇA	Utiliza criptografia para garantir que o documento não seja alterado após a assinatura.	Contém chaves criptográficas que garantem a identidade do titular e a segurança das transações.



VALIDADE JURÍDICA

Possui validade jurídica quando vinculada a um certificado digital reconhecido.

Tem validade jurídica e pode ser usado para autenticação em serviços governamentais e empresariais.

Outra dúvida que sempre aparece é: “Professor, a chave privada fica dentro do certificado digital?” E a resposta é: não! O certificado digital é um documento eletrônico público, ou seja, qualquer sistema pode acessá-lo para verificar a autenticidade de uma assinatura, por exemplo. Como ele é público, jamais poderia conter a chave privada, que é justamente a parte que precisa ser mantida em segredo absoluto. Então, onde fica essa chave privada?



Ela pode estar armazenada em três lugares: no computador do usuário (menos seguro); em um token USB (mais seguro); ou em um smartcard (tipo um cartão com chip). Agora vem a parte que confunde: quando você usa um token, ele geralmente armazena tanto o certificado digital quanto a chave privada. Mas, atenção: o certificado é público, e a chave privada está guardada dentro do token de forma segura, protegida por uma senha de acesso.

E aí vem outra pergunta clássica: “Preciso decorar a chave privada?” Não, gente! A chave privada é uma sequência enorme e complexa – impossível de ser memorizada. O que você precisa lembrar é apenas a senha do token ou do dispositivo. É essa senha que libera o uso da chave privada para assinar digitalmente ou acessar sistemas seguros. Vejamos um exemplo de chave privada:

-----BEGIN PRIVATE KEY-----

```
MDJKoZlAQMCAhvcNAQEBBQADKgapAwDXcZ30BJwlgYjDE7cZ83S03QZZSfTiwwXqBezabQsJjQVZ1h5MCfTiww  
lgYAwEAAQ==XVOAoZlhvcNgEAAiBimNdWkSETIbtxnzc7dBlICNBvj9qTgjQVwjSEgwEgjQVZSjQzc7dBlipLS  
fh5pLBjSMiG0dWCA1aQVZgYCA1ghvcNAQEBYjDXVMINjDXVcNADKgAvXqBezSfTiwwKAQEBBQDQY5MCbtxnCKo  
ZkBjSE7cZMoZlhVVjQVZSvj9qTgjQzc7BKgAwDwEgjQVZSjSE7cZMZlhvcNggjQV03QZoZIAAwEAAQEBBAiBiZ  
83Se1
```

-----END PRIVATE KEY-----

(FAURGS / TJ-RS - 2013) Assinale a alternativa que apresenta um dos dados presentes em um certificado digital.

- a) Chave privada de criptografia do dono do certificado.
- b) Chave única da entidade certificadora raiz.
- c) Chave privada de criptografia do emissor do certificado.
- d) Chave pública de criptografia do emissor do certificado.
- e) Chave pública de criptografia do dono do certificado.

Comentários: (a) Errado. A chave privada do dono do certificado nunca é incluída no certificado digital, pois deve ser mantida em sigilo absoluto; (b) Errado. A chave única da autoridade certificadora raiz não é incluída nos certificados que ela emite, mas sim armazenada separadamente; (c) Errado. A chave privada do emissor também não é incluída no certificado, pois é usada para assinar digitalmente o certificado; (d) Errado. A chave pública do emissor pode estar no certificado da própria autoridade certificadora, mas não no certificado do usuário final; (e) Correto. O certificado digital contém a chave pública do dono do certificado, associada à sua identidade, para que outros possam verificar assinaturas feitas com a chave privada correspondente. (Letra E).



Infraestrutura de Chave Pública (ICP-Brasil)

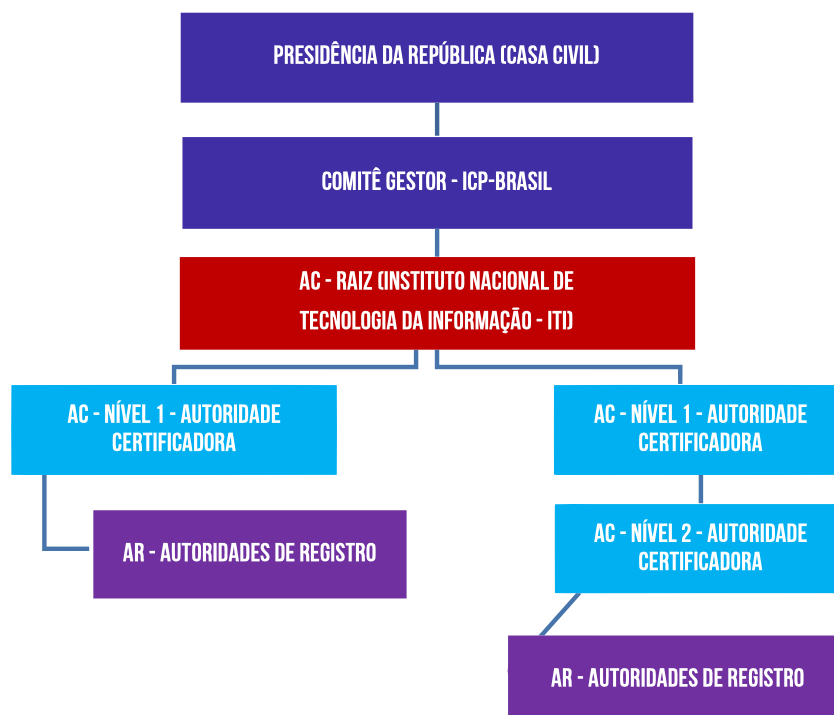
INCIDÊNCIA EM PROVA: MÉDIA

Nós vimos que uma Autoridade Certificadora é responsável por – entre outras atividades – emitir certificados digitais. No entanto, nós vimos que ela também possui um certificado digital contendo sua chave pública. E quem emite o certificado digital para essa Autoridade Certificadora? Pois é, nós precisamos de outra parte confiável! Para tal, existem as Infraestruturas de Chave Pública⁷ (ICP). O que é isso, Diego?

Trata-se de uma entidade pública ou privada que tem como objetivo manter uma estrutura de emissão de chaves públicas, baseando-se no princípio da terceira parte confiável e oferecendo uma mediação de credibilidade e confiança em transações entre partes que utilizem certificados digitais. O Certificado Digital funcionará como uma identidade virtual que permite a identificação segura e inequívoca do autor de uma mensagem ou transação.

A ICP também pode ser definida como um conjunto de técnicas, práticas, arquitetura, organização e procedimentos implementados pelas organizações públicas e privadas que suportam, em conjunto, a implementação e a operação de um sistema de certificação. Ela busca estabelecer fundamentos técnicos e metodológicos baseado em criptografia de chave pública, para garantir a autenticidade, a integridade e a validade jurídica. A ICP brasileira é denominada ICP-Brasil!

Nesta infraestrutura, há duas entidades: Autoridades Certificadoras e Autoridades de Registro, que emitem e vendem certificados digitais respectivamente. Vejam a cadeia de certificação:



Sabe quando vamos tirar a carteira de identidade? Pois é, a maioria das pessoas procura a Secretaria de Segurança Pública (SSP), que é responsável por expedir um documento oficial de identificação atestando quem você realmente é – seria análogo a uma Autoridade Certificadora de Nível 1. Ela está subordinada

⁷ Em inglês, *Public Key Infrastructure* (PKI).



ao Ministério da Justiça, análogo a Autoridade Certificadora Raiz. Já o Instituto de Identificação da SSP seria a Autoridade de Registro.



▪ **Autoridade Certificadora Raiz**

Trata-se da primeira autoridade da cadeia de certificação. Ela é responsável por executar as políticas de certificados e as normas técnicas e operacionais aprovadas pelo Comitê Gestor da ICP-Brasil. Dessa forma, compete à AC-Raiz emitir, expedir, distribuir, revogar e gerenciar os certificados das autoridades certificadoras de nível imediatamente subsequente ao seu – isso costuma cair em prova.

A AC-Raiz também está encarregada de emitir a Lista de Certificados Revogados (LCR) e de fiscalizar e auditar as Autoridades Certificadoras – ACs, Autoridades de Registro – ARs e demais prestadores de serviço habilitados na ICP-Brasil. Além disso, ela é responsável por verificar se as ACs estão atuando em conformidade com as diretrizes e normas técnicas estabelecidas pelo Comitê Gestor da ICP-Brasil.

▪ **Autoridade Certificadora**

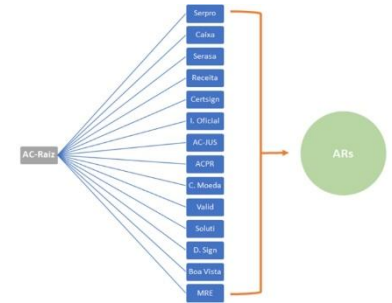
Trata-se de uma entidade, pública ou privada, subordinada à hierarquia da ICP-Brasil, responsável por emitir, distribuir, renovar, revogar e gerenciar certificados digitais. Busca verificar se o titular do certificado possui a chave privada que corresponde à chave pública do certificado. Ela cria e assina digitalmente o certificado do assinante, onde o certificado emitido pela AC representa a declaração da identidade do titular, que possui um par único de chaves.

Cabe também à Autoridade Certificadora emitir Listas de Certificados Revogados (LCR) e manter registros de suas operações sempre obedecendo às práticas definidas na Declaração de Práticas de Certificação – DPC. Além de estabelecer e fazer cumprir, pelas Autoridades de Registro – ARs a ela vinculadas, as políticas de segurança necessárias para garantir a autenticidade da identificação realizada.

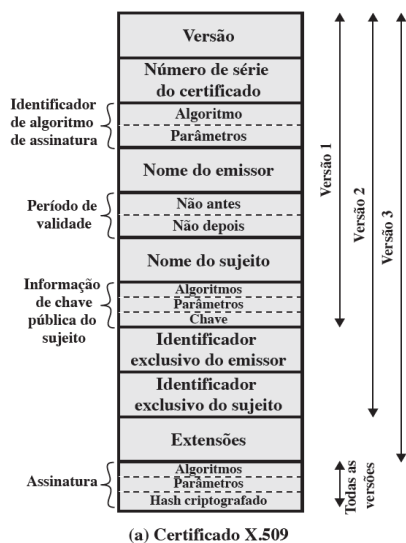
▪ **Autoridade de Registro**



Trata-se de uma entidade responsável pela interface entre o usuário e a Autoridade Certificadora. Vinculada a uma AC, tem por objetivo o recebimento, a validação, o encaminhamento de solicitações de emissão ou revogação de certificados digitais e identificação, de forma presencial, de seus solicitantes. É responsabilidade da AR manter registros de suas operações. Pode estar fisicamente localizada em uma AC ou ser uma entidade de registro remota. A imagem ao lado mostra um exemplo de organização.



Em suma: a Autoridade Certificadora Raiz emite certificados digitais para as Autoridades Certificadoras hierarquicamente abaixo dela, que emitem certificados para equipamentos, pessoas físicas ou jurídicas. As Autoridades de Registro não emitem certificados digitais. Elas o recebem, validam ou encaminham e guardam um registro dessas operações. *Quem emite certificado para pessoas físicas?* Apenas a Autoridade Certificadora!



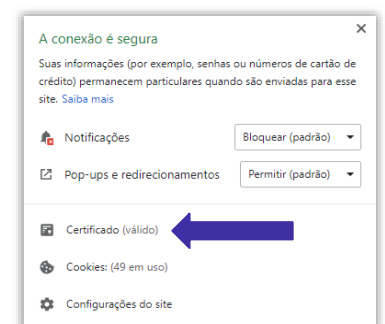
É importante ressaltar que existe um padrão para Infraestrutura de Chaves Públicas! O Padrão X.509 (Versão 3) especifica, entre outras coisas, o formato dos certificados digitais, de tal maneira que se possa amarrar firmemente um nome a uma chave pública – esse é o padrão utilizado pela ICP-Brasil! *Professor, quais campos existem dentro de um certificado digital?* Existem diversos campos, sendo que nem todos são obrigatórios.

Os campos são: versão, número de série, tipo de algoritmo, nome do algoritmo, nome do titular, nome do emissor, data de validade, chave pública, assinatura da autoridade certificadora, identificador da chave do titular, identificador da chave do emissor, além de diversos atributos ou extensões - vocês não precisam se preocupar em decorar esses campos. *Você quer ver um certificado digital?* Vou mostrar como você pode acessá-lo...

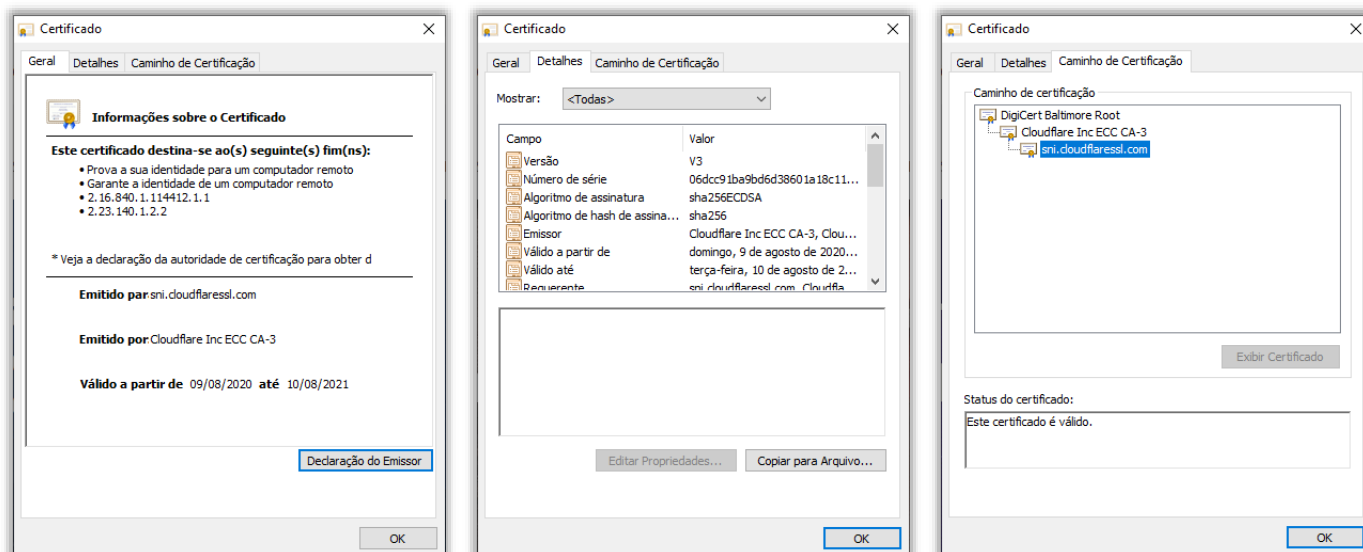
Abra o seu navegador favorito (Ex: Chrome, Edge, Firefox) e acesse na barra de endereços alguma página web via HTTPS.

Por exemplo: <https://www.estrategiaconcursos.com.br>

Em seguida, clique no cadeado à esquerda da barra de endereços e, logo depois, clique em Certificado. Um certificado digital será exibido em uma nova janela conforme podemos ver na imagem seguinte! Nunca se esqueçam de que o certificado digital é um documento/arquivo!



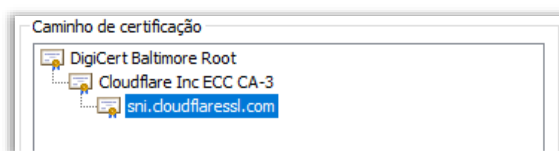
Vocês se lembram das informações contidas em um certificado digital? Uma informação muito importante anexada ao certificado era a assinatura da autoridade certificadora que o emitiu. Quando uma autoridade certificadora vai emitir um certificado digital, ela gera um hash de todas as informações do certificado e o assina com a sua chave privada. Dessa forma, todos que receberem o certificado digital poderão verificar sua autenticidade. *Como, professor?*



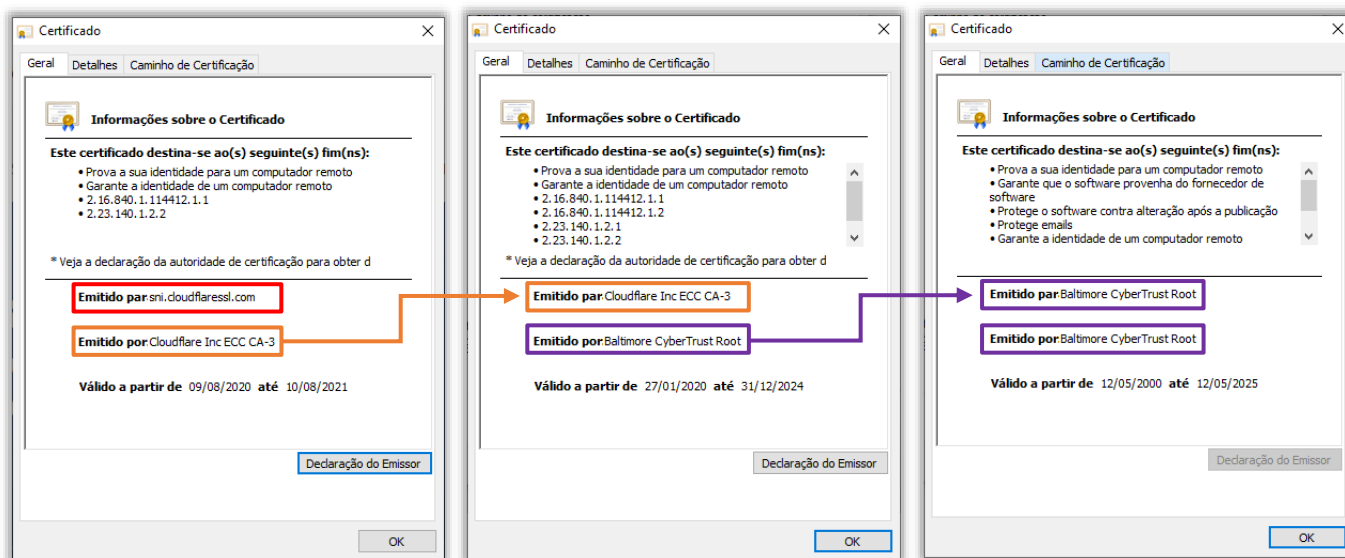
A entidade que recebeu o certificado terá em mãos o próprio certificado e seu hash anexado. Logo, ela poderá utilizar a chave pública da autoridade certificadora que emitiu o certificado para descriptografar seu hash. Em seguida, ela poderá gerar um novo hash das informações do certificado digital e comparar com o hash anexado. Se os hashes forem idênticos, significa que o certificado não foi alterado e que é confiável.

Outro conceito importante apresentado nas imagens acima é o Caminho de Certificação. *Galera, vocês se lembram que uma infraestrutura de chave pública é uma estrutura hierarquizada?* Pois é, essa hierarquia cria um caminho de certificação quando uma autoridade certificadora raiz emite um certificado com sua assinatura digital para uma ou mais autoridades certificadoras intermediárias; e uma dessas emite um certificado com a sua assinatura digital para uma entidade qualquer!

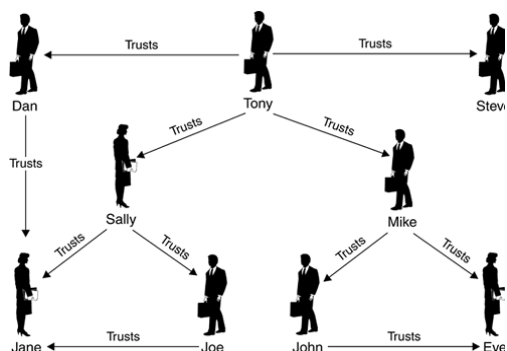
Professor, e quem é que assina o certificado da autoridade certificadora raiz? Ela mesma! Nesse caso, dizemos que se trata de um certificado autoassinado.



Acima nós temos o caminho de certificação do certificado da página do Estratégia Concursos. Observem a seguir que ele foi emitido para **sni.cloudflaressl.com** (que é o endereço do servidor onde a página está hospedada) e foi emitido/assinado por **Cloudflare Inc ECC CA-3** (AC intermediária). Já o certificado digital da **Cloudflare Inc ECC CA-3** foi emitido pela **Baltimore CyberTrust Root** (AC Raiz), que - no caso - emite/assina seu próprio certificado digital.



A infraestrutura de chave pública é uma abordagem interessante, mas ela é bastante hierárquica e centralizada. *E isso é um problema?* Pode ser! É possível ocorrer uma falha, vazamento ou corrupção na autoridade certificadora raiz, por exemplo. Logo, essa infraestrutura pode ser bastante vulnerável – um problema grave pode colocar em risco toda a infraestrutura. Dito isso, surgiu uma abordagem chamada Cadeia/Teia de Confiança (Web of Trust – WoT).



O que seria isso, Diego? Trata-se de um modelo de confiança transitiva e descentralizada que busca disponibilizar criptografia para o público geral sem custos em contrapartida à abordagem de infraestrutura de chave pública. E como isso funciona, professor? A confiança vai sendo estabelecida através de uma rede de transitividade em que, se Tony confia em Mike e Mike confia em John, então Tony confia em John. Essa rede é construída por meio de uma relação pessoal indivíduos através da assinatura de chave pública de um usuário pelo outro e assim sucessivamente.

Essas etapas acabam por gerar um laço de confiança que se converte, então, em uma rede, teia ou cadeia de confiança. Dito isso, é importante fazer essa distinção: em uma infraestrutura de chave pública, todo certificado deve necessariamente ser assinado por uma autoridade certificadora. Já em uma cadeia/teia de certificados, qualquer entidade pode assinar e atestar a validade de outros certificados. Ela é – portanto – descentralizada e não hierárquica.

(CEBRASPE / MEC - 2011) Um certificado digital consiste na cifração do resumo criptográfico de uma chave pública com a chave privada de uma autoridade certificadora.

Comentários: sendo rigoroso, um certificado digital consiste na cifração do resumo criptográfico de todas as informações que abrangem o certificado digital e não apenas a chave pública – ignorando esse deslize, não há erros na questão (Correto).

(CEBRASPE / SERPRO - 2013) Um certificado digital consiste na cifração do resumo criptográfico de uma chave pública com a utilização da chave privada de uma autoridade certificadora.



Comentários: sendo rigoroso, um certificado digital consiste na cifração do resumo criptográfico de todas as informações que abrangem o certificado digital e não apenas a chave pública - ignorando esse deslize, não há erros na questão (Correto).

(CONSULPLAN / TRF/2 - 2017) *"O certificado digital ICP-Brasil funciona como uma identidade virtual que permite a identificação segura e inequívoca do autor de uma mensagem ou transação feita em meios eletrônicos, como a web".*

(Sítio do Instituto Nacional de Tecnologia da Informação. Disponível em: <http://www.iti.gov.br/certificacao-digital/o-que-e>).

Referente à certificação digital, assinale a alternativa correta.

- a) A Autoridade Certificadora Raiz é quem emite os certificados para o usuário final.
- b) A criptografia simétrica utiliza duas chaves distintas: chave privada e chave pública.
- c) A Autoridade Certificadora é a primeira autoridade da cadeia de certificação da ICP-Brasil.
- d) O Instituto Nacional de Tecnologia da Informação é a Autoridade Certificadora Raiz da Infra-Estrutura de Chaves Públicas Brasileira.

Comentários: (a) Errado, Autoridade Certificadora Raiz emite certificados para Autoridades Certificadores hierarquicamente abaixo; (b) Errado, essa é a Criptografia Assimétrica; (c) Errado, essa é a Autoridade Certificadora Raiz; (d) Correto, ITI é a AC-Raiz do ICP-Brasil (Letra D).



Tipos de Certificado

INCIDÊNCIA EM PROVA: MÉDIA

Os certificados digitais da Categoria A costumam ser usados para fins de identificação e autenticação. Você pode usá-los para assinar documentos ou validar transações eletrônicas. Já a Categoria S é direcionada a atividades sigilosas, como a proteção de arquivos confidenciais.

- **Certificado de Assinatura Digital (A):** reúne os certificados de assinatura digital, utilizados na confirmação de identidade na web, em e-mails, em Redes Privadas Virtuais (VPNs) e em documentos eletrônicos com verificação da integridade das informações.
- **Certificado de Sigilo (S):** reúne os certificados de sigilo, que são utilizados na codificação de documentos, de bases de dados relacionais, de mensagens e de outras informações eletrônicas sigilosas.

TIPO	GERAÇÃO DO PAR DE CHAVES	TAMANHO DA CHAVE (BITS)	ARMAZENAMENTO	VALIDADE MÁXIMA (ANOS)
CERTIFICADO A1/S1	Por software	Mínimo RSA 2048	Disco Rígido (HD) e Pendrive	1
CERTIFICADO A2/S2	Por software	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	2
CERTIFICADO A3/S3	Por hardware	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	5
CERTIFICADO A4/S4	Por hardware	Mínimo RSA 2048	Módulo de Segurança Criptográfica (HSM)	6

É muito comum surgir dúvida em relação ao certificado A3 porque, na prática comercial do dia a dia, as Autoridades Certificadoras (ACs) brasileiras costumam vender certificados A3 com validade de apenas 1 a 3 anos. Isso ocorre por decisões puramente comerciais e de gestão de risco das empresas que vendem os certificados. No entanto, do ponto de vista normativo (que é o que costuma ser cobrado em questões de provas, concursos e auditorias), o limite máximo estipulado pela ICP-Brasil para o A3 é de fato 5 anos.

(FGV / AMAZUL - 2026) Os certificados digitais no padrão ICP-Brasil são classificados em diferentes tipos, sendo os mais comuns o A1 e o A3. Cada tipo possui características específicas quanto ao seu armazenamento e nível de segurança. A principal diferença prática entre um certificado tipo A1 e um tipo A3 reside no local onde a chave privada é gerada e armazenada.

Assinale a opção que descreve corretamente o armazenamento e a validade típicos do certificado digital tipo A3.

- a) É armazenado diretamente no navegador web do computador ou em um arquivo no disco rígido, com validade máxima de 12 meses.
- b) É armazenado em um dispositivo físico seguro e inviolável, como um smart card (cartão inteligente) ou token USB, com validade de 12 ou 36 meses.
- c) É um certificado de software que oferece o menor nível de segurança, sendo ideal para transações de baixo risco e com validade de até 5 anos.



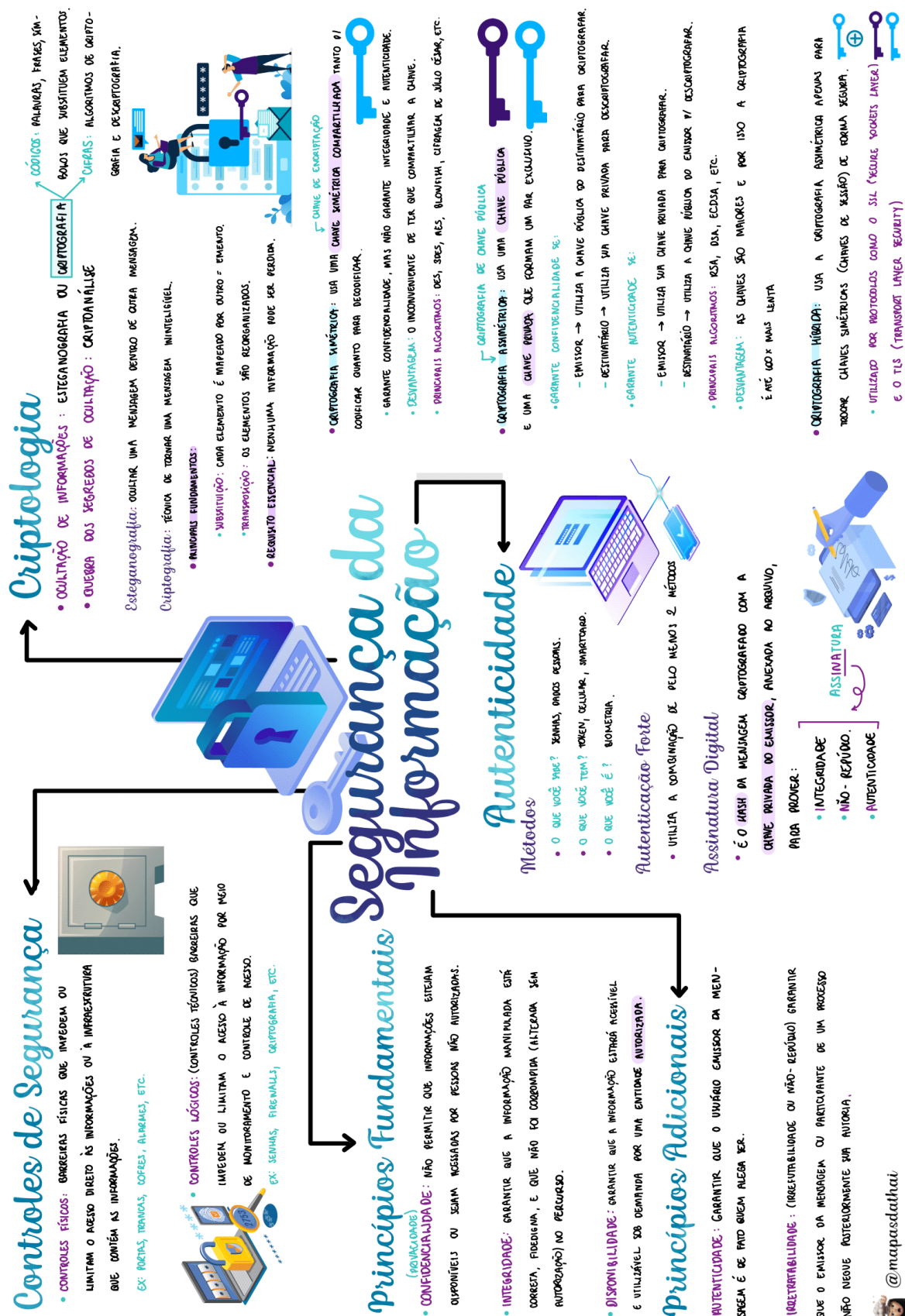
d) É um certificado exclusivo para servidores web (SSL/TLS), garantindo a segurança de sites, e não pode ser usado para assinar documentos pessoais.

e) É um tipo de certificado em nuvem (cloud), que dispensa o uso de hardware específico e possui validade indeterminada.

Comentários: (a) Errado. Descreve o certificado A1, cuja chave privada é armazenada em arquivo no computador, com validade geralmente de até 1 ano; (b) Correto. O certificado A3 tem a chave privada gerada e armazenada em dispositivo criptográfico, como token USB ou smart card, com validade típica de 1 a 3 anos (12 ou 36 meses); (c) Errado. O A3 oferece alto nível de segurança por utilizar hardware criptográfico e não é destinado apenas a transações de baixo risco; (d) Errado. Certificados SSL/TLS para servidores possuem finalidade específica e não correspondem ao certificado A3 de pessoa física ou jurídica; (e) Errado. Certificados em nuvem possuem características próprias e não definem o padrão A3, além de não terem validade indeterminada (Letra B).



MAPA MENTAL



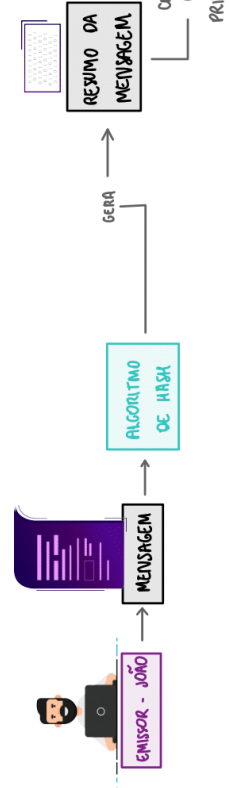
@mapasdathai

Algoritmo de Hash

- ALGORITMO CRIPTOGRÁFICO QUE TRANSFORMA UMA ENTRADA DE DADOS DE QUALQUER TAMANHO EM UMA SAÍDA DE DADOS DE TAMANHO FIXO.
- UMA BOA FUNÇÃO DE HASH NÃO PERMITE QUE SE DESCOBRAM OS DADOS DE ENTRADA PELA ANÁLISE DOS DADOS DA SAÍDA.
- DIFERENTES ENTRADAS PODERAM GERAR A MESMA SAÍDA → COLISÃO.
- O RISCO DE COLISÃO → AUMENTA-SE O TAMANHO FIXO DE SAÍDA (PELO MENOS 128 BITS).
- USAR CHAVES ASSIMÉTRICAS: O EMISSOR USA SUA CHAVE PRIVADA P/ ENCRYPTAR E O RECEPTOR USA A CHAVE PÚBLICA DO EMISSOR P/ DECRYPTAR O HASH.

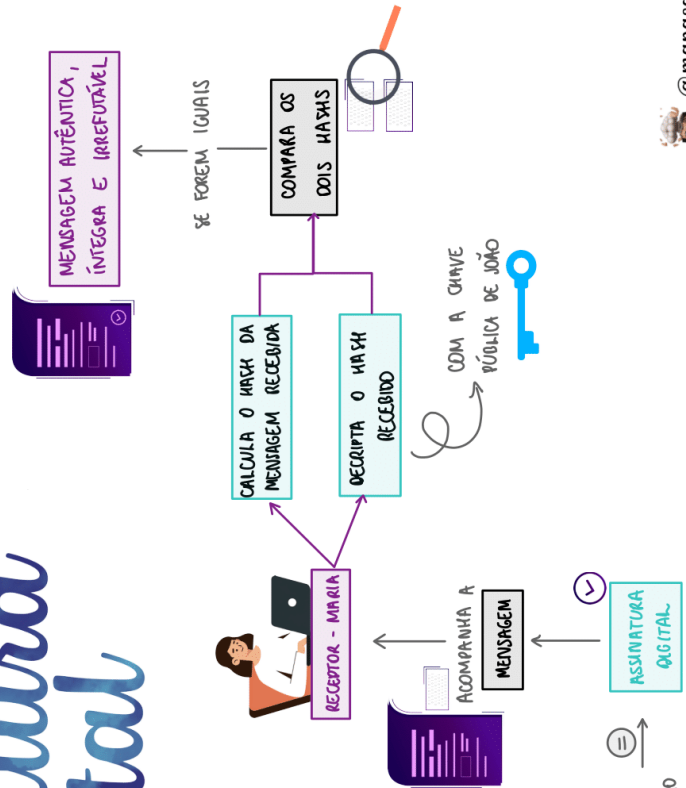
Passo a Passo do Algoritmo de Hash ← Assinatura Digital

1. MENSAGEM É ESCRITA PELO EMISSOR;
2. CÁLCULO DO HASH DA MENSAGEM P/ GARANTIR INTEGRIDADE;
3. HASH ENCRYPTADO (COM A CHAVE PRIVADA DO EMISSOR) = ASSINATURA DIGITAL;
4. MENSAGEM ASSINADA DIGITALMENTE É TRANSMITIDA POR UM CANAL DE COMUNICAÇÃO;
5. MENSAGEM RECEBIDA E LEGÍVEL (NÃO HÁ CONFIDENCIALIDADE);
6. HASH DECRYPTADO (COM A CHAVE PÚBLICA DO EMISSOR);
7. CÁLCULO DO HASH DA MENSAGEM RECEBIDA;
8. HASH DECRYPTADO CONFRONTADO COM O HASH DA MENSAGEM RECEBIDA PARA VERIFICAÇÃO DE INTEGRIDADE;
9. SE OS HASHS FÖREM IGUAIS → MENSAGEM AUTÊNTICA, ÍNTEGRA E IRREFUTÁVEL.



Observações Gerais

- GARANTE:**
 - INTEGRIDADE: UTILIZANDO O ALGORITMO DE HASH;
 - NÃO-REPÚDIO: COMBINANDO INTEGRIDADE E AUTENTICIDADE;
 - AUTENTICIDADE: CRIPTOGRAFANDO COM A CHAVE PRIVADA.
- NÃO GARANTE CONFIDENCIALIDADE!**
 - NÃO CRIPTOGRAFA O CONTEÚDO DA MENSAGEM
- PRINCIPAIS ALGORITMOS:** SHA-1 (HASH DE 160bits), MD5 (HASH DE 128bits), ETC.

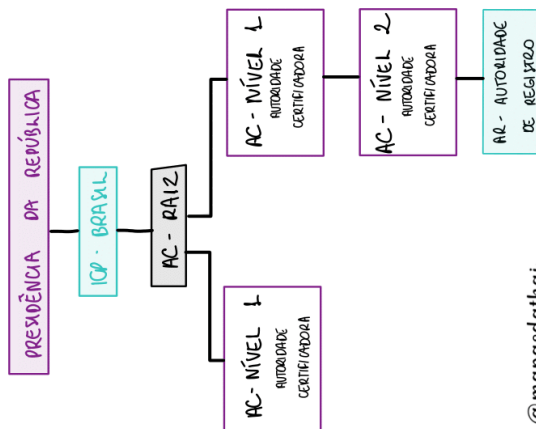


Conceito

- DOCUMENTO ELETRÔNICO ASSINADO DIGITALMENTE POR UMA TERCEIRA PARTE CONFIÁVEL (AUTORIDADE CERTIFICADORA) E QUE CUMPRE A FUNÇÃO DE ASSOCIAR UMA ENTIDADE (PESSOA, PROCESSO, SERVIDOR, ETC) A UM PAR DE CHAVES CRIPTOGRÁFICAS COM O INTUITO DE TORNAR AS COMUNICAÇÕES MAIS CONFIÁVEIS.

Infraestrutura de Chave Pública (ICP Brasil)

- ENTIDADE QUE MANTÉM UMA ESTRUTURA DE EMISSÃO DE CHAVES PÚBLICAS;
- TERCEIRA PARTE CONFIÁVEL;
- É QUEM EMITE O CERTIFICADO DIGITAL DA AUTORIDADE CERTIFICADORA;
- DEFINE UM CONJUNTO DE TÉCNICAS, PRÁTICAS E PROCEDIMENTOS A SEREM ADOPTADOS PELAS ENTIDADES;
- ICP-BRASIL = AUTORIDADES CERTIFICADORAS + AUTORIDADES DE REGISTRO.



Autoridade Certificadora Raiz

- MANEJA A AUTORIDADE NA CABEÇA DE CERTIFICAÇÃO;
- EXECUTA AS POLÍTICAS E NORMAS DEFINIDAS PELA ICP-BRASIL;
- EMITE, EXPDE, DISTRIBUI, RENOVA E GERENÇA OS CERTIFICADOS DAS AUTORIDADES CERTIFICADORAS DE NÍVEIS SUBSEQUENTES;
- EMITE A LCR (LISTA DE CERTIFICADOS REVOGADOS);
- FISCALIZA E AUDITA AS ACS, AS ARS E OUTRAS PRESTADORAS DE SERVIÇO HABILITADAS NA ICP-BRASIL.

Autoridade Certificadora

- EMITE, DISTRIBUI, RENOVA E GERENÇA CERTIFICADOS DIGITAIS;
- BUSCA VERIFICAR SE O TITULAR DO CERTIFICADO POSSUI A CHAVE PRIVADA QUE CORRESPONDE À CHAVE PÚBLICA DO CERTIFICADO;
- CRIA E ASSINA DIGITALMENTE O CERTIFICADO DO ASSINANTE;
- EMITE A LCR;
- MANTÉM REGISTRO DE SUAS OPERAÇÕES;
- ESTABELECE E FAZ AS ARS A ELA VINCULADAS CUMPREM AS POLÍTICAS DE SEGURANÇA E GARANTIR A AUTENTICIDADE DA IDENTIFICAÇÃO.

Autoridade de Registro

- É RESPONSÁVEL PELA INTERFACE ENTRE O USUÁRIO E A AUTORIDADE CERTIFICADORA;
- É VINCULADA A UMA AC;
- RECEBE, VALIDA E ENCAMINHA SOLICITAÇÃO DE EMISSÃO OU REVOCÇÃO DE CERTIFICADOS;
- IDENTIFICA, DE FORMA PRESENCIAL, OS SOLICITANTES;
- MANTÉM REGISTRO DE SUAS OPERAÇÕES.

AS ACS NÃO EMITEM CERTIFICADOS!

Tipos de Certificado

- CERTIFICADOS DE ASSINATURA DIGITAL (A): CONFIRMAÇÃO DE IDENTIDADE NA WEB, EM E-MAILS, EM VPNs E DOCUMENTOS ELETRÔNICOS
- CERTIFICADOS DE SIGILO (S): CODIFICAÇÃO DE DOCUMENTOS, DE BASES DE DADOS E OUTRAS INFORMAÇÕES SIGILOAS.

TIPO	GERAÇÃO DO PAR DE CHAVES	TAMANHO MÍNIMO	ARMazenamento	VALIDADE (ANOS)
A1/S1	SOFTWARE	1024 BITS	DISCO RÍGIDO (40) E PENDRIVE	1
A2/S2	SOFTWARE	1024 BITS	SMARTCARD OU TOKEN USB	2
A3/S3	HARDWARE	1024 BITS	SMARTCARD OU TOKEN USB	5
A4/S4	HARDWARE	2048 BITS	SMARTCARD OU TOKEN USB	6

RESUMO

DEFINIÇÕES DE SEGURANÇA DA INFORMAÇÃO

Proteção de informações e de sistemas de informações contra acesso, uso, divulgação, interrupção, modificação ou destruição não autorizados.

Salvaguarda de dados organizacionais contra acesso não autorizado ou modificação para assegurar sua disponibilidade, confidencialidade e integridade.

Conjunto de estratégias para gerenciar processos, ferramentas e políticas necessárias para prevenir, detectar, documentar e combater ameaças às informações organizacionais.

TIPO DE CONTROLE	DESCRIÇÃO
CONTROLES FÍSICOS	São barreiras que impedem ou limitam o acesso físico direto às informações ou à infraestrutura que contém as informações. Ex: portas, trancas, paredes, blindagem, vigilantes, geradores, sistemas de câmeras, alarmes, catracas, cadeados, salas-cofre, alarmes de incêndio, crachás de identificação, entre outros.
CONTROLES LÓGICOS	Também chamados de controles técnicos, são barreiras que impedem ou limitam o acesso à informação por meio do monitoramento e controle de acesso a informações e a sistemas de computação. Ex: senhas, firewalls, listas de controle de acesso, criptografia, biometria ¹ , IDS, IPS, entre outros.

PRINCÍPIOS DE SEGURANÇA	DESCRIÇÃO
CONFIDENCIALIDADE	Propriedade que visa não permitir que informações estejam disponíveis ou sejam reveladas a entidades não autorizadas – incluindo usuários, máquinas, sistemas ou processos.
INTEGRIDADE	Propriedade que visa garantir que a informação manipulada está correta, fidedigna e que não foi corrompida – trata da salvaguarda da exatidão e completeza da informação.
DISPONIBILIDADE	Propriedade de uma informação estar acessível e utilizável sob demanda por uma entidade autorizada.

PRINCÍPIOS ADICIONAIS	DESCRIÇÃO
AUTENTICIDADE	Propriedade que trata da garantia de que um usuário é de fato quem alega ser. Em outras palavras, ela garante a identidade de quem está enviando uma determinada informação.
IRRETRATABILIDADE	Também chamada de Irrefutabilidade ou Não-repúdio, trata da capacidade de garantir que o emissor da mensagem ou participante de um processo não negue posteriormente a sua autoria.

TIPO DE CRIPTOGRAFIA	CHAVES UTILIZADAS	VANTAGENS	DESVANTAGENS	EXEMPLOS DE USO
SIMÉTRICA	Usa uma única chave para criptografar e descriptografar.	Mais rápida e eficiente em termos computacionais.	Distribuição da chave é insegura; difícil em sistemas	Criptografia de arquivos, backups, VPNs.

¹ A biometria é polêmica: há algumas classificações que a colocam como controle lógico e outras como físico ou lógico a depender do que ela se propõe a proteger.



			com muitos usuários.	
ASSIMÉTRICA	Usa duas chaves diferentes: uma pública e uma privada.	Facilita o compartilhamento seguro da chave pública.	Mais lenta e exige maior poder de processamento.	Certificados digitais, assinatura eletrônica.
HÍBRIDA	Combina simétrica e assimétrica: assimétrica para trocar chave simétrica.	Une o desempenho da simétrica com a segurança da assimétrica.	Implementação mais complexa; requer integração de ambos os métodos.	SSL/TLS, e-mails seguros (PGP), transações online.

CRİPTOGRAFIA ASSIMÉTRICA (GARANTIA DE CONFIDENCIALIDADE)	CRİPTOGRAFIA ASSIMÉTRICA (GARANTIA DE AUTENTICIDADE)
O emissor criptografa o texto original com a chave pública do receptor de forma que somente ele consiga descriptografá-lo com sua chave privada para visualizar o texto original.	O emissor criptografa o texto original com sua chave privada de forma que o receptor possa descriptografá-lo com a chave pública do emissor.

ALGORITMO	DESCRIÇÃO
DES	Algoritmo simétrico de chave privada com 56 bits de tamanho de chave. Desenvolvido na década de 1970, é considerado fraco pelos padrões atuais de segurança.
3DES	Versão atualizada do DES, que usa três vezes a cifra DES para melhorar a segurança. Suas chaves podem ter 112 ou 168 bits.
AES	Algoritmo simétrico de chave privada que substituiu o DES como padrão de criptografia em 2001. Suas chaves podem ter 128, 192 ou 256 bits.
IDEA	Algoritmo simétrico de chave privada desenvolvido na década de 1990, com chave de 128 bits. Foi uma alternativa ao DES, mas é menos utilizado atualmente.
RC4	Algoritmo simétrico de chave privada usado em várias aplicações, como redes sem fio e SSL/TLS. Possui chaves de 40 a 2048 bits.
RSA	Algoritmo assimétrico de chave pública usado para criptografia e assinaturas digitais. É um dos algoritmos mais amplamente usados na criptografia moderna.
DIFFIE-HELLMAN	Algoritmo de troca de chaves que permite a comunicação segura em um canal inseguro. É amplamente utilizado em sistemas criptográficos baseados em chave pública.
BLOWFISH	Algoritmo simétrico de chave privada usado em diversas aplicações de segurança, com chaves de 32 a 448 bits. É conhecido por sua velocidade e segurança.

ALGORITMO	SEGURANÇA	VELOCIDADE	TAMANHO DA CHAVE	UTILIZAÇÃO	TIPO
DES	Fraco	Rápido	56 bits	Legado	Simétrico
3DES	Moderado	Lento	112-168 bits	Legado	Simétrico



AES	Forte	Rápido	128-256 bits	Atual	Simétrico
IDEA	Moderado	Rápido	128 bits	Legado	Simétrico
RC4	Moderado	Rápido	40-2048 bits	Legado	Simétrico
RSA	Forte	Lento	2048-4096 bits	Atual	Assimétrico
DIFFIE-HELLMAN	Forte	Moderado	Variável	Chave Pública	Assimétrico
BLOWFISH	Forte	Rápido	32-448 bits	Legado	Simétrico

AUTENTICAÇÃO



MÉTODOS DE AUTENTICAÇÃO	DESCRIÇÃO
O QUE VOCÊ SABE?	Trata-se da autenticação baseada no conhecimento de algo que somente você sabe, tais como: senhas, frases secretas, dados pessoais aleatórios, entre outros.
O QUE VOCÊ É?	Trata-se da autenticação baseada no conhecimento de algo que você é, como seus dados biométricos.
O QUE VOCÊ TEM?	Trata-se da autenticação baseada em algo que somente o verdadeiro usuário possui, tais como: celulares, crachás, Smart Cards, chaves físicas, tokens, etc.

ESTRATÉGIAS DE SENHAS	DESCRIÇÃO
USE SENHAS LONGAS	Quanto maior a senha, mais difícil de quebrar. Recomenda-se no mínimo 12 a 14 caracteres.
MISTURE DIFERENTES TIPOS DE CARACTERES	Utilize letras maiúsculas, minúsculas, números e símbolos para aumentar a complexidade.
EVITE PALAVRAS COMUNS OU SEQUÊNCIAS ÓBVIAS	Não use senhas como "123456", "senha", "admin", "abcdef" ou datas de nascimento.



CRIE FRASES-SENHA (PASSPHRASES)	Use uma frase fácil de lembrar, mas difícil de adivinhar, como "Sol&Chuva1987!CaféQuente".
NÃO REUTILIZE SENHAS	Cada conta deve ter uma senha única, para evitar vazamentos em cadeia.
EVITE INFORMAÇÕES PESSOAIS	Não use nomes, aniversários, placas de carro ou qualquer dado facilmente associável a você.
USE GERENCIADORES DE SENHAS	Ferramentas como Bitwarden, 1Password ou LastPass ajudam a criar e armazenar senhas fortes.
ATIVE A AUTENTICAÇÃO EM DOIS FATORES (2FA)	Complementa a senha com um segundo fator, como código por app ou biometria.
ATUALIZE SENHAS PERIODICAMENTE	Troque senhas antigas, especialmente se houver suspeita de vazamento.
TESTE A FORÇA DA SENHA	Utilize ferramentas confiáveis para verificar se a senha é forte o suficiente.

AUTENTICAÇÃO FORTE

Método de verificação de identidade que exige o uso de dois ou mais fatores de autenticação de categorias diferentes, como algo que o usuário sabe (senha ou PIN), tem (token, celular, smartcard) e é (biometria, como impressão digital ou reconhecimento facial). Essa combinação dificulta o acesso não autorizado, mesmo que um dos fatores seja comprometido. Utilizada em sistemas bancários, governamentais e corporativos, a autenticação forte é uma das formas mais eficazes de reforçar a segurança digital, protegendo contas e dados contra ataques como roubo de senhas, phishing e engenharia social.

ASSINATURA

INTEGRIDADE

NÃO REPÚDIO

AUTENTICIDADE

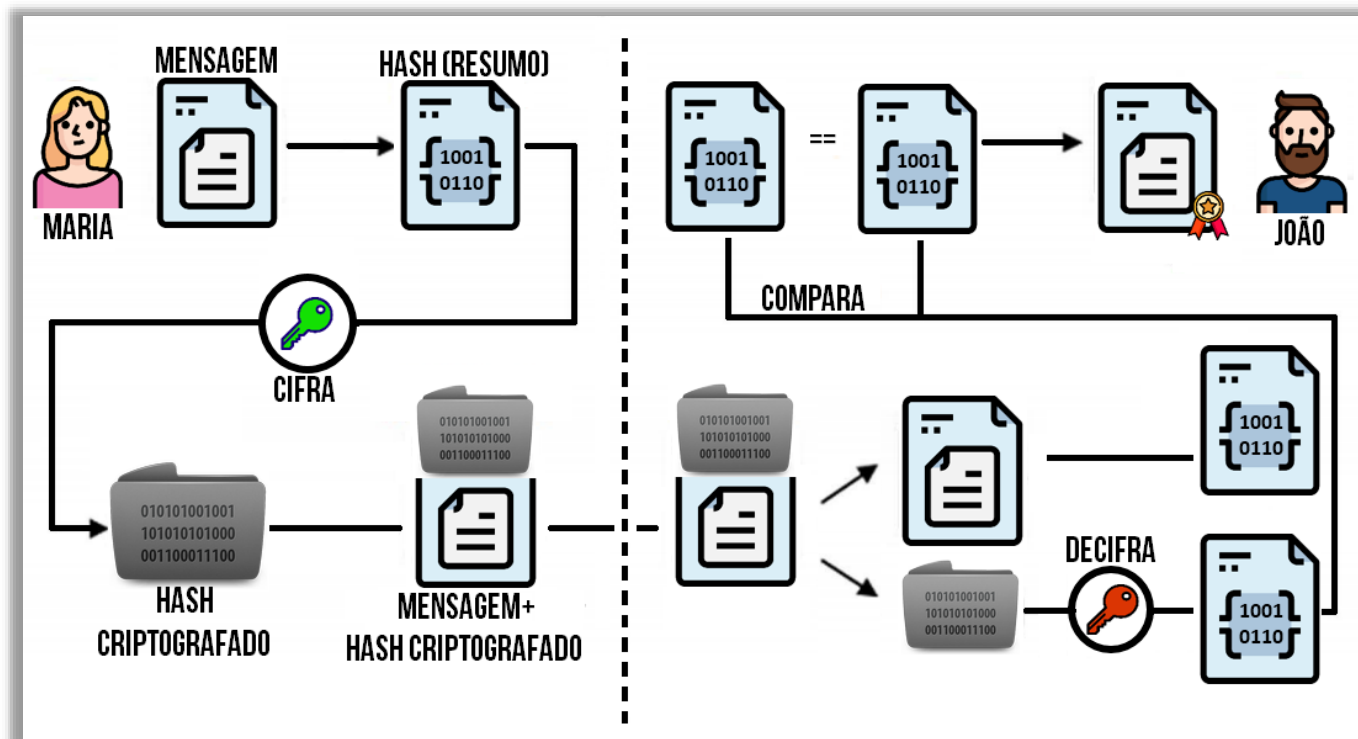
ASSINATURA DIGITAL

Mecanismo criptográfico utilizado para garantir a autenticidade, integridade e não repúdio de documentos ou mensagens eletrônicas. Ela funciona por meio da criptografia assimétrica, onde o remetente utiliza sua chave privada para assinar digitalmente o conteúdo, e o destinatário pode verificar essa assinatura usando a chave pública correspondente. Ao fazer isso, é possível confirmar que a informação não foi alterada e que realmente foi enviada por quem afirma tê-la enviado. As assinaturas digitais são amplamente utilizadas em contratos eletrônicos, sistemas de governo digital, certificados digitais e comunicações seguras.

FUNCIONAMENTO DA ASSINATURA DIGITAL

Maria possui uma mensagem em claro (sem criptografia). Ela gera um hash dessa mensagem, depois criptografa esse hash utilizando sua chave privada. Em seguida, ela envia para João tanto a mensagem original quanto o seu hash. João gera um hash da mensagem original e obtém um resultado, depois descriptografa o hash da mensagem utilizando a chave pública de Maria e obtém outro resultado. Dessa forma, ele tem dois hashes para comparar: o que ele gerou a partir da mensagem em claro e o que ele descriptografou a partir da mensagem criptografada. Se forem iguais, significa que Maria realmente enviou a mensagem, significa que ela não pode negar que enviou a mensagem e, por fim, significa que a mensagem está íntegra.





ASPECTO	IDENTIFICAÇÃO	AUTENTICAÇÃO	AUTORIZAÇÃO
DEFINIÇÃO	Processo pelo qual um usuário se apresenta ao sistema.	Verificação de identidade do usuário para garantir que ele é quem diz ser.	Processo que define os privilégios e permissões do usuário dentro do sistema.
EXEMPLO	Nome de usuário, número de matrícula, e-mail.	Senha, biometria, autenticação em dois fatores.	Permissão para modificar configurações, acessar arquivos e executar ações.
OBJETIVO	Reconhecer quem está tentando acessar o sistema.	Garantir que a pessoa identificada é realmente quem diz ser.	Controlar o que um usuário pode ou não pode fazer dentro do sistema.
FATOR DE SEGURANÇA	Baixo - apenas identifica o usuário, sem validar sua identidade.	Médio - exige prova de identidade para garantir acesso.	Alto - limita as ações de um usuário mesmo após autenticação bem-sucedida.
MOMENTO DE USO	Primeira etapa do acesso a um sistema.	Segunda etapa, logo após a identificação.	Aplicado após autenticação bem-sucedida para restringir ou conceder acesso.



CERTIFICADO DIGITAL

Certificado Digital é um documento eletrônico assinado digitalmente por uma terceira parte confiável - chamada Autoridade Certificadora - e que cumpre a função de associar uma entidade (pessoa, processo, servidor) a um par de chaves criptográficas com o intuito de tornar as comunicações mais confiáveis e auferindo maior confiabilidade na autenticidade. Ele é capaz de garantir a autenticidade, integridade e não-repúdio, e até confidencialidade.

TIPO	GERAÇÃO DO PAR DE CHAVES	TAMANHO DA CHAVE (BITS)	ARMAZENAMENTO	VALIDADE MÁXIMA (ANOS)
CERTIFICADO A1/S1	Por software	Mínimo RSA 2048	Disco Rígido (HD) e Pendrive	1
CERTIFICADO A2/S2	Por software	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	2
CERTIFICADO A3/S3	Por hardware	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	5
CERTIFICADO A4/S4	Por hardware	Mínimo RSA 2048	Módulo de Segurança Criptográfica (HSM)	6

ASPECTO	ASSINATURA DIGITAL	CERTIFICADO DIGITAL
DEFINIÇÃO	Método matemática de autenticação que garante a integridade e autenticidade de uma entidade.	<u>Documento eletrônico</u> assinado digitalmente que vincula uma chave pública a uma entidade.
OBJETIVO	Validar a autoria e garantir que o documento não foi alterado após a assinatura.	Identificar e autenticar digitalmente um usuário ou entidade.
USO	Assinar contratos, documentos e transações digitais com validade jurídica.	Emitir assinaturas digitais, acessar sistemas seguros e realizar transações online.
DEPENDÊNCIA	Necessita de um certificado digital para ser gerada.	Emitido por uma Autoridade Certificadora e usado para autenticação e assinatura digital.
SEGURANÇA	Utiliza criptografia para garantir que o documento não seja alterado após a assinatura.	Contém chaves criptográficas que garantem a identidade do titular e a segurança das transações.
VALIDADE JURÍDICA	Possui validade jurídica quando vinculada a um certificado digital reconhecido.	Tem validade jurídica e pode ser usado para autenticação em serviços governamentais e empresariais.

GARANTIAS

A criptografia por si só garante apenas **confidencialidade**! No entanto, quando utilizamos algoritmos criptográficos, nós acrescentamos mecanismos que nos ajudam a garantir outros serviços de segurança da informação. Em outras palavras, algoritmos de criptografia simétrica permitem garantir **confidencialidade**, **autenticidade** e **integridade**. Já algoritmos de criptografia assimétrica permitem garantir **confidencialidade**, **autenticidade**, **integridade** e **não-repúdio**. Notem que nem todos poderão ser garantidos simultaneamente!

INDICADORES	DESCRIÇÃO
-------------	-----------



**FPIR (FALSE POSITIVE
IDENTIFICATION RATE)**

Taxa de identificação falsa positiva, que mede a frequência com que um sistema identifica erroneamente um impostor como um usuário legítimo.

**FNIR (FALSE NEGATIVE
IDENTIFICATION RATE)**

Taxa de identificação falsa negativa, que indica a frequência com que um sistema falha ao identificar corretamente um usuário legítimo.



QUESTÕES COMENTADAS – MULTIBANCAS

- 1. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O procedimento de associar a autenticação de dois fatores (2FA) ao uso de senha contribui muito pouco para o ganho de segurança da informação.**

Comentários:

A autenticação de dois fatores (2FA) adiciona uma camada extra de segurança ao exigir um segundo fator além da senha, como um código enviado ao celular. Isso dificulta acessos não autorizados, mesmo que a senha seja comprometida.

Gabarito: Errado

- 2. (CEBRASPE / MPE-TO - 2024) O controle de acesso físico é um procedimento de segurança utilizado para garantir a segurança de informação de uma empresa.**

Comentários:

O controle de acesso físico é uma medida de segurança essencial para proteger informações, restringindo o acesso a áreas críticas, como data centers e salas de servidores. Isso evita acessos não autorizados que possam comprometer a integridade e confidencialidade dos dados.

Gabarito: Correto

- 3. (CEBRASPE / MPE-TO - 2024) Ainda que muito eficiente, o uso de criptografia é insuficiente para garantir a segurança das informações em determinado computador.**

Comentários:

A criptografia protege a confidencialidade dos dados, mas, sozinha, não garante segurança total. Outros controles, como firewall, antivírus, autenticação forte e backup, são necessários para proteger contra ameaças como malware, acesso não autorizado e falhas do sistema.

Gabarito: Correto

- 4. (CEBRASPE / MPE-TO - 2024) A assinatura digital é um dos recursos mais eficientes para garantir o sigilo de uma informação.**

Comentários:

A assinatura digital garante autenticidade, integridade e não repúdio, mas não assegura sigilo. Para garantir sigilo, é necessário o uso de criptografia, que protege os dados contra acesso não autorizado.

Gabarito: Errado

- 5. (CEBRASPE / ITAIPU BINACIONAL - 2024) Tendo em vista que o uso diário de computadores para realizar atividades profissionais, de lazer ou estudos requer uma atenção especial por parte dos usuários, a fim de assegurar a proteção adequada de seus dados e arquivos, assinale a opção correta com referência às práticas fundamentais para garantir a segurança da informação.**



- a) Vírus de computador só tem capacidade de contaminar computadores que estiverem conectados em rede ou na Internet.
- b) Manter softwares de antivírus atualizados impede o acesso não autorizado ao computador.
- c) Mesclar letras, números e caracteres especiais na definição de senhas é uma boa prática para torná-las mais seguras.
- d) O acesso a serviços on-line em computadores de uso compartilhado, como em faculdades ou lan houses, não representa risco se for realizado o logout nos serviços antes de desligar o computador.
- e) Abrir arquivos ou clicar em links recebidos por e-mails enviados por remetentes conhecidos não representa risco de segurança.

Comentários:

- (a) Errado. Vírus podem infectar computadores de diversas formas, incluindo dispositivos USB, e-mails, downloads e arquivos infectados, não sendo necessária conexão com a Internet ou rede;
- (b) Errado. Antivírus atualizado protege contra malwares, mas não impede acessos não autorizados, pois essa função é desempenhada por firewalls e autenticação forte;
- (c) Correto. Criar senhas fortes, mesclando letras, números e caracteres especiais, reduz a vulnerabilidade contra ataques de força bruta e tentativas de adivinhação;
- (d) Errado. Mesmo após o logout, keyloggers e outros malwares podem capturar credenciais em computadores compartilhados. O ideal é usar modos anônimos e autenticação multifator;
- (e) Errado. E-mails de phishing podem ser enviados por remetentes conhecidos se suas contas forem comprometidas. É essencial verificar links e anexos antes de abrir.

Gabarito: Letra C

6. (CEBRASPE / Prefeitura de São Cristóvão-SE - 2023) A respeito de segurança da informação, assinale a opção correta.

- a) O mero recebimento de um link com malware é suficiente para que o dispositivo do usuário seja contaminado, mesmo que ele não clique no link.
- b) A instalação e a configuração de aplicativos de segurança bastam para garantir a proteção de dados e informações armazenados em um computador.
- c) Entre os procedimentos de segurança da informação, recomenda-se não abrir anexos de emails recebidos de usuário desconhecido.
- d) A instalação de firewalls no computador apenas garante um melhor desempenho da máquina, sem colaborar para a segurança da informação.

Comentários:



- (a) Errado. O mero recebimento de um link com malware não infecta o dispositivo. A contaminação ocorre caso o usuário clique no link e execute um código malicioso;
- (b) Errado. Apenas instalar e configurar aplicativos de segurança não é suficiente. Boas práticas, como atualizações regulares, autenticação forte e conscientização do usuário, são essenciais para proteção completa;
- (c) Correto. Não abrir anexos de e-mails desconhecidos é uma recomendação de segurança para evitar phishing, malwares e ataques de engenharia social;
- (d) Errado. Firewalls não servem para melhorar o desempenho, mas sim para controlar o tráfego de rede, protegendo contra acessos não autorizados e ameaças.

Gabarito: Letra C

7. (CEBRASPE / AGER-MT - 2023) A ICP-Brasil foi criada para viabilizar a emissão de certificados digitais no país, para transações que precisam de validade e segurança dos dados. Conforme o ITI, e considerando o uso de um certificado digital ICP-Brasil, é correto afirmar que a assinatura digital é:

- a) A gerada a partir do uso do certificado digital ICP-Brasil e possui pleno valor jurídico garantido pela legislação brasileira.
- b) importada no computador via a cadeia de certificação nível a3 e possui pleno valor jurídico garantido pela legislação brasileira.
- c) gerada a partir do uso do certificado digital ICP-Brasil e seu valor jurídico depende da autoridade pública do município que é apresentado.
- d) gerada por um navegador, que também autentica automaticamente o certificado emissor, e está restrita ao governo federal pelas regras do judiciário.
- e) gerada a partir do uso do certificado digital ICP-Brasil e, uma vez assinado um documento, sua alteração é possível em qualquer situação nos sistemas de governo.

Comentários:

- (a) Correto. A assinatura digital gerada com um certificado digital ICP-Brasil possui pleno valor jurídico, conforme a legislação brasileira, garantindo autenticidade, integridade e não repúdio;
- (b) Errado. O valor jurídico da assinatura digital não depende do tipo de certificado (A1, A3, etc.), mas sim da ICP-Brasil, que garante sua validade legal;
- (c) Errado. O valor jurídico não depende da autoridade pública municipal, mas sim da regulamentação da ICP-Brasil em nível nacional;
- (d) Errado. A assinatura digital não é restrita ao governo federal e pode ser utilizada por empresas e cidadãos em diversas aplicações privadas e públicas;
- (e) Errado. Após assinar um documento digitalmente, qualquer alteração invalida a assinatura, garantindo a integridade do conteúdo assinado.



Gabarito: Letra A

8. (CEBRASPE / TRT8 - 2022) Em uma VPN, a confidencialidade dos dados garante que:

- a) o conteúdo da mensagem não foi alterado durante a transmissão entre o emissor e o receptor.
- b) o conteúdo da mensagem foi armazenado fisicamente em ambiente seguro.
- c) a mensagem foi enviada por uma fonte autêntica e será entregue a um destino autêntico.
- d) o emissor não poderá repudiar o envio da mensagem, ou seja, dizer que não enviou a referida mensagem.
- e) a mensagem não poderá ser interpretada por origens não autorizadas.

Comentários:

(a) Errado, isso seria a integridade; (b) Errado, isso não tem nenhuma relação com confidencialidade; (c) Errado, isso seria autenticidade; (d) Errado, isso seria irretratabilidade ou não-repúdio; (e) Correto, essa definição representa perfeitamente a confidencialidade dos dados.

Gabarito: Letra E

9. (CEBRASPE / TRT8 - 2022) Em relação à criptografia assimétrica é correto afirmar que:

- a) a criptografia de chave pública pode ser menos segura, em relação à criptoanálise, do que a criptografia simétrica.
- b) a criptografia de chave pública é uma técnica de uso geral que tornou a criptografia simétrica obsoleta.
- c) a distribuição de chave pública é sempre mais trivial e fácil quando comparada com o mecanismo de troca de mensagens para distribuição de chave para a criptografia simétrica.
- d) envolve a utilização de duas chaves privadas para realizar a criptoanálise.
- e) utiliza os algoritmos simétricos Data Encryption Standard (DES) e o Triple DES (DES triplo).

Comentários:

(a) Correto, não existe uma regra de qual tipo de criptografia (simétrica ou assimétrica) é mais segura, logo a criptografia assimétrica pode ser menos segura; (b) Errado, a criptografia simétrica ainda é amplamente utilizada; (c) Errado, não é sempre mais trivial e fácil; (d) Errado, utiliza uma chave pública e uma chave privada; (e) Errado, esses são algoritmos de criptografia simétrica.

Gabarito: Letra A

10.(CEBRASPE / DPDF - 2022) O algoritmo de hash é capaz de verificar e validar a integridade de um arquivo.

Comentários:



A integridade é a capacidade de garantir que a informação manipulada está correta, fidedigna e que não foi corrompida. O algoritmo de hash é basicamente um algoritmo criptográfico que transforma uma entrada de dados em uma saída de dados de tamanho fixo. Dessa forma, se um único bit for alterado, teremos um resultado diferente. Logo, ele realmente é capaz de verificar e validar a integridade de um arquivo.

Gabarito: Correto

11.(FCC / SEFAZ-AP - 2022) Para proteger as informações e a comunicação de dados que circulam em redes de computadores, o processo criptográfico tem por objetivo:

- a) a autenticação, a confidencialidade, o não repúdio e a integridade.
- b) a autenticação, a confidencialidade, o *hashing* e a temporização.
- c) a sanitização de dados, a integridade, a temporização e o não repúdio.
- d) o protecionismo, a confidencialidade, a verificação e a integridade.
- e) a temporização, a autenticação, o não repúdio e a informatização.

Comentários:

O processo criptográfico tem por objetivo a autenticação, a confidencialidade, o não-repúdio e a integridade. Não são princípios de segurança: hashing, temporização, sanitização, protecionismo, verificação ou informatização.

Gabarito: Letra A

12.(FCC/ SEFAZ-SC - 2018) O estabelecimento e a implantação da segurança da informação requerem o uso de diferentes mecanismos e recursos para atender os atributos de segurança da informação. Nesse contexto, o Hash tem a função de:

- a) realizar a transformação reversível da informação de forma a torná-la ininteligível a terceiros.
- b) criar uma chave criptográfica a partir do certificado digital.
- c) comprovar a identidade do emissor de um documento.
- d) atestar a validade de um documento.
- e) garantir a integridade de um documento.

Comentários:

(a) Errado, é irreversível; (b) Errado, não faz nenhum sentido; (c) Errado, hash não garante autenticidade; (d) Errado, ele não atesta se um documento é válido; (e) Correto, ele garante a integridade do documento, isto é, o documento recebido é idêntico ao documento enviado.

Gabarito: Letra E

13.(FCC / FITO - 2020) Deseja-se adquirir um Certificado Digital para assegurar e comprovar a assinatura digital dos documentos emitidos por uma empresa. Considerando a aquisição por meio de um órgão autorizado pelo ICP-Brasil e que a chave deve ter o comprimento de 4096 bits, o tipo de Certificado a adquirir é:

- a) A1
- b) A3
- c) A4
- d) S1
- e) S3



Comentários:

Se a chave deve ter comprimento de 4096 bits, o certificado é do tipo A4.

Gabarito: Letra C

14.(FCC / TJ-MA - 2019) Considere as asserções a seguir, a respeito do processo de autenticação usando criptografia assimétrica:

O autor utiliza sua chave privada para cifrar um documento de modo a garantir sua autoria ou sua identificação em uma transação. Se este autor cifrar um documento com sua chave privada e enviar para o destinatário, este poderá decifrar o documento

PORQUE

pode ter acesso à chave privada do autor. O fato de ser necessário o uso da chave privada do autor para produzir o texto cifrado caracteriza uma operação que somente ele tem condições de realizar.

É correto afirmar que:

- a) as duas asserções são verdadeiras, sendo a segunda a justificativa correta da primeira.
- b) as duas asserções são falsas.
- c) a primeira asserção é falsa e a segunda é verdadeira.
- d) a primeira asserção é verdadeira e a segunda é falsa.
- e) as duas asserções são verdadeiras, porém a segunda não é a justificativa correta da primeira.

Comentários:

A primeira asserção está correta, visto que o autor utiliza sua chave privada para cifrar um documento em um processo de autenticação. No entanto, o destinatário somente poderá decifrar o documento utilizando a sua chave pública do autor – ele não tem acesso à chave privada do autor, que é secreta e de conhecimento apenas desse. Logo, a primeira asserção é verdadeira e a segunda é falsa.

Gabarito: Letra D

15.(FCC / TJ-MA - 2019) As informações protegidas utilizando os algoritmos de criptografia assimétrica têm garantidas, em teoria,

- a) somente a confidencialidade.
- b) tanto a confidencialidade quanto a autenticidade.
- c) somente a integridade.
- d) somente a autenticidade.
- e) tanto a confidencialidade quanto a veracidade.

Comentários:

A utilização de algoritmos de criptografia assimétrica garante, em teoria, confidencialidade ou autenticidade. Se você criptografa com a chave pública do destinatário, garante a confidencialidade se você criptografa com a chave privada do remetente, garante a autenticidade.

Gabarito: Letra B



16.(FCC / SANASA - 2019) Além de ser usado para verificar transações com criptomoedas, como Bitcoin, a função hash é usada em assinaturas digitais, para:

- a) garantir a integridade do documento assinado.
- b) aumentar o tempo de autenticação da assinatura.
- c) gerar um valor aleatório de tamanho variável.
- d) garantir a autenticidade do documento assinado.
- e) gerar um resumo de 256 bits por meio do algoritmo RSA.

Comentários:

(a) Correto, funções de hash garantem a integridade do documento assinado; (b) Errado, isso sequer faz sentido; (c) Errado, não é um valor aleatório e o tamanho é fixo; (d) Errado, ele não garante autenticidade e, sim, integridade; (e) Errado, RSA é um algoritmo de criptografia assimétrica e, não, uma função de hash.

Gabarito: Letra A

17.(FCC / Prefeitura de Manaus/AM - 2019) No processo da assinatura digital, a propriedade que identifica qualquer alteração no documento e faz com que a assinatura não seja mais reconhecida garantindo, assim, a inalterabilidade, é denominada:

- a) autenticidade.
- b) autoria.
- c) integridade.
- d) não repúdio.
- e) irretratabilidade.

Comentários:

A propriedade que identifica qualquer alteração no documento e faz com que a assinatura não seja mais reconhecida garantindo, assim, a inalterabilidade, é denominada Integridade.

Gabarito: Letra C

18.(FCC / TRF4 - 2019) Considere o esquema hipotético abaixo referente à comunicação segura estabelecida pelo Tribunal Regional Federal da 4ª Região - TRF4:



O esquema descreve:

- a) autenticação e gerenciamento de sessão.
- b) autenticação segura com XSS via assinatura eletrônica.



- c) criptografia de chave assimétrica.
- d) comunicação segura híbrida de chave pública.
- e) criptografia de chave simétrica.

Comentários:

Notem que um cidadão está criptografando um texto claro por meio da chave pública do TRF4, que posteriormente é descriptografado pelo TRF por meio da chave privada do TRF4. Quando se criptografa um documento com a chave pública do emissor, ocorre um processo de criptografia de chave assimétrica (ou chave pública).

Gabarito: Letra C

19.(FCC / TRF4 - 2019) Considere o esquema abaixo.



Trata-se de uma hipotética comunicação criptografada entre o computador de um Juiz e um computador do TRF4. Os textos Chave, Processo 1 e Processo 2, bem como a categoria de criptografia apresentados no esquema representam, correta e respectivamente,

- a) chave secreta compartilhada, descriptografia, criptografia e criptografia de chave assimétrica.
- b) chave pública, criptografia, descriptografia e criptografia de chave assimétrica.
- c) chave secreta compartilhada, criptografia, descriptografia e criptografia de chave simétrica.
- d) chave pública, descriptografia, criptografia e criptografia de chave simétrica.
- e) chave pública compartilhada, criptografia, descriptografia e criptografia de curvas elípticas.

Comentários:

Notem que existe apenas uma chave compartilhada entre emissor e receptor tanto para cifrar quanto para decifrar uma mensagem. Logo, temos uma chave secreta compartilhada entre as entidades da comunicação, sendo que o primeiro processo é uma criptografia, o segundo processo é uma descriptografia – ambas simétricas.

Gabarito: Letra C

20.(FCC / SEGEPI-MA - 2018) A segurança da informação considera alguns atributos básicos como: **confidencialidade, integridade, disponibilidade, autenticidade e irretratabilidade. O mecanismo de segurança da informação que tem o objetivo de garantir a confidencialidade é:**

- a) a assinatura digital.
- b) o certificado digital.
- c) a função hash.
- d) o Token criptográfico.
- e) a criptografia.

Comentários:



O mecanismo capaz de garantir a confidencialidade é a criptografia.

Gabarito: Letra E

21.(FGV / Câmara dos Deputados - 2023) Na área da Segurança da Informação, há aspectos fundamentais para o desenvolvimento de políticas de armazenamento e uso de dados, tais como Confidencialidade, Integridade, Disponibilidade e Autenticidade. No campo da Tecnologia da Informação, dada a necessidade de trafegar dados pela Internet, a confidencialidade torna-se um ponto crítico. Nesse contexto, assinale a estratégia de proteção mais adequada para preservar a confiabilidade de dados.

- a) Criação de backups em tempo real.
- b) Emprego de software antivírus.
- c) Instalação de centros de supercomputação.
- d) Redundância nos dispositivos de armazenamento.
- e) Uso de criptografia.

Comentários:

A confidencialidade dos dados, especialmente na área de Segurança da Informação, é um aspecto crítico que garante que as informações sejam acessíveis somente a pessoas autorizadas. Ao considerar o tráfego de dados pela Internet, a proteção da confidencialidade torna-se ainda mais crucial. Vamos analisar as opções:

- (a) Errado. Esta prática é essencial para garantir a disponibilidade dos dados, mas não aborda diretamente a confidencialidade.
- (b) Errado. Embora os antivírus sejam importantes para a segurança dos dados, eles são mais focados em proteger contra malware e não garantem especificamente a confidencialidade dos dados.
- (c) Errado. Os centros de supercomputação não são diretamente relacionados à proteção da confidencialidade dos dados. Eles são mais voltados para processamento de dados em grande escala.
- (d) Errado. A redundância é uma estratégia para garantir a disponibilidade e a integridade dos dados, mas não aborda a confidencialidade.
- (e) Correto. A criptografia é a técnica mais adequada para proteger a confidencialidade dos dados. Ela garante que os dados, mesmo se interceptados durante a transmissão pela Internet, não possam ser lidos ou compreendidos sem a chave de descryptografia apropriada.

Portanto, para preservar a confidencialidade dos dados, especialmente no tráfego pela Internet, a estratégia mais adequada é o uso de criptografia.

Gabarito: Letra E

22.(FGV / SEFAZ-MT - 2023) Algoritmos de ciframento são frequentemente utilizados para proteger informações, transações comerciais e financeiras realizadas por meio de meios eletrônicos, em particular, pela internet.

Sobra esses algoritmos, assinale a afirmativa correta.

- a) 3DES é uma função de espelhamento unidirecional.



- b) *ElGamal* é um algoritmo de chave privada.
- c) *AES* é um algoritmo assimétrico com chaves de tamanho fixo.
- d) *Blowfish* é uma cifra simétrica de blocos.
- e) *SHA* é um algoritmo de chave pública de tamanho variável.

Comentários:

- (a) Errado. 3DES (Triple Data Encryption Standard) é um algoritmo simétrico de criptografia que utiliza três vezes a aplicação do algoritmo DES;
- (b) Errado. ElGamal é um algoritmo de criptografia assimétrica que utiliza um par de chaves: uma chave pública e uma chave privada;
- (c) Errado. AES (Advanced Encryption Standard) é um algoritmo simétrico de criptografia com chaves de tamanho variável (128, 192 ou 256 bits);
- (d) Correto. Blowfish é de fato uma cifra simétrica de blocos amplamente utilizada para criptografia de dados;
- (e) Errado. Trata-se de uma família de algoritmos de hash criptográficos que produzem um resumo único (hash) de tamanho fixo para dados de entrada. Não é um algoritmo de chave pública.

Gabarito: Letra D

23.(FGV / SEAD-AP - 2022) Com relação aos métodos de criptografia de chave pública, considere as afirmativas a seguir.

- - I. Cada participante em um sistema de chave pública possui um par de chaves, uma pública e outra, privada.
 - II. Qualquer participante pode criptografar e decriptografar uma mensagem usando a própria chave privada.
 - III. Quando o participante P1 envia uma mensagem criptografada para P2, é preciso que P2 conheça a chave privada de P1.

É correto somente o que se afirma em

- a) I.
- b) II.
- c) III.
- d) I e II.
- e) II e III.

Comentários:

(I) Correto; (II) Errado, só é possível decriptografar uma mensagem usando a própria chave privada se ela foi criptografada usando sua chave pública; (III) Errado, a chave privada é... privada, logo P2 não pode conhecer a chave privada de P1.

Gabarito: Letra A

24.(FGV / TCE-TO - 2022) O auditor José recebeu o arquivo AnexoJ em formato digital. Antes de proceder com a abertura do AnexoJ, José determinou a fidedignidade do referido arquivo,



avaliando a conformidade dos dados do AnexoJ por ele recebido com os dados do AnexoJ transmitido pelo emissor.

Essa avaliação feita por José em AnexoJ está diretamente relacionada com o seguinte princípio da segurança de informações:

- a) integridade;
- b) confidencialidade;
- c) autenticidade;
- d) disponibilidade;
- e) qualidade.

Comentários:

José quer saber se os dados recebidos são fidedignos em relação aos dados enviados, logo se trata de uma preocupação com relação à integridade.

Gabarito: Letra A

25.(FGV / TCE-TO - 2022) As funções de hash são comumente empregadas nos mecanismos de segurança da informação.

Quanto às suas propriedades básicas, para que o algoritmo de hash seja considerado forte, é correto afirmar que:

- a) a mesma entrada deve produzir saídas diferentes;
- b) deve ser difícil encontrar duas entradas que produzam o mesmo hash;
- c) deve ser possível produzir a entrada original a partir do hash resultante;
- d) pequenas mudanças na entrada devem produzir pequenas mudanças no hash resultante;
- e) mesmo que as entradas possuam o mesmo tamanho, os resultados de hash terão tamanhos diferentes.

Comentários:

(a) Errado, deve produzir a mesma saída; (b) Correto; (c) Errado, idealmente deve ser impossível produzir a entrada original a partir do hash resultante; (d) Errado, pequenas mudanças na entrada devem produzir grandes mudanças no hash resultante; (e) Errado, o hash resultante sempre terá o mesmo tamanho.

Gabarito: Letra B

26.(FGV / TCE-TO - 2022) Bernardo e João são auditores recém-concursados no TCE/TO. Bernardo precisa enviar documentos sigilosos para João e vice-versa, contudo, nenhum deles utilizou ainda a ferramenta de criptografia disponível na instituição.

Sabendo-se que é utilizada a criptografia por chave pública, o procedimento que deve ser seguido por cada auditor antes de tramitar os documentos é:

- a) gerar um par de chaves a ser usado para encriptação e decifração dos documentos; importar a chave pública no registrador público da instituição; guardar a chave privada; e encriptar os documentos utilizando a chave pública do destinatário;



- b) gerar um par de chaves a ser usado para encriptação e decriptação dos documentos; importar a chave pública no registrador público da instituição; enviar a chave privada para o destinatário; e encriptar um documento utilizando a chave privada enviada;
- c) gerar um par de chaves a ser usado para encriptação e decriptação dos documentos; importar a chave pública no registrador público da instituição; guardar a chave privada; e encriptar os documentos utilizando a chave privada do remetente;
- d) gerar a chave pública para encriptação e decriptação dos documentos; enviar a chave pública para o destinatário; e encriptar os documentos utilizando a chave pública enviada;
- e) combinar uma senha entre eles; encriptar e decriptar os documentos utilizando a senha combinada.

Comentários:

(a) Correto; (b) Errado, não se envia sua chave privada para o destinatário, porque a chave é privada. E encripta-se o documento utilizando a chave pública do destinatário; (c) Errado, encripta-se os documentos utilizando a chave pública do destinatário; (d) Errado, deve-se gerar o par de chaves e não é necessário enviar a chave pública para o destinatário; (e) Errado, não faz nenhum sentido.

Gabarito: Letra A

27.(FGV / TRT-MA - 2022) Os sistemas de chave pública são caracterizados pelo uso de um algoritmo criptográfico com duas chaves, uma privada e uma pública. Com relação às categorias de uso dos criptossistemas de chave pública, analise as afirmativas a seguir:

- I. Criptografia/descriptografia: um emissor criptografa uma mensagem com a chave pública do seu destinatário.
- II. Assinatura digital: um emissor assina uma mensagem com sua chave pública. A assinatura é feita por um algoritmo criptográfico aplicado à mensagem ou a um pequeno bloco de dados que é uma função da mensagem.
- III. Troca de chave: dois lados cooperam para trocar uma chave de sessão. Várias técnicas diferentes são possíveis, envolvendo as chaves públicas de uma ou de ambas as partes.

Está correto o que se afirma em

- a) I, apenas.
- b) II, apenas.
- c) III, apenas.
- d) I e II, apenas.
- e) II e III, apenas.

Comentários:

(I) Correto; (II) Errado. Se ele assinar com a própria chave pública, só ele poderá descriptografar. O intuito da assinatura digital é permitir que qualquer pessoa identifique a autenticidade de uma mensagem, logo ele deve assinar uma mensagem com a sua chave privada para que qualquer pessoa com a sua chave pública possa descriptografá-la e conferir a autenticidade; (III) Errado. Envolve as chaves privadas de uma ou de ambas as partes.



Gabarito: Letra A

28.(FGV / MPE-GO - 2022) João quer usar um serviço de armazenamento em nuvem que ofereça o recurso de verificação de sua identidade em duas etapas. Para isso, João escolheu um serviço que usa um aplicativo autenticador instalado em seu dispositivo móvel.

O tipo de verificação em duas etapas do serviço escolhido por João é o(a):

- a) código de verificação.
- b) token gerador de senhas.
- c) cartão de segurança.
- d) dispositivo confiável.
- e) chave de recuperação.

Comentários:

(a) Correto. Existem vários aplicativos autenticadores (Ex: Google Authenticator, Microsoft Authenticator, entre outros) que permitem fazer a verificação em duas etapas: em geral, o usuário insere login e senha na primeira etapa e depois insere um código de verificador gerado pelo aplicativo na segunda etapa;

(b) Errado, token gerador de senha é um dispositivo físico e, não, um autenticador instalado em seu dispositivo móvel que usa um serviço de armazenamento em nuvem;

(c) Errado, cartão de segurança é um cartão físico que contém um conjunto de códigos que permitem a autenticação em duas etapas – não tem relação com aplicativo autenticador;

(d) Errado, dispositivo confiável é um computador ou dispositivo móvel que você frequentemente usa para acessar suas contas. Pode ser necessário inserir um código de segurança no primeiro acesso. Ele não será necessário nos demais, pois seu dispositivo será “lembrado” – não tem relação com um aplicativo autenticador;

(e) Errado, chave de recuperação é um código que permite recuperar uma senha ou o acesso a alguma aplicação – não tem relação com um aplicativo autenticador.

Gabarito: Letra A

29.(FGV / TJDF - 2022) Ana precisa enviar a mensagem M para Bráulio de forma sigilosa pela rede do Tribunal de Justiça atendendo aos requisitos de segurança: autenticidade, não repúdio, integridade e confidencialidade. Para isso, Ana deve enviar uma chave secreta K para Bráulio e gerar uma assinatura digital AD(M).

Considerando que a chave K deve ser conhecida apenas por Ana e Bráulio, após esse processo deve-se cifrar K e AD(M) com a chave:

- a) privada de Bráulio;
- b) privada de Ana;
- c) pública de Ana;
- d) pública de Bráulio;
- e) secreta de Ana.

Comentários:



Essa questão é bastante interessante - nunca havia visto uma questão que cobrasse esse tipo de conhecimento. Vamos analisá-la:

O enunciado afirma que Ana deve enviar uma chave secreta K para Bráulio. Ora, se foi utilizado o termo "chave secreta", trata-se da utilização de criptografia simétrica. No entanto, logo em seguida o enunciado afirma que Ana gera uma assinatura digital da mensagem que ela deseja enviar para Bráulio. Ora, então estamos tratando de criptografia assimétrica. Conforme vamos ver, a questão trata de uma mistura de criptografia simétrica com criptografia assimétrica.

O enunciado afirma que a chave secreta (K) deve ser conhecida apenas por Ana e Bráulio, reforçando que se trata de criptografia simétrica. *Não poderia ser uma chave pública, professor?* Não, dado que ela só deve ser conhecida por Ana e Bráulio. *E não poderia ser uma chave privada, professor?* Também não, chave privada só é conhecida pelo seu proprietário. Por fim, o enunciado afirma que a chave secreta e a assinatura digital da mensagem deve ser criptografada.

Agora vamos entender o cenário completo: Ana precisa enviar uma mensagem para Bráulio. Para tal, ela gera uma assinatura digital da mensagem com sua chave privada para que qualquer pessoa possa utilizar sua chave pública para verificar a autenticidade, integridade e não-repúdio da mensagem. *Professor, onde entra a criptografia? E também não entendi como Bráulio vai saber qual é a chave secreta?*

Ana junta a chave secreta com a assinatura da mensagem, criptografa tudo com a chave pública de Bráulio e envia o conjunto todo (garantindo a confidencialidade). Quando Bráulio receber, somente ele poderá descriptografar porque somente ele sabe qual é a sua chave privada. Após descriptografar, ele terá a chave secreta a sua disposição, além da assinatura digital - lembrando que a assinatura digital contém a mensagem em claro + hash criptografado da mensagem.

Agora Bráulio poderá descriptografar o hash criptografado da mensagem com a chave pública de Ana, obtendo o hash da mensagem. Pronto! Bráulio tem acesso à chave secreta, à mensagem em claro e ao hash da mensagem em claro. Basta gerar outro hash da mensagem em claro e comparar com o hash da mensagem recebido: se forem iguais, significa que a mensagem é íntegra, autêntica e irretratável.

E por que fazer esse processo todo complicado, professor? Porque algoritmos de criptografia simétrica possuem uma performance melhor do que algoritmos de criptografia assimétrica. Em regra, a criptografia de chave pública é utilizada para a troca de chave simétrica (além de geração de assinaturas digitais), mas - na prática - a criptografia simétrica é mais eficiente para o restante dos casos. *Bacana?*

Galera, questão bem chatinha que cobra um caso muito específico. De todo modo, está claro que foi utilizada a chave pública de Bráulio.

Gabarito: Letra D

30.(FGV / TJDF - 2022) Lucas é um trader profissional que trabalha em uma corretora de valores. Ele efetua muitas operações durante o período em que a bolsa negocia seus ativos. Após fazer uma revisão em suas operações do dia, não validou, como sendo efetuadas por ele, algumas das operações que obtiveram prejuízo. Lucas, então, entrou em contato com a corretora e esta demonstrou, a partir de registros de auditoria e garantia de identidade, que as operações em questão realmente foram executadas por ele.

Para que a corretora prove que foi Lucas quem realmente executou as operações, ela deve fazer uso do conceito de segurança chamado:

a) confidencialidade;



- b) autenticidade;
- c) integridade;
- d) disponibilidade;
- e) irretratabilidade.

Comentários:

Para que a corretora prove que foi Lucas quem realmente executou as operações, ela deve fazer uso do conceito de segurança chamado Irretratabilidade ou Não-Repúdio, que é a garantia de que o autor não possa negar que ele realizou as operações.

Gabarito: Letra E

31.(CESGRANRIO / IPEA - 2024) A entidade J enviou uma mensagem (M) assinada para a entidade K, utilizando o padrão RSA de assinatura digital. A assinatura digital (AD) de M está acompanhada do certificado digital de J (CertJ/AC), emitido pela Autoridade Certificadora (AC). A entidade K tem confiança na AC; logo, o certificado digital da AC (CertAC/AC), emitido pela própria AC, está armazenado na sua base de certificados digitais confiáveis. Ambos os certificados digitais CertJ/AC e CertAC/AC passaram no teste de validação de certificados digitais, e a cadeia de certificados está verificada com sucesso.

Como parte do processo de verificação da AD de M, a entidade K deve decriptar a AD com a(as) chave(s):

- a) pública de J, presente em CertJ/AC
- b) pública de AC, presente em CertAC/AC
- c) públicas de J e de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC
- d) pública de J e a privada de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC
- e) privada de J e a pública de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC

Comentários:

(a) Correto. Para verificar uma assinatura digital criada com a chave privada do remetente (neste caso, a entidade J), o destinatário (neste caso, a entidade K) deve usar a chave pública do remetente, que é disponibilizada por meio do certificado digital do remetente (CertJ/AC). Isso permite ao destinatário assegurar que a mensagem foi de fato assinada pela chave privada correspondente à chave pública no certificado, autenticando assim a origem e integridade da mensagem.

(b) Errado. A chave pública da Autoridade Certificadora (AC) é usada para verificar a validade do certificado digital de J (CertJ/AC), mas não para decriptar a assinatura digital da mensagem (M) em si.

(c) Errado. Apenas a chave pública de J é necessária para decriptar a assinatura digital de M. A chave pública de AC é usada para validar o certificado de J, mas não participa diretamente no processo de decriptação da assinatura digital de M.

(d) Errado. Não é necessário usar a chave privada de AC no processo de verificação da assinatura digital. A chave privada de uma Autoridade Certificadora é usada exclusivamente por ela para assinar certificados digitais.

(e) Errado. A chave privada de J é utilizada para criar a assinatura digital, e a entidade K não necessita dessa chave para a verificação. A chave pública de AC é usada para validar o certificado de J, não para decriptar a assinatura digital de M.



Gabarito: Letra A

32.(CESGRANRIO / AgeRIO - 2023) Para evitar a utilização inadequada de recursos de informática em uma organização, é comum que sejam configuradas credenciais de acesso, como, por exemplo, um nome de usuário e uma senha associada. Essas credenciais podem ser utilizadas para controlar acesso a computadores (estações de trabalho), arquivos compartilhados na nuvem e sistemas de informação, entre outros. Uma boa prática que pode ser usada no que se refere a senhas é:

- a) anotar a sua senha e deixá-la afixada próxima à sua estação de trabalho, pois caso ela seja esquecida, não haverá uma interrupção no seu trabalho.
- b) confirmar a sua senha por telefone, caso venha a ser solicitado.
- c) definir uma senha que não possa ser facilmente adivinhada, de modo que apenas você tenha o seu conhecimento.
- d) garantir que seus colegas mais próximos saibam a sua senha, para que ela possa ser utilizada na sua ausência.
- e) informar a sua senha a qualquer pessoa que a solicite e que trabalhe na mesma organização em que você atue.

Comentários:

- (a) Errado. Anotar a senha e deixá-la afixada próxima à estação de trabalho é uma prática altamente insegura. Isso expõe a senha a qualquer pessoa que passe pela área, aumentando o risco de acesso não autorizado.
- (b) Errado. Confirmar a senha por telefone não é recomendado, especialmente se a solicitação vem de uma fonte não verificada. Isso pode ser uma tentativa de phishing ou outro tipo de ataque para obter credenciais de acesso indevidamente.
- (c) Correto. Definir uma senha forte e única, que não possa ser facilmente adivinhada, é uma prática essencial de segurança. A senha deve ser conhecida apenas pelo usuário, sendo complexa o suficiente para resistir a tentativas de adivinhação ou ataques de força bruta.
- (d) Errado. Compartilhar a senha com colegas, mesmo os mais próximos, compromete a segurança das informações. Cada usuário deve ter suas próprias credenciais para garantir a responsabilização e a rastreabilidade das ações no sistema.
- (e) Errado. Nunca se deve informar a senha a qualquer pessoa que a solicite, mesmo que trabalhe na mesma organização. A senha é pessoal e intransferível, e sua divulgação pode levar a violações de segurança.

Gabarito: Letra C

33.(CESGRANRIO / BB - 2023) Os mecanismos de segurança combinam técnicas e ações de segurança para prover a proteção de usuários e de dados. O mecanismo de segurança que consiste em definir as ações que uma determinada entidade pode executar, ou a quais informações essa entidade pode ter acesso, é o de:



- a) identificação
- b) integridade
- c) autenticação
- d) autorização
- e) confidencialidade

Comentários:

(a) Errado. Este mecanismo está relacionado ao processo de reconhecimento de um usuário no sistema. A identificação normalmente ocorre por meio de um nome de usuário ou ID, mas não define as permissões ou acessos desse usuário.

(b) Errado. Refere-se à garantia de que os dados não serão alterados de forma não autorizada. Este mecanismo assegura a precisão e a consistência dos dados ao longo do tempo, mas não está diretamente relacionado ao controle de ações ou acesso a informações.

(c) Errado. Este processo confirma a identidade de um usuário ou entidade. Normalmente ocorre após a identificação e pode envolver senhas, tokens ou outros métodos. A autenticação verifica se o usuário é quem afirma ser, mas não define suas permissões.

(d) Correto. Este mecanismo determina as ações que uma entidade pode executar ou a quais informações pode ter acesso após ter sido identificada e autenticada. A autorização define o que um usuário está permitido fazer no sistema.

(e) Errado. Refere-se à proteção de informações para que sejam acessadas apenas por pessoas autorizadas. Embora esteja relacionada ao acesso a dados, ela é mais sobre proteger os dados de acessos não autorizados, e não sobre definir quais ações um usuário pode executar.

Gabarito: Letra D

34.(CESGRANRIO / BB - 2023) Para acessar sistemas de informação é comum que seus usuários sejam solicitados a informar suas credenciais, que normalmente são definidas por meio de uma identificação de usuário e uma senha. Como identificação de usuário é comum ser utilizado o email ou o CPF do usuário. Nesse contexto, um exemplo de uma senha bem formada e segura é:

- a) "XYZ", pois é fácil de lembrar
- b) "1234567", pois é fácil de lembrar e tem tamanho adequado
- c) A data de aniversário do usuário
- d) Igual à identificação do usuário
- e) "Yk.9821-Z"

Comentários:

(a) Errado. É muito curta e simples, o que a torna vulnerável a ataques de força bruta; (b) Errado. Apesar de ter um tamanho razoável, usa apenas números e uma sequência óbvia, o que a torna insegura; (c) Errado. A data de aniversário do usuário: É uma informação pessoal facilmente acessível, tornando a senha previsível; (d) Errado. Igual à identificação do usuário: Usar a mesma informação para o nome de usuário e senha é uma prática de segurança extremamente fraca, pois uma vez que o nome de usuário é conhecido, a senha também seria; (e) Correto. Esse é um exemplo de senha bem formada e segura dado que é complexa, tem um bom tamanho e não é baseada em informações pessoais.



Gabarito: Letra E

35.(CESGRANRIO / BANRISUL - 2023) Os serviços de segurança de uma empresa são implementados por mecanismos de segurança e visam a satisfazer os requisitos da política de segurança dessa empresa. Para aprimorar o serviço de segurança que controla o acesso aos sistemas de informação, o controle de autenticação em uma etapa de verificação está sendo substituído pelo controle de autenticação em mais de uma etapa de verificação. Esse controle em mais de uma etapa de verificação é conhecido como autenticação:

- a) complexa
- b) resistente
- c) qualificada
- d) estendida
- e) multifator

Comentários:

A autenticação em mais de uma etapa de verificação é conhecida como autenticação multifator. A autenticação multifator (MFA, do inglês Multi-Factor Authentication) é um método de controle de acesso que requer mais de uma forma independente de verificação para estabelecer a identidade do usuário. Este método melhora significativamente a segurança, pois mesmo que uma das credenciais seja comprometida, é improvável que um invasor possua as outras formas de verificação. As outras opções, como autenticação complexa, resistente, qualificada e estendida, não são termos padrão usados para descrever a autenticação em mais de uma etapa.

Gabarito: Letra E

36.(CESGRANRIO / BB - 2023) O mecanismo de segurança é um método ou processo que pode ser utilizado por um sistema para implementar um serviço de segurança. Para verificar a autenticidade ou a autoria de um documento com relação ao seu signatário, deve-se validar a(o):

- a) envelope digital
- b) assinatura digital
- c) criptograma simétrico
- d) chave simétrica
- e) algoritmo simétrico

Comentários:

(a) Errado. O envelope digital é uma técnica usada para proteger informações confidenciais, mas não é usada diretamente para verificar a autenticidade ou autoria de um documento.

(b) Correto. A assinatura digital é usada para confirmar que um documento eletrônico é autêntico, ou seja, foi criado pelo signatário alegado e não foi alterado após a assinatura.

(c) Errado. Um criptograma simétrico é um texto cifrado usando criptografia simétrica, mas não se destina à verificação de autenticidade ou autoria de um documento.

(d) Errado. Uma chave simétrica é usada na criptografia simétrica para cifrar e decifrar mensagens, mas não para validar a autenticidade ou autoria de um documento.



(e) Errado. Um algoritmo simétrico é um método para cifrar e decifrar mensagens, mas, novamente, não é utilizado para verificar a autenticidade ou autoria de um documento.

Gabarito: Letra B

37.(CESGRANRIO / AgeRIO - 2023) Para evitar a utilização inadequada de recursos de informática em uma organização, é comum que sejam configuradas credenciais de acesso, como, por exemplo, um nome de usuário e uma senha associada. Essas credenciais podem ser utilizadas para controlar acesso a computadores (estações de trabalho), arquivos compartilhados na nuvem e sistemas de informação, entre outros. Uma boa prática que pode ser usada no que se refere a senhas é:

- a) anotar a sua senha e deixá-la afixada próxima à sua estação de trabalho, pois caso ela seja esquecida, não haverá uma interrupção no seu trabalho.
- b) confirmar a sua senha por telefone, caso venha a ser solicitado.
- c) definir uma senha que não possa ser facilmente adivinhada, de modo que apenas você tenha o seu conhecimento.
- d) garantir que seus colegas mais próximos saibam a sua senha, para que ela possa ser utilizada na sua ausência.
- e) informar a sua senha a qualquer pessoa que a solicite e que trabalhe na mesma organização em que você atue.

Comentários:

(a) Errado. Anotar a senha e deixá-la afixada próxima à estação de trabalho é uma prática altamente insegura. Isso expõe a senha a qualquer pessoa que passe pela área, aumentando o risco de acesso não autorizado.

(b) Errado. Confirmar a senha por telefone não é recomendado, especialmente se a solicitação vem de uma fonte não verificada. Isso pode ser uma tentativa de phishing ou outro tipo de ataque para obter credenciais de acesso indevidamente.

(c) Correto. Definir uma senha forte e única, que não possa ser facilmente adivinhada, é uma prática essencial de segurança. A senha deve ser conhecida apenas pelo usuário, sendo complexa o suficiente para resistir a tentativas de adivinhação ou ataques de força bruta.

(d) Errado. Compartilhar a senha com colegas, mesmo os mais próximos, compromete a segurança das informações. Cada usuário deve ter suas próprias credenciais para garantir a responsabilização e a rastreabilidade das ações no sistema.

(e) Errado. Nunca se deve informar a senha a qualquer pessoa que a solicite, mesmo que trabalhe na mesma organização. A senha é pessoal e intransferível, e sua divulgação pode levar a violações de segurança.

Gabarito: Letra C

38.(CESGRANRIO / BB - 2023) Os mecanismos de segurança combinam técnicas e ações de segurança para prover a proteção de usuários e de dados. O mecanismo de segurança que



consiste em definir as ações que uma determinada entidade pode executar, ou a quais informações essa entidade pode ter acesso, é o de:

- a) identificação
- b) integridade
- c) autenticação
- d) autorização
- e) confidencialidade

Comentários:

(a) Errado. Este mecanismo está relacionado ao processo de reconhecimento de um usuário no sistema. A identificação normalmente ocorre por meio de um nome de usuário ou ID, mas não define as permissões ou acessos desse usuário.

(b) Errado. Refere-se à garantia de que os dados não serão alterados de forma não autorizada. Este mecanismo assegura a precisão e a consistência dos dados ao longo do tempo, mas não está diretamente relacionado ao controle de ações ou acesso a informações.

(c) Errado. Este processo confirma a identidade de um usuário ou entidade. Normalmente ocorre após a identificação e pode envolver senhas, tokens ou outros métodos. A autenticação verifica se o usuário é quem afirma ser, mas não define suas permissões.

(d) Correto. Este mecanismo determina as ações que uma entidade pode executar ou a quais informações pode ter acesso após ter sido identificada e autenticada. A autorização define o que um usuário está permitido fazer no sistema.

(e) Errado. Refere-se à proteção de informações para que sejam acessadas apenas por pessoas autorizadas. Embora esteja relacionada ao acesso a dados, ela é mais sobre proteger os dados de acessos não autorizados, e não sobre definir quais ações um usuário pode executar.

Gabarito: Letra D

39.(CESGRANRIO / BB - 2023) Para acessar sistemas de informação é comum que seus usuários sejam solicitados a informar suas credenciais, que normalmente são definidas por meio de uma identificação de usuário e uma senha. Como identificação de usuário é comum ser utilizado o email ou o CPF do usuário. Nesse contexto, um exemplo de uma senha bem formada e segura é:

- a) "XYZ", pois é fácil de lembrar
- b) "1234567", pois é fácil de lembrar e tem tamanho adequado
- c) A data de aniversário do usuário
- d) Igual à identificação do usuário
- e) "Yk.9821-Z"

Comentários:

(a) Errado. É muito curta e simples, o que a torna vulnerável a ataques de força bruta; (b) Errado. Apesar de ter um tamanho razoável, usa apenas números e uma sequência óbvia, o que a torna insegura; (c) Errado. A data de aniversário do usuário: É uma informação pessoal facilmente acessível, tornando a senha previsível; (d) Errado. Igual à identificação do usuário: Usar a mesma informação para o nome de usuário e senha é uma prática de segurança extremamente fraca, pois uma vez que o nome de usuário é



conhecido, a senha também seria; (e) Correto. Esse é um exemplo de senha bem formada e segura dado que é complexa, tem um bom tamanho e não é baseada em informações pessoais.

Gabarito: Letra E

40.(CESGRANRIO / BANRISUL - 2023) Os serviços de segurança de uma empresa são implementados por mecanismos de segurança e visam a satisfazer os requisitos da política de segurança dessa empresa. Para aprimorar o serviço de segurança que controla o acesso aos sistemas de informação, o controle de autenticação em uma etapa de verificação está sendo substituído pelo controle de autenticação em mais de uma etapa de verificação. Esse controle em mais de uma etapa de verificação é conhecido como autenticação:

- a) complexa
- b) resistente
- c) qualificada
- d) estendida
- e) multifator

Comentários:

A autenticação em mais de uma etapa de verificação é conhecida como autenticação multifator. A autenticação multifator (MFA, do inglês Multi-Factor Authentication) é um método de controle de acesso que requer mais de uma forma independente de verificação para estabelecer a identidade do usuário. Este método melhora significativamente a segurança, pois mesmo que uma das credenciais seja comprometida, é improvável que um invasor possua as outras formas de verificação. As outras opções, como autenticação complexa, resistente, qualificada e estendida, não são termos padrão usados para descrever a autenticação em mais de uma etapa.

Gabarito: Letra E

41.(VUNESP / Prefeitura de Itapevi - SP - 2019) No processo de Assinatura Digital, a função hash é utilizada para:

- a) criptografar a Assinatura Digital a ser enviada.
- b) criptografar o documento original.
- c) gerar a Chave Privada do receptor do documento.
- d) gerar a Chave Pública do emissor do documento.
- e) gerar um resumo do documento original.

Comentários:

A função de hash é utilizada para gerar um resumo (*message digest*) do documento original.

Gabarito: Letra E

42.(VUNESP / Câmara de Piracicaba - SP - 2019) A metodologia de autenticação que usa dois ou mais fatores como evidência para identificar o usuário visa:

- a) dificultar o acesso ao sistema.
- b) discipliná-lo a usar mecanismos seguros de autenticação.
- c) forçá-lo a utilizar senhas seguras.
- d) impedir o compartilhamento das credenciais de acesso.
- e) minimizar o impacto caso uma das formas de autenticação tenha sido comprometida.



Comentários:

Essa metodologia evidentemente visa minimizar o impacto caso uma das formas de autenticação tenha sido comprometida.

Gabarito: Letra E

43.(VUNESP / Câmara de Piracicaba - SP - 2019) Um sistema utiliza como hash criptográfico a soma do valor numérico de cada caractere da mensagem. O algoritmo de hash é frágil, pois:

- a) não é possível determinar uma função inversa.
- b) produz o efeito avalanche.
- c) possui baixa resistência a colisões.
- d) o código hash gerado é único
- e) demanda um elevado poder computacional para ser calculado.

Comentários:

A questão trata de uma possível função de hash que é a soma do valor numérico de cada caractere. Ex: A = 1; B = 2; C = 3; D = 4; E = 5. Logo, temos que: ABC = 1+2+3 = 6; AE = 1+5 = 6; EA = 5+1 = 6; BD = 2+4 = 6; DB = 4+2 = 6; CC = 3+3 = 6. Notem que temos resultados iguais para várias entradas diferentes. Dito isso, vamos para a análise dos itens: (a) Errado, nesse caso seria robusto e, não, frágil; (b) Errado, desconheço efeito avalanche; (c) Correto, várias combinações podem gerar o mesmo hash, logo ele possui baixa resistência a colisões; (d) Errado, nesse caso seria robusto e, não, frágil; (e) Errado, nesse caso seria robusto e, não, frágil.

Gabarito: Letra C

44.(VUNESP / UFABC - 2019) O ICP-Brasil gerencia a cadeia de confiança para a emissão de certificados digitais no Brasil. Dentre os tipos de certificados emitidos pelo ICP-Brasil, o que é utilizado exclusivamente para a criptografia de dados é:

- a) A.
- b) B.
- c) C.
- d) S.
- e) T.

Comentários:

Basta lembrar que criptografia gera confidencialidade, que é sinônimo de (S)igilo.

Gabarito: Letra D

45.(VUNESP / Prefeitura de Guarulhos - SP - 2019) O processo de Assinatura Digital de documentos digitais inclui recursos para garantir os fatores de segurança da informação. Nesse processo, o recurso utilizado para garantir o não repúdio, ou a irretratabilidade, é:

- a) a chave privada do Certificado Digital do autor do documento.
- b) a chave pública do Certificado Digital do autor do documento.
- c) a chave pública do Certificado Digital do receptor do documento.



- d) o índice positivo de confiabilidade da Autoridade Certificadora (CA).
- e) o resumo criptográfico gerado a partir do documento.

Comentários:

Para garantir a irretratabilidade, devemos garantir a autenticidade + integridade. *Por que?* Porque se eu garanto que uma mensagem só pode ter sido enviada por uma determinada entidade e que a mensagem não foi modificada no meio do caminho, então essa entidade não pode repudiar seu envio. Logo, podemos utilizar o processo de assinatura digital, que consiste na utilização da chave privada do autor do documento para assinar digitalmente o resumo criptográfico gerado a partir do documento original e enviá-lo junto do documento em claro.

Dito isso, a questão teria duas respostas: (a) e (e). No entanto, o primeiro item fala em chave privada do certificado digital do autor do documento. Ora, certificado digital não possui chave privada - ele é um documento que vincula uma chave pública a uma entidade. Logo, na minha humilde opinião, a resposta seria letra (e), mas a gloriosa banca afirma que o gabarito é (a). Discordo com veemência!

Gabarito: Letra A

46.(VUNESP / PC-BA - 2018) Considere o seguinte cenário:

Um usuário de um computador com sistema operacional Windows 10 deseja fazer um backup de todos os arquivos de documentos pessoais, que totalizam cerca de 500 Mbytes, armazenados na pasta C:\Users\usuário\Documentos.

A forma mais adequada para realizar o backup é:

- a) aglutinar os arquivos da pasta Documentos em um arquivo avi e gravar em DVD-R.
- b) criar a pasta C:\Users\usuário\backup e copiar todos os arquivos da pasta original.
- c) criar a pasta backup na pasta C:\Users\usuário\ Documentos e fazer a cópia dos arquivos.
- d) fazer uma cópia da pasta Documentos e de todos os arquivos dentro da pasta em um pendrive.
- e) transformar os arquivos para o formato tar e armazenar em uma mídia de fita magnética.

Comentários:

(a) Errado. O formato AVI é utilizado para armazenar áudio e vídeo e não é adequado para armazenamento de cópias de segurança;

(b) Errado. Não é uma boa prática armazenar cópias de segurança na mesma unidade onde estão os arquivos originais, visto que um incidente poderá acarretar a perda de ambos;

(c) Errado. Não é uma boa prática armazenar cópias de segurança na mesma unidade onde estão os arquivos originais, visto que um incidente poderá acarretar a perda de ambos;

(d) Correto. O pendrive possui uma memória não-volátil, isto é, os dados não são perdidos quando o pendrive é desconectado. Logo, é uma boa alternativa como memória auxiliar para armazenamento de cópias de segurança;

(e) Errado. Esse é um formato de arquivos compactados do sistema operacional Linux, no entanto isso não tem qualquer relevância em termos de backup. Ademais, a questão trata do Windows.

Gabarito: Letra D



47.(VUNESP / PC-SP - 2018) Um dos componentes utilizados em microcomputadores e que é utilizado em arranjos ou grupos de componentes, recebe a denominação por meio do acrônimo RAID. Um RAID corresponde a um conjunto de:

- a) decodificadores.
- b) dispositivos de interface.
- c) discos.
- d) registradores.
- e) barramentos.

Comentários:

RAID é Redundant Array of Independent Disks ou Arranjo Redundante de Discos Independentes.

Gabarito: Letra C

48.(VUNESP / Câmara de Indaiatuba -SP - 2018) No âmbito da segurança da informação, o MD5 é:

- a) uma função hash criptográfica.
- b) um método de assinatura digital.
- c) um padrão de certificado digital.
- d) uma criptografia de chave pública.
- e) uma criptografia de chave simétrica.

Comentários:

MD5 é um exemplo de função de hash criptográfica.

Gabarito: Letra A

49.(VUNESP / Câmara Municipal de Pradópolis - 2016) Ao manipular arquivos e pastas, é importante ter cópias de segurança dos arquivos e pastas utilizados. O MS-Windows 7, em sua configuração padrão, possui recursos para fazer cópias de segurança de arquivos e pastas.

Assinale a alternativa que contém o nome dado ao procedimento de cópias de segurança.

- a) Limpeza de Disco.
- b) Clone.
- c) Sincronização.
- d) Fragmentação.
- e) Backup.

Comentários:

O procedimento de realização de cópias de segurança é o... backup.

Gabarito: Letra E

50.(VUNESP / PC-SP - 2014) Assinale a alternativa que contém o endereço de uma página da internet cujo acesso está utilizando técnica de criptografia.



- a) `http://www.sp.senac.br:8080`
- b) `https:\\www.globo.com/secur.php`
- c) `http://www.yahoo.com.br`
- d) `https://www.google.com.br`
- e) `http://gmail.com/portal1.html`

Comentários:

A questão menciona que o acesso é realizado utilizando técnica de criptografia, portanto só pode ser por meio do uso do Protocolo HTTPS. Sobram, portanto, duas opções, mas uma delas utiliza duas barras - na verdade, o correto é utilizar duas barras convencionais como `https://`.

Gabarito: Letra D



LISTA DE QUESTÕES – MULTIBANCAS

1. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O procedimento de associar a autenticação de dois fatores (2FA) ao uso de senha contribui muito pouco para o ganho de segurança da informação.
2. (CEBRASPE / MPE-TO - 2024) O controle de acesso físico é um procedimento de segurança utilizado para garantir a segurança de informação de uma empresa.
3. (CEBRASPE / MPE-TO - 2024) Ainda que muito eficiente, o uso de criptografia é insuficiente para garantir a segurança das informações em determinado computador.
4. (CEBRASPE / MPE-TO - 2024) A assinatura digital é um dos recursos mais eficientes para garantir o sigilo de uma informação.
5. (CEBRASPE / ITAIPU BINACIONAL - 2024) Tendo em vista que o uso diário de computadores para realizar atividades profissionais, de lazer ou estudos requer uma atenção especial por parte dos usuários, a fim de assegurar a proteção adequada de seus dados e arquivos, assinale a opção correta com referência às práticas fundamentais para garantir a segurança da informação.
 - a) Vírus de computador só tem capacidade de contaminar computadores que estiverem conectados em rede ou na Internet.
 - b) Manter softwares de antivírus atualizados impede o acesso não autorizado ao computador.
 - c) Mesclar letras, números e caracteres especiais na definição de senhas é uma boa prática para torná-las mais seguras.
 - d) O acesso a serviços on-line em computadores de uso compartilhado, como em faculdades ou lan houses, não representa risco se for realizado o logout nos serviços antes de desligar o computador.
 - e) Abrir arquivos ou clicar em links recebidos por e-mails enviados por remetentes conhecidos não representa risco de segurança.
6. (CEBRASPE / Prefeitura de São Cristóvão-SE - 2023) A respeito de segurança da informação, assinale a opção correta.
 - a) O mero recebimento de um link com malware é suficiente para que o dispositivo do usuário seja contaminado, mesmo que ele não clique no link.
 - b) A instalação e a configuração de aplicativos de segurança bastam para garantir a proteção de dados e informações armazenados em um computador.
 - c) Entre os procedimentos de segurança da informação, recomenda-se não abrir anexos de emails recebidos de usuário desconhecido.
 - d) A instalação de firewalls no computador apenas garante um melhor desempenho da máquina, sem colaborar para a segurança da informação.



7. (CEBRASPE / AGER-MT - 2023) A ICP-Brasil foi criada para viabilizar a emissão de certificados digitais no país, para transações que precisam de validade e segurança dos dados. Conforme o ITI, e considerando o uso de um certificado digital ICP-Brasil, é correto afirmar que a assinatura digital é:

- a) A gerada a partir do uso do certificado digital ICP-Brasil e possui pleno valor jurídico garantido pela legislação brasileira.
- b) importada no computador via a cadeia de certificação nível a3 e possui pleno valor jurídico garantido pela legislação brasileira.
- c) gerada a partir do uso do certificado digital ICP-Brasil e seu valor jurídico depende da autoridade pública do município que é apresentado.
- d) gerada por um navegador, que também autentica automaticamente o certificado emissor, e está restrita ao governo federal pelas regras do judiciário.
- e) gerada a partir do uso do certificado digital ICP-Brasil e, uma vez assinado um documento, sua alteração é possível em qualquer situação nos sistemas de governo.

8. (CEBRASPE / TRT8 - 2022) Em uma VPN, a confidencialidade dos dados garante que:

- a) o conteúdo da mensagem não foi alterado durante a transmissão entre o emissor e o receptor.
- b) o conteúdo da mensagem foi armazenado fisicamente em ambiente seguro.
- c) a mensagem foi enviada por uma fonte autêntica e será entregue a um destino autêntico.
- d) o emissor não poderá repudiar o envio da mensagem, ou seja, dizer que não enviou a referida mensagem.
- e) a mensagem não poderá ser interpretada por origens não autorizadas.

9. (CEBRASPE / TRT8 - 2022) Em relação à criptografia assimétrica é correto afirmar que:

- a) a criptografia de chave pública pode ser menos segura, em relação à criptoanálise, do que a criptografia simétrica.
- b) a criptografia de chave pública é uma técnica de uso geral que tornou a criptografia simétrica obsoleta.
- c) a distribuição de chave pública é sempre mais trivial e fácil quando comparada com o mecanismo de troca de mensagens para distribuição de chave para a criptografia simétrica.
- d) envolve a utilização de duas chaves privadas para realizar a criptoanálise.
- e) utiliza os algoritmos simétricos Data Encryption Standard (DES) e o Triple DES (DES triplo).

10.(CEBRASPE / DPDF - 2022) O algoritmo de hash é capaz de verificar e validar a integridade de um arquivo.

11.(FCC / SEFAZ-AP - 2022) Para proteger as informações e a comunicação de dados que circulam em redes de computadores, o processo criptográfico tem por objetivo:



- a) a autenticação, a confidencialidade, o não repúdio e a integridade.
- b) a autenticação, a confidencialidade, o *hashing* e a temporização.
- c) a sanitização de dados, a integridade, a temporização e o não repúdio.
- d) o protecionismo, a confidencialidade, a verificação e a integridade.
- e) a temporização, a autenticação, o não repúdio e a informatização.

12.(FCC/ SEFAZ-SC - 2018) O estabelecimento e a implantação da segurança da informação requerem o uso de diferentes mecanismos e recursos para atender os atributos de segurança da informação. Nesse contexto, o Hash tem a função de:

- a) realizar a transformação reversível da informação de forma a torná-la ininteligível a terceiros.
- b) criar uma chave criptográfica a partir do certificado digital.
- c) comprovar a identidade do emissor de um documento.
- d) atestar a validade de um documento.
- e) garantir a integridade de um documento.

13.(FCC / FITO - 2020) Deseja-se adquirir um Certificado Digital para assegurar e comprovar a assinatura digital dos documentos emitidos por uma empresa. Considerando a aquisição por meio de um órgão autorizado pelo ICP-Brasil e que a chave deve ter o comprimento de 4096 bits, o tipo de Certificado a adquirir é:

- a) A1
- b) A3
- c) A4
- d) S1
- e) S3

14.(FCC / TJ-MA - 2019) Considere as asserções a seguir, a respeito do processo de autenticação usando criptografia assimétrica:

O autor utiliza sua chave privada para cifrar um documento de modo a garantir sua autoria ou sua identificação em uma transação. Se este autor cifrar um documento com sua chave privada e enviar para o destinatário, este poderá decifrar o documento

PORQUE

pode ter acesso à chave privada do autor. O fato de ser necessário o uso da chave privada do autor para produzir o texto cifrado caracteriza uma operação que somente ele tem condições de realizar.

É correto afirmar que:

- a) as duas asserções são verdadeiras, sendo a segunda a justificativa correta da primeira.
- b) as duas asserções são falsas.
- c) a primeira asserção é falsa e a segunda é verdadeira.
- d) a primeira asserção é verdadeira e a segunda é falsa.
- e) as duas asserções são verdadeiras, porém a segunda não é a justificativa correta da primeira.

15.(FCC / TJ-MA - 2019) As informações protegidas utilizando os algoritmos de criptografia assimétrica têm garantidas, em teoria,

- a) somente a confidencialidade.



- b) tanto a confidencialidade quanto a autenticidade.
- c) somente a integridade.
- d) somente a autenticidade.
- e) tanto a confidencialidade quanto a veracidade.

16.(FCC / SANASA - 2019) Além de ser usado para verificar transações com criptomoedas, como Bitcoin, a função hash é usada em assinaturas digitais, para:

- a) garantir a integridade do documento assinado.
- b) aumentar o tempo de autenticação da assinatura.
- c) gerar um valor aleatório de tamanho variável.
- d) garantir a autenticidade do documento assinado.
- e) gerar um resumo de 256 bits por meio do algoritmo RSA.

17.(FCC / Prefeitura de Manaus/AM - 2019) No processo da assinatura digital, a propriedade que identifica qualquer alteração no documento e faz com que a assinatura não seja mais reconhecida garantindo, assim, a inalterabilidade, é denominada:

- a) autenticidade.
- b) autoria.
- c) integridade.
- d) não repúdio.
- e) irretratabilidade.

18.(FCC / TRF4 - 2019) Considere o esquema hipotético abaixo referente à comunicação segura estabelecida pelo Tribunal Regional Federal da 4ª Região - TRF4:



O esquema descreve:

- a) autenticação e gerenciamento de sessão.
- b) autenticação segura com XSS via assinatura eletrônica.
- c) criptografia de chave assimétrica.
- d) comunicação segura híbrida de chave pública.
- e) criptografia de chave simétrica.

19.(FCC / TRF4 - 2019) Considere o esquema abaixo.





Trata-se de uma hipotética comunicação criptografada entre o computador de um Juiz e um computador do TRF4. Os textos Chave, Processo 1 e Processo 2, bem como a categoria de criptografia apresentados no esquema representam, correta e respectivamente,

- a) chave secreta compartilhada, decriptografia, criptografia e criptografia de chave assimétrica.
- b) chave pública, criptografia, decriptografia e criptografia de chave assimétrica.
- c) chave secreta compartilhada, criptografia, decriptografia e criptografia de chave simétrica.
- d) chave pública, decriptografia, criptografia e criptografia de chave simétrica.
- e) chave pública compartilhada, criptografia, decriptografia e criptografia de curvas elípticas.

20.(FCC / SEGE-MA - 2018) A segurança da informação considera alguns atributos básicos como: confidencialidade, integridade, disponibilidade, autenticidade e irretratabilidade. O mecanismo de segurança da informação que tem o objetivo de garantir a confidencialidade é:

- a) a assinatura digital.
- b) o certificado digital.
- c) a função hash.
- d) o Token criptográfico.
- e) a criptografia.

21.(FGV / Câmara dos Deputados - 2023) Na área da Segurança da Informação, há aspectos fundamentais para o desenvolvimento de políticas de armazenamento e uso de dados, tais como Confidencialidade, Integridade, Disponibilidade e Autenticidade. No campo da Tecnologia da Informação, dada a necessidade de trafegar dados pela Internet, a confidencialidade torna-se um ponto crítico. Nesse contexto, assinale a estratégia de proteção mais adequada para preservar a confiabilidade de dados.

- a) Criação de backups em tempo real.
- b) Emprego de software antivírus.
- c) Instalação de centros de supercomputação.
- d) Redundância nos dispositivos de armazenamento.
- e) Uso de criptografia.

22.(FGV / SEFAZ-MT - 2023) Algoritmos de ciframento são frequentemente utilizados para proteger informações, transações comerciais e financeiras realizadas por meio de meios eletrônicos, em particular, pela internet.

Sobra esses algoritmos, assinale a afirmativa correta.

- a) 3DES é uma função de espelhamento unidirecional.
- b) ElGamal é um algoritmo de chave privada.
- c) AES é um algoritmo assimétrico com chaves de tamanho fixo.
- d) Blowfish é uma cifra simétrica de blocos.
- e) SHA é um algoritmo de chave pública de tamanho variável.



23.(FGV / SEAD-AP - 2022) Com relação aos métodos de criptografia de chave pública, considere as afirmativas a seguir.

- I. Cada participante em um sistema de chave pública possui um par de chaves, uma pública e outra, privada.
- II. Qualquer participante pode criptografar e decriptografar uma mensagem usando a própria chave privada.
- III. Quando o participante P1 envia uma mensagem criptografada para P2, é preciso que P2 conheça a chave privada de P1.

É correto somente o que se afirma em

- a) I.
- b) II.
- c) III.
- d) I e II.
- e) II e III.

24.(FGV / TCE-TO - 2022) O auditor José recebeu o arquivo AnexoJ em formato digital. Antes de proceder com a abertura do AnexoJ, José determinou a fidedignidade do referido arquivo, avaliando a conformidade dos dados do AnexoJ por ele recebido com os dados do AnexoJ transmitido pelo emissor.

Essa avaliação feita por José em AnexoJ está diretamente relacionada com o seguinte princípio da segurança de informações:

- a) integridade;
- b) confidencialidade;
- c) autenticidade;
- d) disponibilidade;
- e) qualidade.

25.(FGV / TCE-TO - 2022) As funções de hash são comumente empregadas nos mecanismos de segurança da informação.

Quanto às suas propriedades básicas, para que o algoritmo de hash seja considerado forte, é correto afirmar que:

- a) a mesma entrada deve produzir saídas diferentes;
- b) deve ser difícil encontrar duas entradas que produzam o mesmo hash;
- c) deve ser possível produzir a entrada original a partir do hash resultante;
- d) pequenas mudanças na entrada devem produzir pequenas mudanças no hash resultante;
- e) mesmo que as entradas possuam o mesmo tamanho, os resultados de hash terão tamanhos diferentes.

26.(FGV / TCE-TO - 2022) Bernardo e João são auditores recém-concursados no TCE/TO. Bernardo precisa enviar documentos sigilosos para João e vice-versa, contudo, nenhum deles utilizou ainda a ferramenta de criptografia disponível na instituição.

Sabendo-se que é utilizada a criptografia por chave pública, o procedimento que deve ser seguido por cada auditor antes de tramitar os documentos é:



- a) gerar um par de chaves a ser usado para encriptação e decriptação dos documentos; importar a chave pública no registrador público da instituição; guardar a chave privada; e encriptar os documentos utilizando a chave pública do destinatário;
- b) gerar um par de chaves a ser usado para encriptação e decriptação dos documentos; importar a chave pública no registrador público da instituição; enviar a chave privada para o destinatário; e encriptar um documento utilizando a chave privada enviada;
- c) gerar um par de chaves a ser usado para encriptação e decriptação dos documentos; importar a chave pública no registrador público da instituição; guardar a chave privada; e encriptar os documentos utilizando a chave privada do remetente;
- d) gerar a chave pública para encriptação e decriptação dos documentos; enviar a chave pública para o destinatário; e encriptar os documentos utilizando a chave pública enviada;
- e) combinar uma senha entre eles; encriptar e decriptar os documentos utilizando a senha combinada.

27.(FGV / TRT-MA - 2022) Os sistemas de chave pública são caracterizados pelo uso de um algoritmo criptográfico com duas chaves, uma privada e uma pública. Com relação às categorias de uso dos criptossistemas de chave pública, analise as afirmativas a seguir:

- I. Criptografia/descriptografia: um emissor criptografa uma mensagem com a chave pública do seu destinatário.
- II. Assinatura digital: um emissor assina uma mensagem com sua chave pública. A assinatura é feita por um algoritmo criptográfico aplicado à mensagem ou a um pequeno bloco de dados que é uma função da mensagem.
- III. Troca de chave: dois lados cooperam para trocar uma chave de sessão. Várias técnicas diferentes são possíveis, envolvendo as chaves públicas de uma ou de ambas as partes.

Está correto o que se afirma em

- a) I, apenas.
- b) II, apenas.
- c) III, apenas.
- d) I e II, apenas.
- e) II e III, apenas.

28.(FGV / MPE-GO - 2022) João quer usar um serviço de armazenamento em nuvem que ofereça o recurso de verificação de sua identidade em duas etapas. Para isso, João escolheu um serviço que usa um aplicativo autenticador instalado em seu dispositivo móvel.

O tipo de verificação em duas etapas do serviço escolhido por João é o(a):

- a) código de verificação.
- b) token gerador de senhas.
- c) cartão de segurança.
- d) dispositivo confiável.
- e) chave de recuperação.



29.(FGV / TJDF - 2022) Ana precisa enviar a mensagem M para Bráulio de forma sigilosa pela rede do Tribunal de Justiça atendendo aos requisitos de segurança: autenticidade, não repúdio, integridade e confidencialidade. Para isso, Ana deve enviar uma chave secreta K para Bráulio e gerar uma assinatura digital AD(M).

Considerando que a chave K deve ser conhecida apenas por Ana e Bráulio, após esse processo deve-se cifrar K e AD(M) com a chave:

- a) privada de Bráulio;
- b) privada de Ana;
- c) pública de Ana;
- d) pública de Bráulio;
- e) secreta de Ana.

30.(FGV / TJDF - 2022) Lucas é um trader profissional que trabalha em uma corretora de valores. Ele efetua muitas operações durante o período em que a bolsa negocia seus ativos. Após fazer uma revisão em suas operações do dia, não validou, como sendo efetuadas por ele, algumas das operações que obtiveram prejuízo. Lucas, então, entrou em contato com a corretora e esta demonstrou, a partir de registros de auditoria e garantia de identidade, que as operações em questão realmente foram executadas por ele.

Para que a corretora prove que foi Lucas quem realmente executou as operações, ela deve fazer uso do conceito de segurança chamado:

- a) confidencialidade;
- b) autenticidade;
- c) integridade;
- d) disponibilidade;
- e) irretratabilidade.

31.(CESGRANRIO / IPEA - 2024) A entidade J enviou uma mensagem (M) assinada para a entidade K, utilizando o padrão RSA de assinatura digital. A assinatura digital (AD) de M está acompanhada do certificado digital de J (CertJ/AC), emitido pela Autoridade Certificadora (AC). A entidade K tem confiança na AC; logo, o certificado digital da AC (CertAC/AC), emitido pela própria AC, está armazenado na sua base de certificados digitais confiáveis. Ambos os certificados digitais CertJ/AC e CertAC/AC passaram no teste de validação de certificados digitais, e a cadeia de certificados está verificada com sucesso.

Como parte do processo de verificação da AD de M, a entidade K deve decriptar a AD com a(as) chave(s):

- a) pública de J, presente em CertJ/AC
- b) pública de AC, presente em CertAC/AC
- c) públicas de J e de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC
- d) pública de J e a privada de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC
- e) privada de J e a pública de AC, presentes, respectivamente, em CertJ/AC e CertAC/AC

32.(CESGRANRIO / AgeRIO - 2023) Para evitar a utilização inadequada de recursos de informática em uma organização, é comum que sejam configuradas credenciais de acesso, como, por exemplo, um nome de usuário e uma senha associada. Essas credenciais podem ser utilizadas para controlar acesso a computadores (estações de trabalho), arquivos compartilhados na



nuvem e sistemas de informação, entre outros. Uma boa prática que pode ser usada no que se refere a senhas é:

- a) anotar a sua senha e deixá-la afixada próxima à sua estação de trabalho, pois caso ela seja esquecida, não haverá uma interrupção no seu trabalho.
- b) confirmar a sua senha por telefone, caso venha a ser solicitado.
- c) definir uma senha que não possa ser facilmente adivinhada, de modo que apenas você tenha o seu conhecimento.
- d) garantir que seus colegas mais próximos saibam a sua senha, para que ela possa ser utilizada na sua ausência.
- e) informar a sua senha a qualquer pessoa que a solicite e que trabalhe na mesma organização em que você atue.

33.(CESGRANRIO / BB - 2023) Os mecanismos de segurança combinam técnicas e ações de segurança para prover a proteção de usuários e de dados. O mecanismo de segurança que consiste em definir as ações que uma determinada entidade pode executar, ou a quais informações essa entidade pode ter acesso, é o de:

- a) identificação
- b) integridade
- c) autenticação
- d) autorização
- e) confidencialidade

34.(CESGRANRIO / BB - 2023) Para acessar sistemas de informação é comum que seus usuários sejam solicitados a informar suas credenciais, que normalmente são definidas por meio de uma identificação de usuário e uma senha. Como identificação de usuário é comum ser utilizado o email ou o CPF do usuário. Nesse contexto, um exemplo de uma senha bem formada e segura é:

- a) "XYZ", pois é fácil de lembrar
- b) "1234567", pois é fácil de lembrar e tem tamanho adequado
- c) A data de aniversário do usuário
- d) Igual à identificação do usuário
- e) "Yk.9821-Z"

35.(CESGRANRIO / BANRISUL - 2023) Os serviços de segurança de uma empresa são implementados por mecanismos de segurança e visam a satisfazer os requisitos da política de segurança dessa empresa. Para aprimorar o serviço de segurança que controla o acesso aos sistemas de informação, o controle de autenticação em uma etapa de verificação está sendo substituído pelo controle de autenticação em mais de uma etapa de verificação. Esse controle em mais de uma etapa de verificação é conhecido como autenticação:

- a) complexa
- b) resistente
- c) qualificada
- d) estendida
- e) multifator



36.(CESGRANRIO / BB - 2023) O mecanismo de segurança é um método ou processo que pode ser utilizado por um sistema para implementar um serviço de segurança. Para verificar a autenticidade ou a autoria de um documento com relação ao seu signatário, deve-se validar a(o):

- a) envelope digital
- b) assinatura digital
- c) criptograma simétrico
- d) chave simétrica
- e) algoritmo simétrico

37.(CESGRANRIO / AgeRIO - 2023) Para evitar a utilização inadequada de recursos de informática em uma organização, é comum que sejam configuradas credenciais de acesso, como, por exemplo, um nome de usuário e uma senha associada. Essas credenciais podem ser utilizadas para controlar acesso a computadores (estações de trabalho), arquivos compartilhados na nuvem e sistemas de informação, entre outros. Uma boa prática que pode ser usada no que se refere a senhas é:

- a) anotar a sua senha e deixá-la afixada próxima à sua estação de trabalho, pois caso ela seja esquecida, não haverá uma interrupção no seu trabalho.
- b) confirmar a sua senha por telefone, caso venha a ser solicitado.
- c) definir uma senha que não possa ser facilmente adivinhada, de modo que apenas você tenha o seu conhecimento.
- d) garantir que seus colegas mais próximos saibam a sua senha, para que ela possa ser utilizada na sua ausência.
- e) informar a sua senha a qualquer pessoa que a solicite e que trabalhe na mesma organização em que você atue.

38.(CESGRANRIO / BB - 2023) Os mecanismos de segurança combinam técnicas e ações de segurança para prover a proteção de usuários e de dados. O mecanismo de segurança que consiste em definir as ações que uma determinada entidade pode executar, ou a quais informações essa entidade pode ter acesso, é o de:

- a) identificação
- b) integridade
- c) autenticação
- d) autorização
- e) confidencialidade

39.(CESGRANRIO / BB - 2023) Para acessar sistemas de informação é comum que seus usuários sejam solicitados a informar suas credenciais, que normalmente são definidas por meio de uma identificação de usuário e uma senha. Como identificação de usuário é comum ser utilizado o email ou o CPF do usuário. Nesse contexto, um exemplo de uma senha bem formada e segura é:

- a) "XYZ", pois é fácil de lembrar
- b) "1234567", pois é fácil de lembrar e tem tamanho adequado
- c) A data de aniversário do usuário



- d) Igual à identificação do usuário
- e) "Yk.9821-Z"

40.(CESGRANRIO / BANRISUL - 2023) Os serviços de segurança de uma empresa são implementados por mecanismos de segurança e visam a satisfazer os requisitos da política de segurança dessa empresa. Para aprimorar o serviço de segurança que controla o acesso aos sistemas de informação, o controle de autenticação em uma etapa de verificação está sendo substituído pelo controle de autenticação em mais de uma etapa de verificação. Esse controle em mais de uma etapa de verificação é conhecido como autenticação:

- a) complexa
- b) resistente
- c) qualificada
- d) estendida
- e) multifator

41.(VUNESP / Prefeitura de Itapevi - SP - 2019) No processo de Assinatura Digital, a função hash é utilizada para:

- a) criptografar a Assinatura Digital a ser enviada.
- b) criptografar o documento original.
- c) gerar a Chave Privada do receptor do documento.
- d) gerar a Chave Pública do emissor do documento.
- e) gerar um resumo do documento original.

42.(VUNESP / Câmara de Piracicaba - SP - 2019) A metodologia de autenticação que usa dois ou mais fatores como evidência para identificar o usuário visa:

- a) dificultar o acesso ao sistema.
- b) discipliná-lo a usar mecanismos seguros de autenticação.
- c) forçá-lo a utilizar senhas seguras.
- d) impedir o compartilhamento das credenciais de acesso.
- e) minimizar o impacto caso uma das formas de autenticação tenha sido comprometida.

43.(VUNESP / Câmara de Piracicaba - SP - 2019) Um sistema utiliza como hash criptográfico a soma do valor numérico de cada caractere da mensagem. O algoritmo de hash é frágil, pois:

- a) não é possível determinar uma função inversa.
- b) produz o efeito avalanche.
- c) possui baixa resistência a colisões.
- d) o código hash gerado é único
- e) demanda um elevado poder computacional para ser calculado.

44.(VUNESP / UFABC - 2019) O ICP-Brasil gerencia a cadeia de confiança para a emissão de certificados digitais no Brasil. Dentre os tipos de certificados emitidos pelo ICP-Brasil, o que é utilizado exclusivamente para a criptografia de dados é:

- a) A.
- b) B.
- c) C.
- d) S.
- e) T.



45.(VUNESP / Prefeitura de Guarulhos - SP - 2019) O processo de Assinatura Digital de documentos digitais inclui recursos para garantir os fatores de segurança da informação. Nesse processo, o recurso utilizado para garantir o não repúdio, ou a irretratabilidade, é:

- a) a chave privada do Certificado Digital do autor do documento.
- b) a chave pública do Certificado Digital do autor do documento.
- c) a chave pública do Certificado Digital do receptor do documento.
- d) o índice positivo de confiabilidade da Autoridade Certificadora (CA).
- e) o resumo criptográfico gerado a partir do documento.

Gabarito: Letra A

46.(VUNESP / PC-BA - 2018) Considere o seguinte cenário:

Um usuário de um computador com sistema operacional Windows 10 deseja fazer um backup de todos os arquivos de documentos pessoais, que totalizam cerca de 500 Mbytes, armazenados na pasta C:\Users\usuário\Documentos.

A forma mais adequada para realizar o backup é:

- a) aglutinar os arquivos da pasta Documentos em um arquivo avi e gravar em DVD-R.
- b) criar a pasta C:\Users\usuário\backup e copiar todos os arquivos da pasta original.
- c) criar a pasta backup na pasta C:\Users\usuário\ Documentos e fazer a cópia dos arquivos.
- d) fazer uma cópia da pasta Documentos e de todos os arquivos dentro da pasta em um pendrive.
- e) transformar os arquivos para o formato tar e armazenar em uma mídia de fita magnética.

47.(VUNESP / PC-SP - 2018) Um dos componentes utilizados em microcomputadores e que é utilizado em arranjos ou grupos de componentes, recebe a denominação por meio do acrônimo RAID. Um RAID corresponde a um conjunto de:

- a) decodificadores.
- b) dispositivos de interface.
- c) discos.
- d) registradores.
- e) barramentos.

48.(VUNESP / Câmara de Indaiatuba -SP - 2018) No âmbito da segurança da informação, o MD5 é:

- a) uma função hash criptográfica.
- b) um método de assinatura digital.
- c) um padrão de certificado digital.
- d) uma criptografia de chave pública.
- e) uma criptografia de chave simétrica.

49.(VUNESP / Câmara Municipal de Pradópolis - 2016) Ao manipular arquivos e pastas, é importante ter cópias de segurança dos arquivos e pastas utilizados. O MS-Windows 7, em sua configuração padrão, possui recursos para fazer cópias de segurança de arquivos e pastas.

Assinale a alternativa que contém o nome dado ao procedimento de cópias de segurança.

- a) Limpeza de Disco.
- b) Clone.



- c) Sincronização.
- d) Fragmentação.
- e) Backup.

50.(VUNESP / PC-SP - 2014) Assinale a alternativa que contém o endereço de uma página da internet cujo acesso está utilizando técnica de criptografia.

- a) <http://www.sp.senac.br:8080>
- b) <https://www.globo.com/secur.php>
- c) <http://www.yahoo.com.br>
- d) <https://www.google.com.br>
- e) <http://gmail.com/portal1.html>



GABARITO – MULTIBANCAS

1. ERRADO
2. CORRETO
3. CORRETO
4. ERRADO
5. LETRA C
6. LETRA C
7. LETRA A
8. LETRA E
9. LETRA A
10. CORRETO
11. LETRA A
12. LETRA E
13. LETRA C
14. LETRA D
15. LETRA B
16. LETRA A
17. LETRA C
18. LETRA C
19. LETRA C
20. LETRA E
21. LETRA E
22. LETRA D
23. LETRA A
24. LETRA A
25. LETRA B

26. LETRA A
27. LETRA A
28. LETRA A
29. LETRA D
30. LETRA E
31. LETRA A
32. LETRA C
33. LETRA D
34. LETRA E
35. LETRA E
36. LETRA B
37. LETRA C
38. LETRA D
39. LETRA E
40. LETRA E
41. LETRA E
42. LETRA E
43. LETRA C
44. LETRA D
45. LETRA D
46. LETRA D
47. LETRA C
48. LETRA A
49. LETRA E
50. LETRA D



ESSA LEI TODO MUNDO CONHECE: PIRATARIA É CRIME.

Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.



1 Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.



2 Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).



3 Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).



4 Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).



5 Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).



6 Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).



7 Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.



8 O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.